

第 4 篇 安全 VPN 技术

第 11 章 数据安全技术基础

第 12 章 IPsec 基本原理

第 13 章 IPsec 配置和应用

第 14 章 SSL VPN

第11章 数据安全技术基础

随着互联网用户的持续增长，基于互联网的应用逐步在电子商务、电子政务以及各个领域成熟，新的业务模式层出不穷。

由于互联网的开放型，随之而来的安全问题越来越紧迫的摆在我们的面前：用户帐号/密码被恶意窃取；私有或机密资料被泄露或被篡改；个人身份被假冒而造成损害；钓鱼网站层出不穷，用户安全无法得到保证，同时由于证据有限而增加纠纷及解决成本；进而由于感受到网络安全方面的弱点，造成用户裹足不前，影响网上应用的进一步发展。

11.1 本章目标

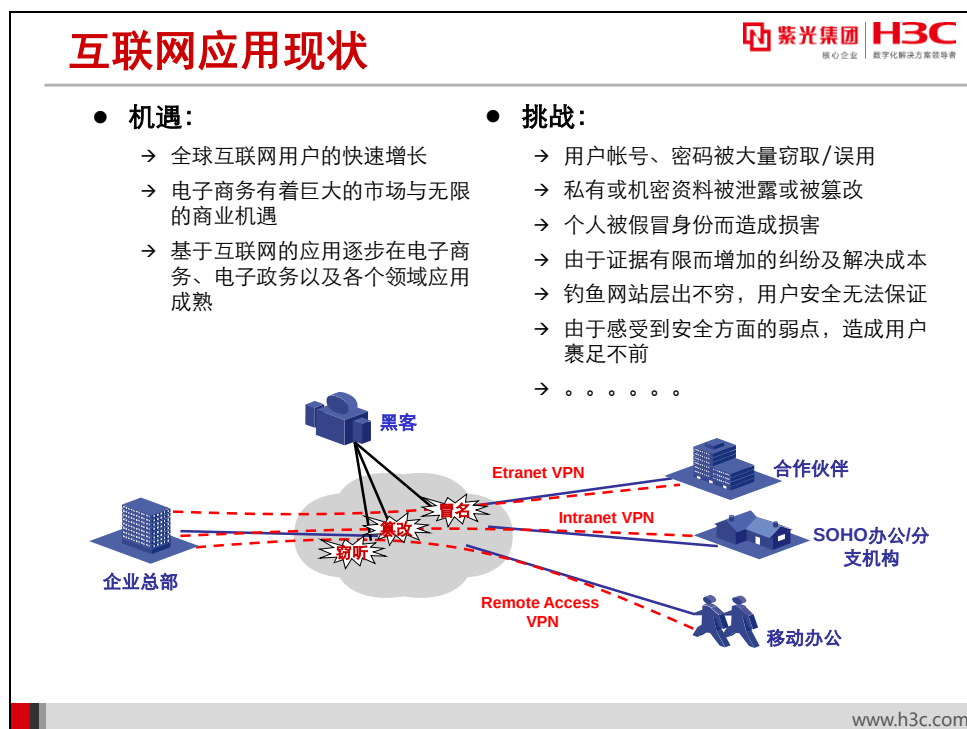
课程目标

● 学习完本课程，您应该能够：

- 描述数据传输面临的主要安全威胁
- 理解加密技术和密钥的概念
- 描述数字签名相关技术原理
- 掌握数字证书的概念及数字证书包含的主要内容
- 理解PKI体系，描述证书的发放、维护、回收的过程
- 独立进行PKI基本配置



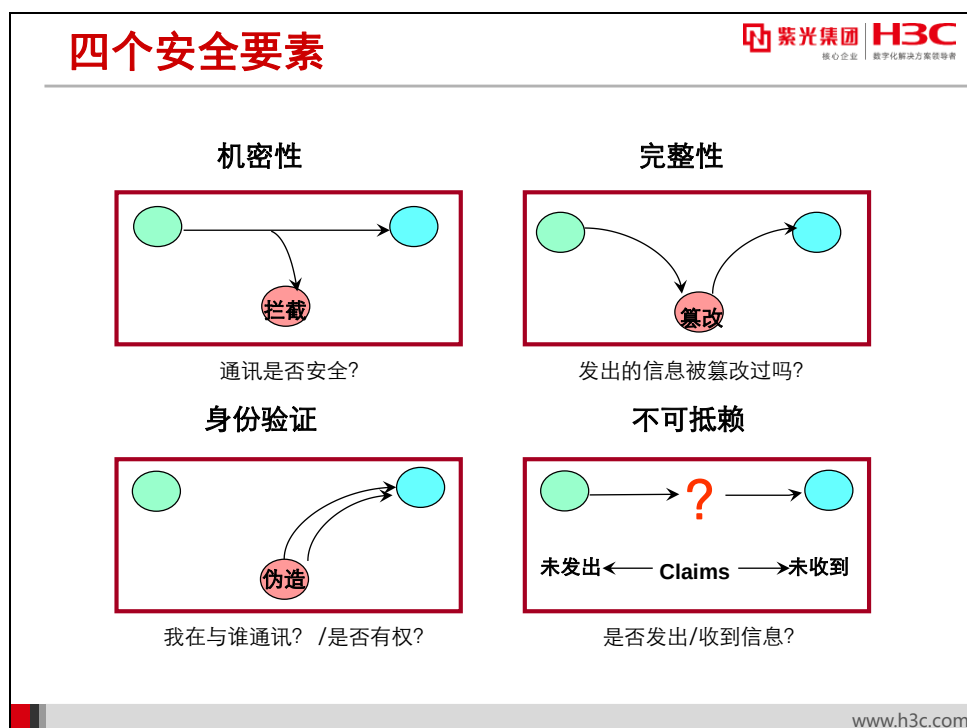
11.2 概念和术语



进入 21 世纪以来，全球互联网用户的快速增长。1996 年不足 0.4 亿，2000 年 6 月已经达到 2.6 亿以上，到 2005 年底则达到了 10.8 亿，并且仍在不断增长。

随着全球互联网用户的快速增长，电子商务面临巨大的市场与无限的商业机遇，蕴含着现实的和潜在的丰厚商业利润。1994 年全球电子商务销售额为 12 亿美元，1997 年达到 26 亿美元，增长了一倍多；1998 年销售额达 700 亿美元，比 1997 年增长近 30 倍；2000 年全球电子商务的交易额达到 3770 亿美元。2005 年底全球电子商务的交易额达到近 7000 亿美元，国内电子商务交易额达到 160 亿人民币。2006 年中国中小企业总数为 3151.8 万家，B2B 电子商务交易额为 330 亿元人民币，2007 年中国电子商务的交易额超过 600 亿人民币。预计 2010 年全球交易额可达 1 万亿美元，未来 10 年中 1/3 的全球国际贸易将以网络贸易的形式来完成。

但同时安全性问题越来越严峻，窃密、冒用、钓鱼网站等恶意手段越来越多，甚至成为世人关注的社会问题。



那么什么样的数据传输是安全的呢?

首先我们必须确保数据的机密性,不被窃取。所谓保证数据的机密性是指防止数据被未获得授权的查看者理解,从而在存储和传输的过程中,防止有意或无意信息内容泄露,保证信息安全。

完整性是另外一个基本的保密需求。所谓保证数据完整性是指防止数据在存储和传输的过程中受到非法的篡改。这种篡改既包括无授权者的篡改,也包括具备有限授权者的越权篡改。一些意外的错误也可能导致信息错误,完整性检查应该能发现这样的错误。

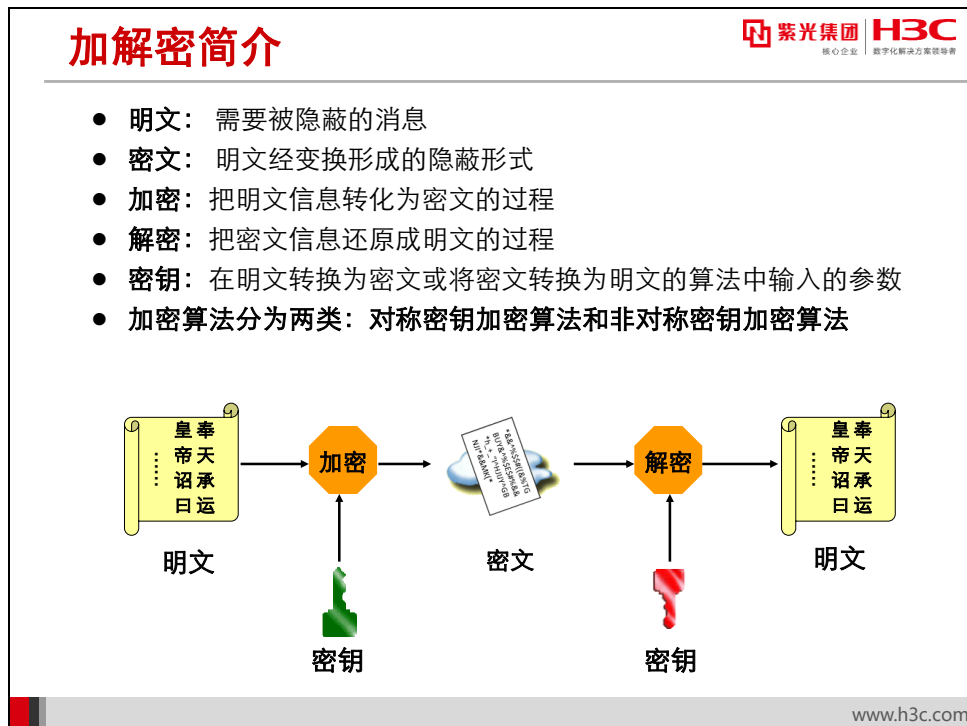
鉴别与授权必不可少。接受者如何保证对方就是正确的发送者呢?或者说,这份数据是否可能是他人伪造的呢?身份验证(**Authentication**)就是要解决这样的问题。身份验证通过检查用户的某种印鉴或标识,判断一份数据是否源于正确的创建者。

同时,在电子商务越来越红火的今天,必须有一个安全手段能保证交易或者其他操作不被否认,对相关操作留有证据,概括来说,就是不可抗抵赖性。

把机密性、身份验证、完整性、不可抵赖性结合起来,能够组成一个安全的网络传输环境。

11.3 数据加解密

11.3.1 加解密简介



数据加密的基本过程就是对原来为明文的文件或数据按某种算法进行处理，使其成为不可读的一段代码。

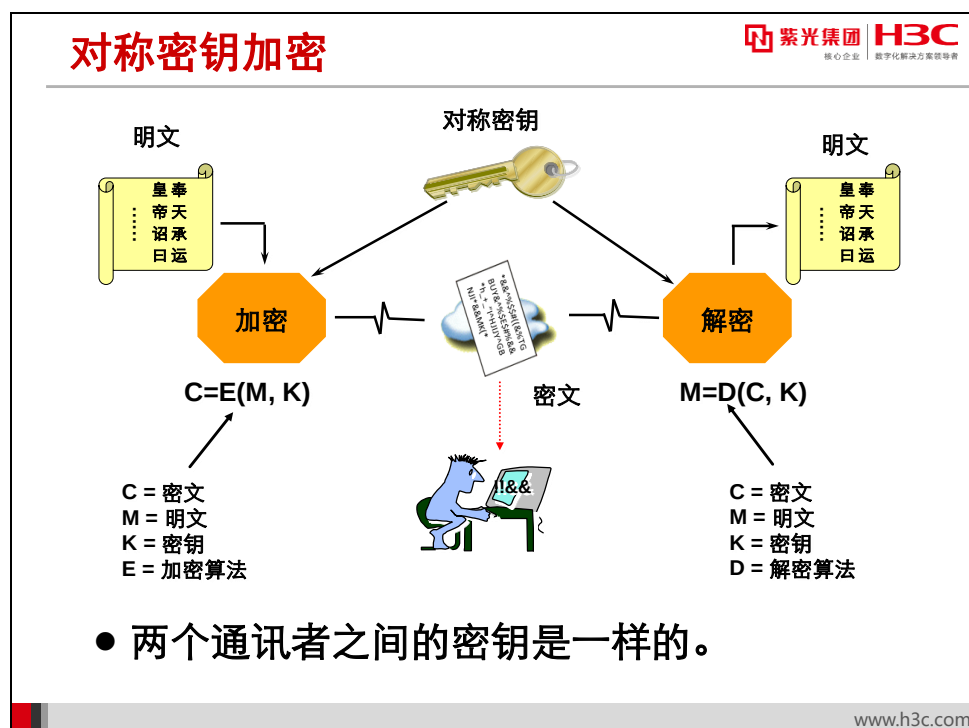
未加密的数据通常称为“明文”，加密后的数据通常称为“密文”。将数据从明文转换为密文的过程，称为“加密”，而将数据从密文转换为明文的过程称为“解密”。

数据机密性通常是由加密算法提供的。加密时，算法以明文为输入，将明文转换为密文，从而使无授权者不能理解真实的数据内容。解密时，算法以密文为输入，将密文转换为明文，从而使有授权者能理解数据内容。

在将明文加密为密文和将密文解密为明文的过程中，除了加解密的数据外，加密算法还需要一个加解密的参数，称之为密钥。

加密算法根据其工作方式的不同，可以分为对称加密算法和非对称加密算法两种。

11.3.2 对称密钥加密



在对称加密算法中，通信双方共享一个秘密，作为加密/解密的密钥。这个密钥既可以是直接获得的，也可以是通过某种共享的方法推算出来的。所以，对称加密算法也称为单密钥算法。

由于任何具有这个共享密钥的人都可以对密文进行解密，所以，对称加密算法的安全性依赖于密钥本身的安全性。由于这种加密方法加解密使用同一个密钥，所以发送人和接受人在开始传输数据之前必须先交换密钥。数据传输和接收通常在很多人之间进行的，每一对发送方和接收方都要有他们之间专用的密钥，因此这种加密算法对密钥的需求量较大。

再加以对称密钥加密方法执行效率一般都比较低，因此对称密钥加密算法适用于能够安全地交换密钥且传输数据量较大的场合。

对称密钥典型算法			
		紫光集团 H3C 核心企业 数字化解决方案领导者	
算法	密钥	开发者	备注
数据加密标准 DES	56位	IBM为美国政府 (NBS/NIST)开发	很多政府强制性使用
3DES	3*56位	IBM为美国政府 (NBS/NIST)开发	应用3次DES
CAST	40-256位可 变	北方通信	比DES稍快
Rivest算法 (RC2)	可变	Ron Rivest (RSA数据安全)	专利细节未公开
RC5		Ron Rivest (RSA数据安全)	
AES		Joan Daemen/Vincent Rijmen	

目前有不少对称密钥加密算法的标准，包括 DES、3DES、RC4、AES 等。

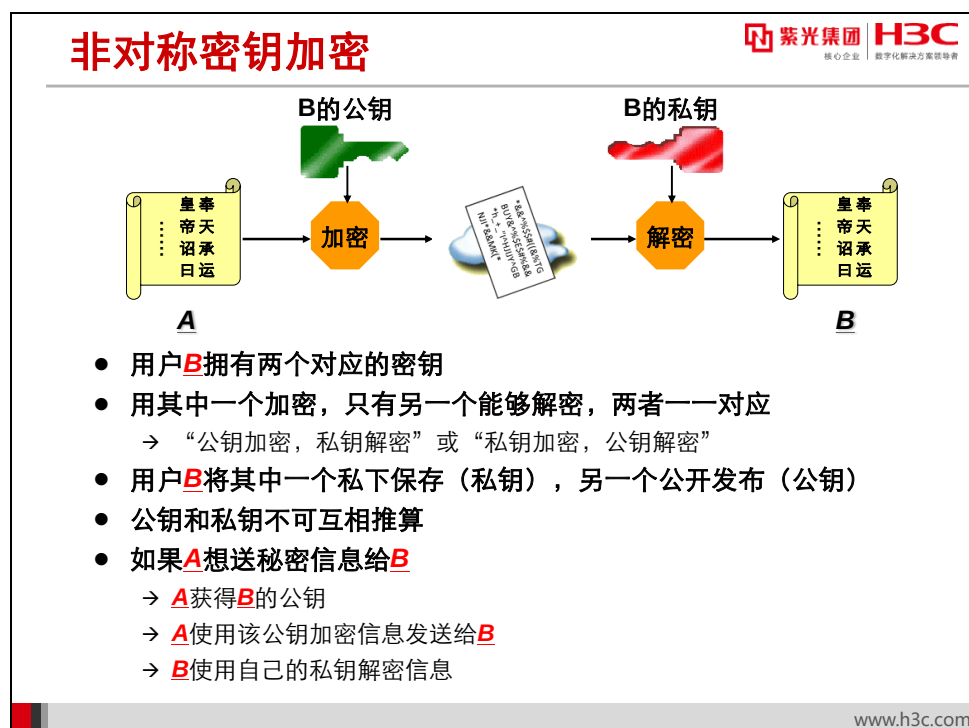
数字加密标准（DES）应用范围很广。它是由 IBM 公司在 20 世纪 70 年代开发出来的，随后被美国政府采纳为美国国家标准。但这个算法有一个很致命的问题，就是算法没有公开，只有美国国家安全局知道具体的算法，并且在批准这一算法用于公共用途时美国国家安全局把 DES 的密钥长度由原来的 64 位缩短为 56 位，这更加重了人们的担心。

3DES 又称之为“三重数字加密算法”，是 DES 算法的加强算法。密钥长度达到了 168 位，与 56 位的 DES 算法相比，安全性要高出不少。

RC4 是一种对称算法，是 Ron Rivest 在 1987 年设计的，用变长密钥对大量数据进行加密，比 DES 快。

AES 又称 Rijndael 加密法，是美国联邦政府采用的一种区块加密标准。这个标准用来替代原先的 DES，已经被多方分析且广为全世界所使用。目前已然成为对称密钥加密中最流行的算法之一。该算法为比利时密码学家 Joan Daemen 和 Vincent Rijmen 所设计。

11.3.3 非对称密钥加密



非对称加密算法也称为公开密钥算法。此类算法为每个用户分配一对密钥：一个私有密钥和一个公开密钥。

私有密钥是保密的，由用户自己保管。公开密钥是公诸于众的，其本身不构成严格的秘密。这两个密钥的产生没有相互关系，也就是说不能利用公开密钥推断出私有密钥。

用两个密钥之一加密的数据，只有用另外一个密钥才能解密。发送方发送数据时，可以将准备发送给接收方的数据用接收方公开密钥进行加密，接收方接收到加密数据后用其私有密钥进行解密。

使用非对称加密算法的时候，用户不必记忆大量的共享密钥，只需要知道自己的密钥和对方的公开密钥即可。虽然处于安全目的，仍然需要一定的公开密钥管理机制，但是在降低密钥管理复杂性方面，非对称算法具有相当的优势。

不过，非对称加密算法的弱点在于其速度非常慢，吞吐量低。因此不适宜于对大量数据的加密。

非对称密钥典型算法			
		紫光集团 H3C 核心企业 数字化转型领导者	
算法	设计者	用途	安全性
RSA	RSA数据安全	加密 数字签名 密钥交换	大数分解
DSA	NSA	数字签名	离散对数
DH	Diffie&Hellman	密钥交换	完全向前保密

非对称密钥的算法有好几个，其中最著名和最流行的要数 RSA 和 DH 了。

RSA 是 1977 年由罗纳德·李维斯特（Ron Rivest）、阿迪·萨莫尔（Adi Shamir）和伦纳德·阿德曼（Leonard Adleman）一起提出的。RSA 算法是第一个能同时用于加密和数字签名的算法，也易于理解和操作。RSA 是被研究得最广泛的公钥算法，从提出到现在已近二十年，经历了各种攻击的考验，逐渐为人们接受，普遍认为是目前最优秀的公钥方案之一。RSA 的安全性依赖于大数的因子分解。

DH 算法一般用于使用不对称加密算法传送对称密钥，其过程一般为：

1、相互产生密钥对。

2、交换公钥。

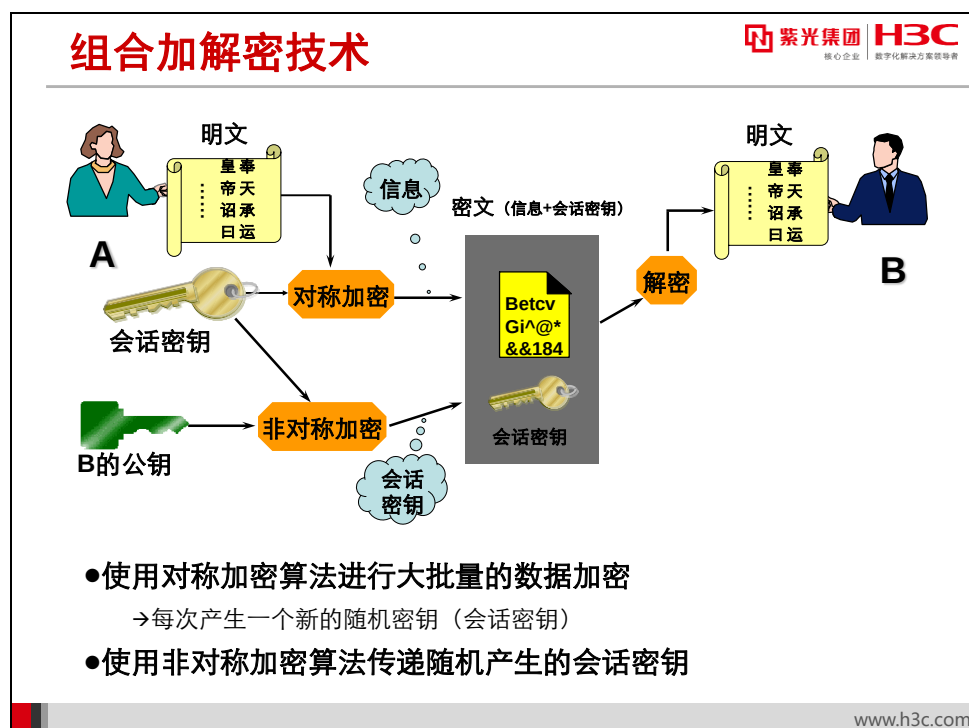
3、用对方的公钥和自己的私钥运行 DH 算法得到另外一个密钥 X（这里的奇妙之处是这个值两端都是一样的）。

4、A 产生对称加密密钥，用密钥 X 加密这个对称的加密密钥并发送到 B。

5、B 用密钥 X 解密，得到对称的加密密钥。

6、B 用这个对称的加密密钥来解密 A 的数据。

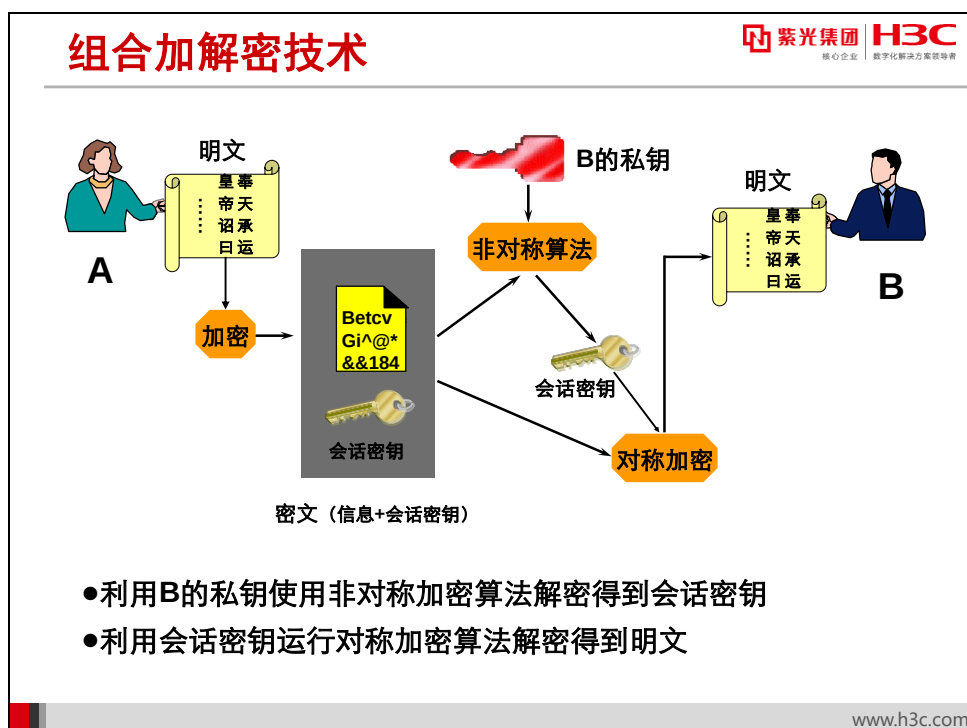
11.3.4 组合加解密技术



组合加解密技术把对称密钥算法的数据处理速度和不对称密钥算法对密钥的保密功能两方面的优势结合在一起。

比如 A 和 B 需要交换大量数据，并且这些数据必须严格保密。如果采用不对称加密算法，则需要花费的时间较长；而交换对称加密算法的密钥的安全问题又让人不放心。

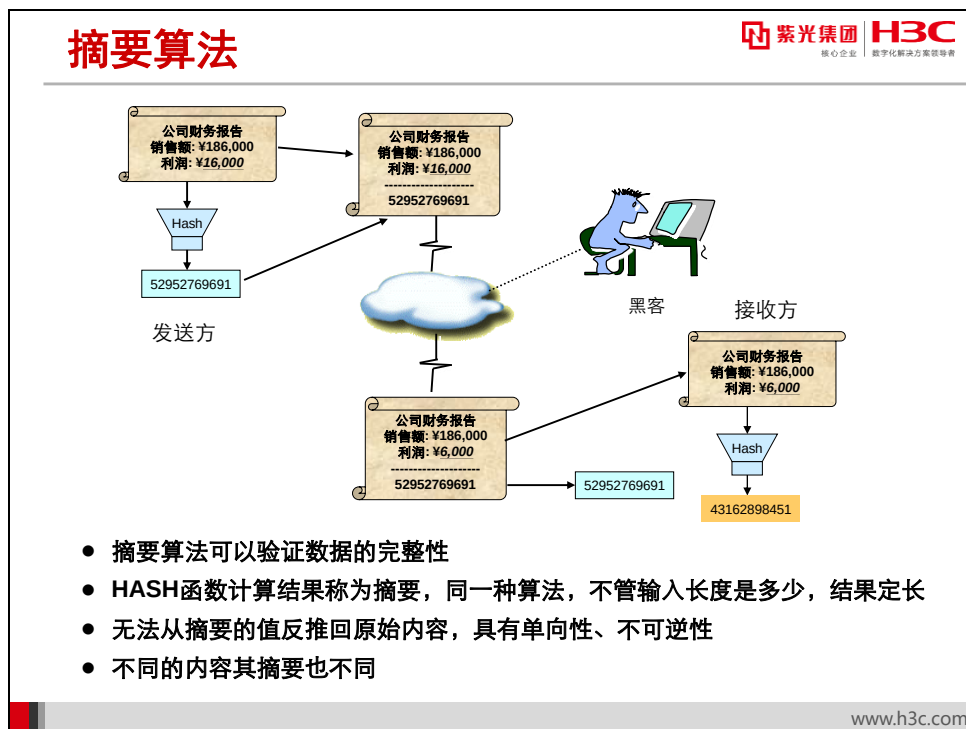
组合加密技术很好地解决了这个问题。首先，发送方选择一个对称密钥用于对需要传输的大量数据进行加密，同时通过不对称加密方法用接收方的公钥将该用于传输大量数据的对称密钥加密，和加密好的数据一起传送给接收方。这样一来，接收方就能够接收到通过非对称加密方法加密的对称密钥并用此对称密钥来解密接收到的数据。



接收方收到数据后首先用自己的私钥解密得到对称加密密钥，然后用该对称加密密钥来解密发送方的加密数据。

这就使得既能够安全地交换对称密钥，又能够加快加密工作的处理效率。

11.4 数据完整性

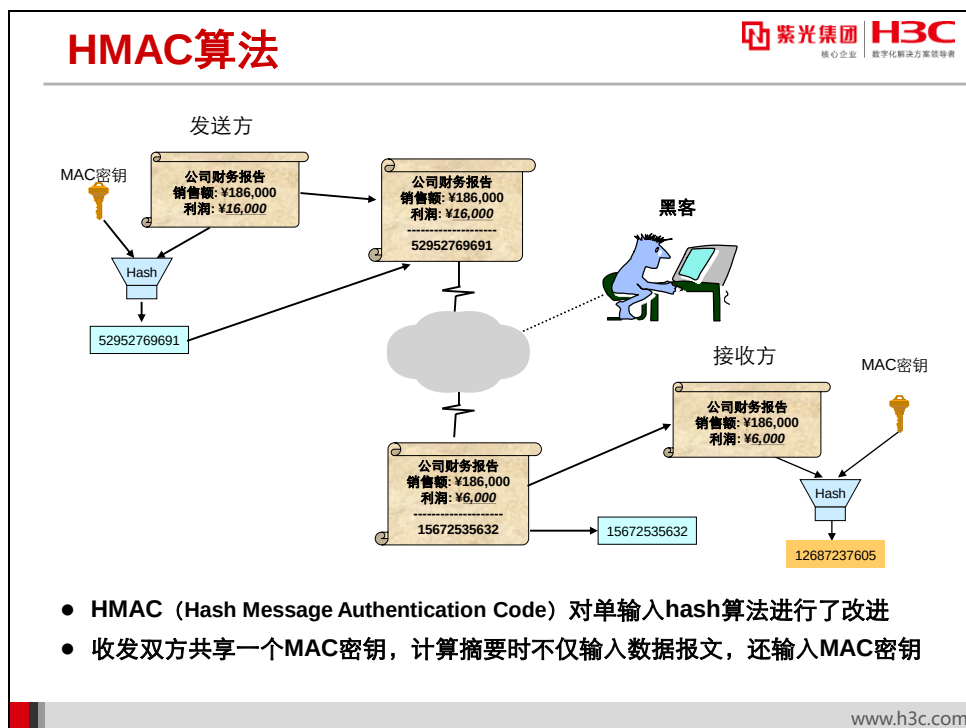


为了保证数据的完整性，我们通常使用摘要算法（HASH）。采用 HASH 函数对一段长度可变的数据进行 hash 计算，会得到一段固定长度的结果，该结果称之为原数据的摘要，也称之为消息验证码（Message Authentication Code, MAC）。摘要中包含了被保护数据的特征，如果该数据稍有变化，都会导致最后计算的摘要不同。另外 HASH 函数具有单向性。也就是说无法根据结果导出原始输入，因而无法构造一个与原报文有相同摘要的报文。

总体而言，HASH 算法具有如下三个特征：

- 无法根据结果推出输入的消息。
- 无法人为控制某个原始数据的 HASH 值等于某个特定值。
- 无法找到具有相同摘要的两个不同输入。

如果你想保证一条消息在传输过程中不被篡改，可以在将它发给接受者之前先计算出该消息的摘要，然后将这个摘要随消息一起发送给接收者。接收者收到消息后，先计算出该消息的摘要，然后将计算出的摘要值和接收到的摘要值进行比较，如果两个值相等就说明该消息在传输过程中没有被篡改。



HMAC 算法进一步提高安全性。该算法是原来单输入的 HASH 算法的改进。

该算法需要收发双方共享一个 MAC 密钥，计算摘要时，除了数据报文外，还需要提供 MAC 密钥。这样计算出来的 MAC 值不但取决于输入的数据报文，还取决于 MAC 密钥参数。

如果黑客截获了报文，修改了报文内容，伪造了摘要，由于不知道 MAC 密钥，黑客无法构造出正确的摘要。接收方重新计算报文摘要时，一定可以发现报文的 MAC 值与携带的 MAC 值是不一致的。

11.5 数字签名

数字签名概述



- 数字签名是用签名方的私钥对信息摘要进行加密的一个过程
- 签名过程所得到的密文即称为签名信息
- 数字签名主要功能：
 - 保证信息传输的完整性
 - 发送者的身份认证
 - 防止交易中的抵赖发生

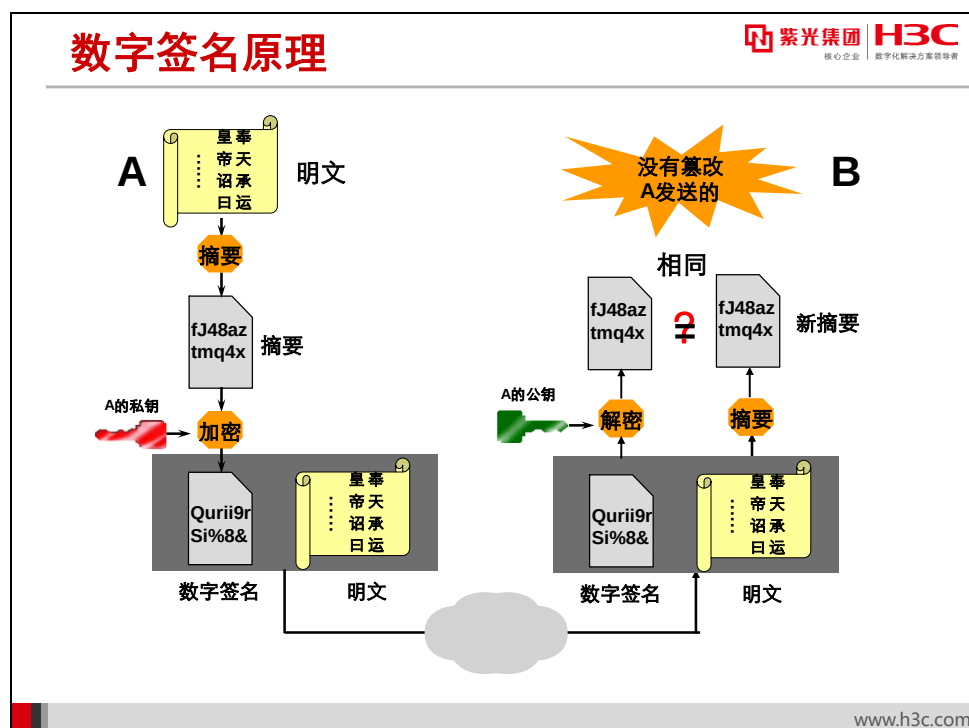
www.h3c.com

简单地说，数字签名是指使用密码算法对待发的数据进行加密处理，生成一段信息，附着在原文上一起发送，这段信息类似现实中的签名或印章，接收方对其进行验证，判断原文真伪。数字签名技术是不对称加密算法的典型应用。

因为直接对原始数据进行加密处理效率较低，一般而言，数字签名的过程是：数据发送方首先对数据进行 HASH 运算，然后使用自己的私钥对 HASH 值进行加密处理，然后将该加密后的 HASH 值和原始数据一起发送给接收方，完成对数据的合法“签名”。数据接收方则利用对方的公钥来解读收到的“数字签名”，并将解读结果用于对数据完整性的检验，以确认签名的合法性。

数字签名技术是在网络虚拟环境中确认身份的重要技术，完全可以代替现实过程中的“亲笔签字”，在技术和法律上有保证。

数字签名可以保证信息传输的完整性，确认发送者的真实身份并防止交易中的抵赖发生。



在数字签名过程中，发送方首先将待发送的原始数据进行 HASH 运算，得到该原始数据的 MAC 值，然后用自己的私钥对该 MAC 值进行加密，得到一个密文串。将该密文串附在原始报文后面一起发送给接收方。

接收方接收到该内容后，也对原始报文内容进行 HASH 运算，得到一个 MAC 值，然后用发送方的公钥对接受报文中的密文串进行解密，比较解密后的值和运算得到的 MAC 值是否相等，如果相等说明报文确实是合法的发送方的，且报文在传送过程中没有被修改。

11.6 数字证书

公钥技术的规模应用难题

- 如何解决公钥的传播问题
 - 如何把自己的公钥告诉别人
 - 得到一个公钥后如何验证其真实性
- 公钥如何管理
- 如何实现不可否认服务

www.h3c.com

我们知道，公钥技术有很多优势，可以运用到加解密中，也可以运用到身份验证中。但如果规模性地运用到实际生产生活中，必定要解决好公钥的传播问题。

比如运用在数据加密过程中，发送方会利用接受方的公钥进行加密，那么接收方是如何将自身的公告发送给数据发送方的呢？特别是大规模应用中更是一个难题。在比如在身份验证服务中，一般发送方会用自身的私钥对数据进行加密，接受方用发送方的公钥解密，那么接收方如何确认接收的发送方的公钥不是伪造的呢？

现实生活给了我们很好的启示。我们如何证明自身的身份的呢？户籍管理制度给我们很好的回答。公安局给每个公民发放一个身份证用以证明该公民的身份，为了保证该身份证的真实性，公安局会在身份证上盖上发放单位的公章。如果需要，相关人员也可以到公安局查询相应人员的身份情况。

同样，可以建立一个体系，由权威机构给相应各方签署证件（包含其公钥）用以标识身份，需要用到公钥的各方可以到一个权威机构去查询相应公钥。

数字证书

 紫光集团 H3C
核心企业 | 数字化解决方案领导者

Name: Tom Tian

Serial number: 382372

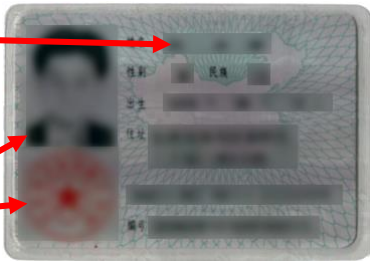
Issued by: H3C corp CA

Issue date: 2010 01 01

Expiration date: 2012 12 30

Public key: 公钥

Digital Signature: 私钥



- **网络世界的电子身份证**
 - 与现实世界的身份证类似
 - 能够证明个人、团体或设备的身份
- **包含相关信息：**
 - 包含姓名、地址、公司、电话号码、Email地址、...
 - 包含所有者的公钥
- **证书的序列号**

- **证书的有效期限**
- **由可信的颁发机构颁发**
 - 比如身份证由公安局颁发一样
- **颁发机构对证书进行签名**
 - 与身份证上公安局的盖章类似
 - 可以由颁发机构证明证书是否有效
 - 可防止篡改证书上的任何资料

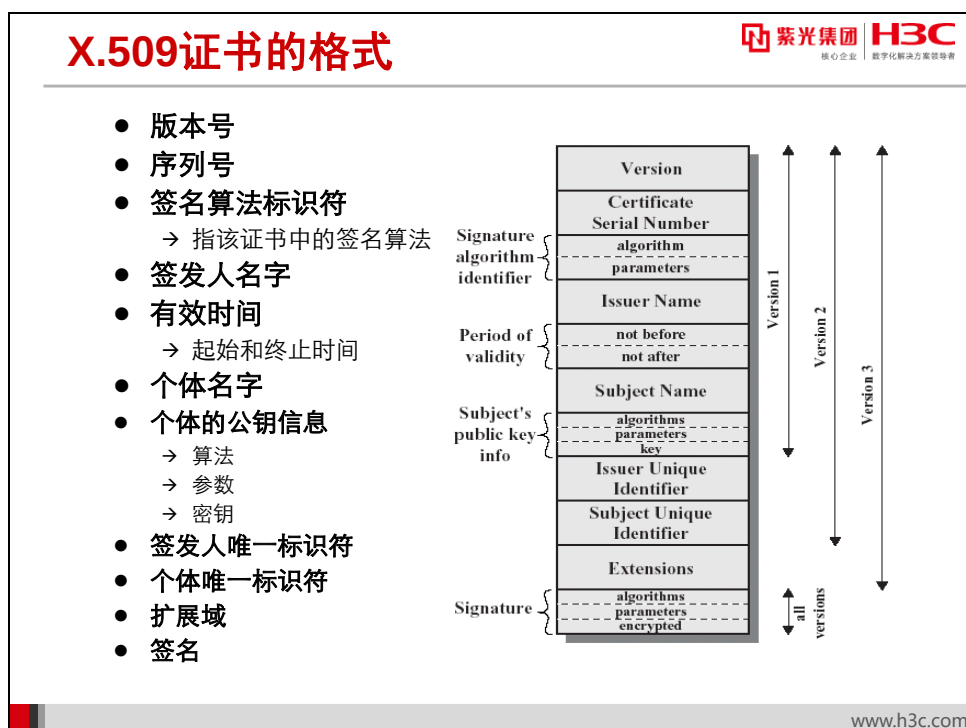
www.h3c.com

数字证书相当于电子化的身份证明，它就和身份证差不多。证书里面是一些帮助确定身份的信息资料。从技术上讲，数字证书就是：把公钥和身份绑定在一起，由一个可信的第三方对绑定后的数据进行签名，以证明数据的可靠性。

数字证书主要包含下列内容：发信人的公钥、发信人的姓名、证书颁发者的名称、证书的序列号、证书颁发者的数字签名、证书的有效期限等。

数字证书可以用来验证某个用户或某个系统的身份，也可以用来加密通信的内容。

要想获得一份数字证书，必须要向某个颁证机构申请。如果申请成功，颁证机构将用其私钥给申请者签发一份证书。申请过程将生成两个密钥，一个是申请者的公钥，一个是申请者的私钥。公钥将被写进申请者的数字证书中，而私钥需要申请者自己收好防止盗用。



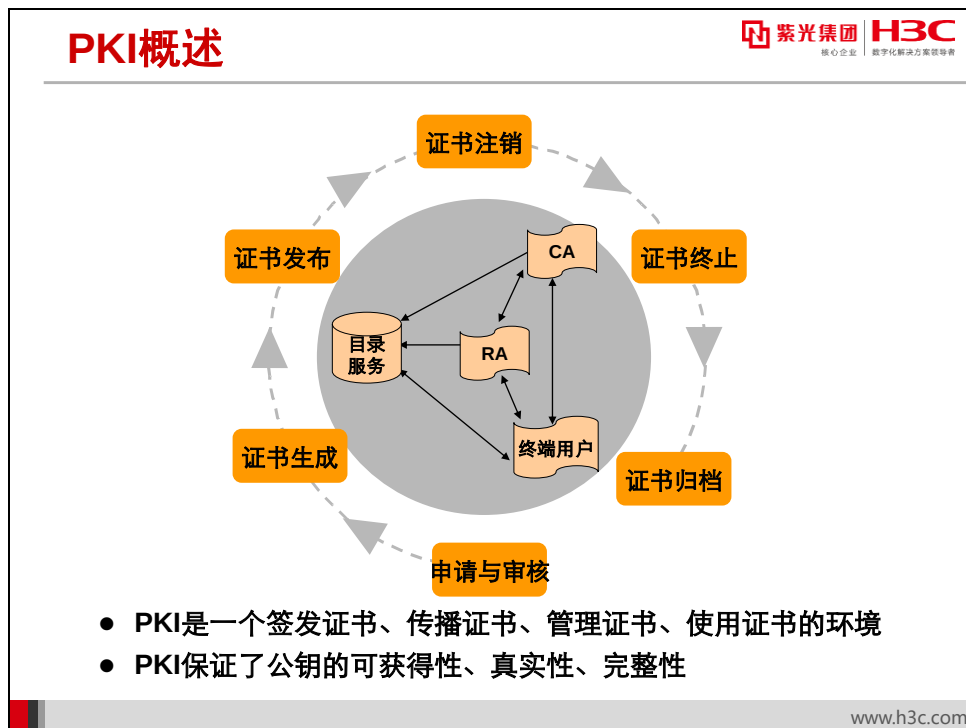
国际标准化组织 ITU 的 X.509 标准制定了标准证书格式。该标准格式经过了改进和发展，先后出现过 V1.0、V2.0、V3.0 三个版本。目前最常用的是 V3.0 版本，此版本的证书被称为 X.509v3 证书。该格式主要包含了如下内容：

- **Subject Name:** 个体的名字。
- **Subject's public key info:** 公钥信息，包括算法、密钥参数（密钥长度）、公钥。
- **Signature:** 由认证机构提供的对证书的数字签名，使用认证机构提供的公钥证书可以验证数字签名的正确性，从而确保了证书的完整性的权威性。
- **Version:** 版本，包括 V1.0、V2.0、V3.0。
- **Certificate Serial Number:** 证书序列号，在同一个认证机构签发的证书中唯一。
- **Period of validity:** 有效期，包括开始时间和结束时间。

当然还有一些其它属性。

11.7 公钥基础设施PKI

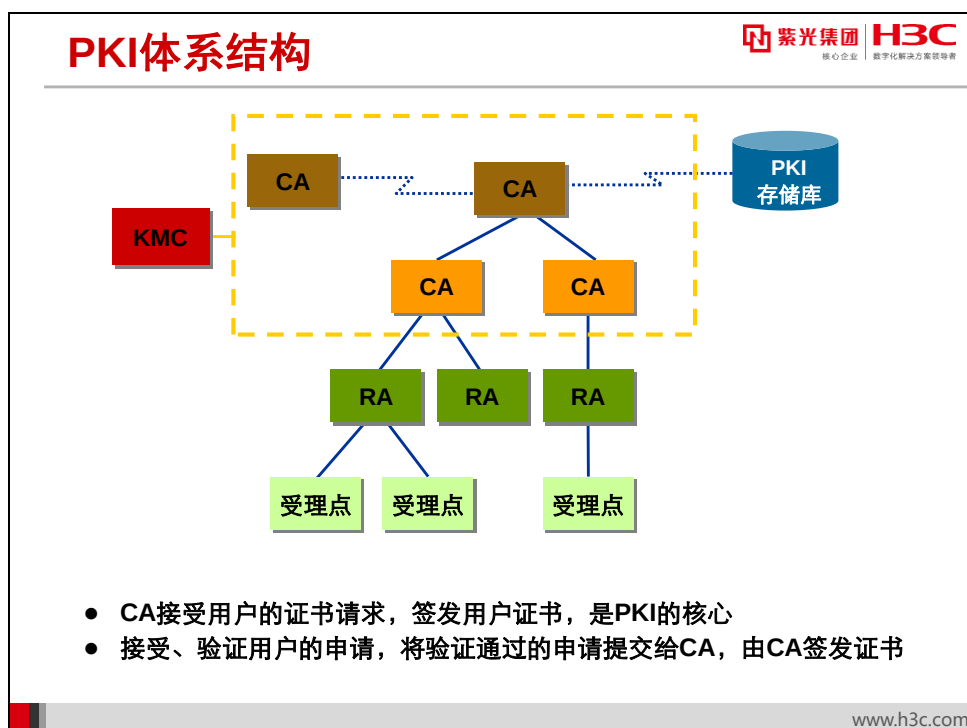
11.7.1 PKI 概述



PKI (Public Key Infrastructure) 即“公开密钥体系”，它不是一个单一的产品，也不是一个单一的协议、技术，它是一个签发证书、传播证书、管理证书、使用证书的环境。PKI 采用了多种技术，由多个实体协同运作的一种环境，包含软件、硬件、人、企业、多种的服务、多种应用。PKI 保证了公钥的可获得性、真实性、完整性。

完整的 PKI 系统必须具有权威认证机构(CA)、数字证书库、密钥备份及恢复系统、证书作废系统、应用接口 (API) 等基本构成部分，构建 PKI 也将围绕着这五大系统来着手构建。

PKI 技术是信息安全技术的核心，也是电子商务的关键和基础技术。



一个 PKI 体系由终端实体、证书机构、注册机构和 PKI 存储库四类实体共同组成。

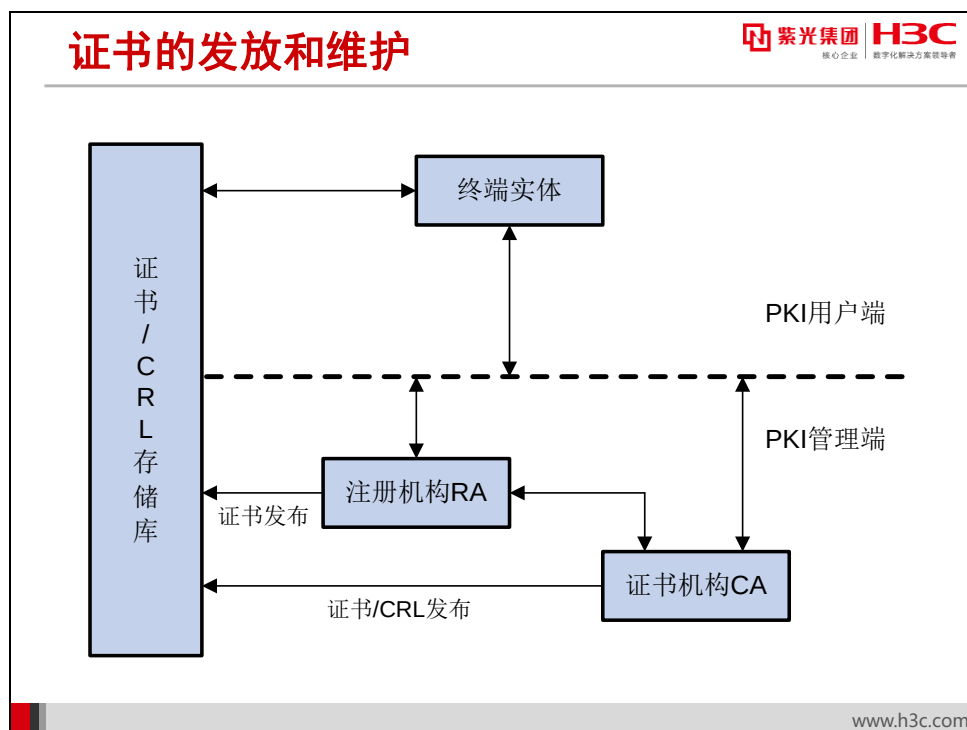
终端实体是 PKI 产品或服务的最终使用者，可以是个人、组织、设备（如路由器、交换机）或计算机中运行的进程。

证书机构 CA 是 PKI 的信任基础，是一个用于签发并管理数字证书的可信实体。其作用包括：发放证书、规定证书的有效期等。

注册机构 RA 是 CA 的延伸，可作为 CA 的一部分，也可以独立。RA 功能包括个人身份审核、CRL 管理、密钥对产生和密钥对备份等。PKI 国际标准推荐由一个独立的 RA 来完成注册管理的任务，这样可以增强应用系统的安全性。

PKI 存储库包括 LDAP（Lightweight Directory Access Protocol，轻量级目录访问协议）服务器和普通数据库，用于对用户申请、证书、密钥、CRL 和日志等信息进行存储和管理，并提供一定的查询功能。

11.7.2 PKI 工作过程



针对一个使用 PKI 的网络，配置 PKI 的目的就是为指定的实体向 CA 申请一个本地证书，并由设备对证书的有效性进行验证。当由于用户姓名的改变、私钥泄漏或业务中止等原因，需要存在一种方法将现行的证书撤消，即撤消公开密钥及相关的用户身份信息的绑定关系。在 PKI 中，所使用的这种方法为证书废除列表。任何一个证书被废除以后，CA 就要发布 CRL 来声明该证书是无效的，并列出现所有被废除的证书的序列号。CRL 提供了一种检验证书有效性的方式。

下面是 PKI 的工作过程：

1. 实体向 RA 提出证书申请；
2. RA 审核实体身份，将实体身份信息和公开密钥以数字签名的方式发送给 CA；
3. CA 验证数字签名，同意实体的申请，颁发证书；
4. RA 接收 CA 返回的证书，发送到 LDAP 服务器以提供目录浏览服务，并通知实体证书发行成功；
5. 实体获取证书，利用该证书可以与其它实体使用加密、数字签名进行安全通信；
6. 实体希望撤消自己的证书时，向 CA 提交申请，CA 批准实体撤消证书，并更新 CRL，发布到 LDAP 服务器。

证书的验证

- 验证证书的签名，用签发该证书的CA的公钥进行验证。
- CRL检查，证书是否撤销。
- 有效期验证
- 证书用途

在使用每一个证书之前，必须对证书进行验证。证书验证包括对签发时间、签发者信息以及证书的有效性等几方面进行验证。证书验证的核心是检查 CA 在证书上的签名，并确定证书仍在有效期内，而且未被废除，因此在进行证书验证操作之前必须首先获取 CA 证书。

配置证书验证时可以设置是否必须进行 CRL 检查，如果配置为使能 CRL 检查，则检验证书的有效性，必须通过 CRL 判断。

11.7.3 配置 PKI

配置任务

- **配置实体DN（Distinguished Name，可识别名称）**
 - 实体DN的参数是实体的身份信息，CA根据实体提供的身份信息来唯一标识证书申请者。
- **配置PKI域参数**
 - 实体在进行PKI证书申请操作之前需要配置一些注册信息来配合完成申请的过程。这些信息的集合就是一个实体的PKI域。
- **PKI证书申请和获取**
 - 证书申请就是实体向CA自我介绍的过程。实体向CA提供身份信息，以及相应的公开密钥，这些信息将成为颁发给该实体证书的主要组成部分。

www.h3c.com

一份证书是一个公开密钥与一个身份的绑定，而身份必须与一个特定的 PKI 实体相关联。实体 DN（Distinguished Name，可识别名称）的参数是实体的身份信息，CA 根据实体提供的身份信息来唯一标识证书申请者。实体 DN 的参数包括：实体通用名、实体所属国家代码、实体 FQDN（Fully Qualified Domain Name，合格域名）、实体 IP 地址、实体所在地理区域名称、实体所属组织名称等等。

实体在进行 PKI 证书申请操作之前需要配置一些注册信息来配合完成申请的过程。这些信息的集合就是一个实体的 PKI 域。PKI 域是一个本地概念，因此创建 PKI 域的目的是便于其它应用引用 PKI 的配置，比如 IKE、SSL 等。一个设备上配置的 PKI 域对 CA 和其它设备是不可见的，每一个 PKI 域有单独的域参数配置信息。PKI 域中包括以下参数：信任的 CA 名称、实体名称、证书申请的注册机构、注册服务器的 URL 等等。

证书申请就是实体向 CA 自我介绍的过程。实体向 CA 提供身份信息，以及相应的公开密钥，这些信息将成为颁发给该实体证书的主要组成部分。实体向 CA 提出证书申请，有离线和在线两种方式。离线申请方式下，CA 允许申请方通过带外方式（如电话、磁盘、电子邮件等）向 CA 提供申请信息。在线证书申请有手工发起和自动发起两种方式。

配置实体DN

 紫光集团 **H3C**
核心企业 | 数字化转型领导者

- 创建一个实体，并进入该实体视图。

[H3C] pki entity *entity-name*
- 配置实体通用名（可选）

[H3C-pki-entity-entity1] common-name *name*

www.h3c.com

pki entity 命令用来配置实体名称，并进入该实体视图。**undo pki entity** 命令用来删除此实体的名称及其实体命名空间下的所有配置。

参数 *entity-name* 是指实体名，为 1~31 个字符的字符串，不区分大小写。

在 PKI 实体视图下可配置实体的各种属性值。*entity-name* 只是用来方便被其它命令引用，不用于证书的相关字段。

common-name 命令用来配置实体的通用名，比如用户名称。**undo common-name** 命令用来删除实体的通用名。

name: 实体的通用名称，为 1~63 个字符的字符串，不区分大小写，不能包含逗号。

配置PKI域参数

 紫光集团 
核心企业 | 数字化解决方案领导者

- 创建一个PKI域，并进入PKI域视图

[H3C] pki domain *domain-name*
- 配置信任的CA名称

[H3C-pki-domain-domain1] ca identifier *name*
- 指定实体名称

[H3C-pki-domain-domain1] certificate request entity *entity-name*
- 配置证书申请的注册受理机构

[H3C-pki-domain-domain1] certificate request from { *ca* | *ra* }
- 配置注册服务器URL

[H3C-pki-domain-domain1] certificate request url *url-string*

www.h3c.com

配置 PKI 域一般需要配置以下几个参数：

- **信任的 CA 名称：**在申请证书时，是通过一个可信实体认证机构，来完成实体证书的注册颁发，因此必须指定一个信任的 CA 名称。
- **实体名称：**向 CA 发送证书申请请求时，必须指定所使用的实体名，以向 CA 表明自己的身份。
- **证书申请的注册机构：**证书申请的受理一般由一个独立的注册机构（即 RA）来承担，它接收用户的注册申请，审查用户的申请资格，并决定是否同意 CA 给其签发数字证书。注册机构并不给用户签发证书，而只是对用户进行资格审查。有时 PKI 把注册管理的职能交给 CA 来完成，而不设立独立运行的 RA。PKI 推荐独立使用 RA 作为注册受理机构。
- **注册服务器的 URL：**证书申请之前必须指定注册服务器的 URL，随后实体可通过简单证书注册协议（SCEP，Simple Certification Enrollment Protocol）向该服务器提出证书申请，SCEP 是专门用于与认证机构进行通信的协议。

配置证书申请和获取

- 生成本地 DSA、RSA 或 ECDSA 密钥对

```
[H3C] public-key local create { dsa | ecdsa | rsa }
```

- 获取证书

```
[H3C] pki retrieve-certificate domain domain-name { ca | local | peer  
entity-name }
```

```
[H3C] pki import domain domain-name { der { ca | local | peer }  
filename filename | p12 local filename filename | pem { ca | local |  
peer } [ filename filename ] }
```

- 申请本地证书

```
[H3C] pki request-certificate domain domain-name [ password  
password ] [ pkcs10 [ filename filename ] ]
```

- 显示证书内容

```
[H3C] display pki certificate domain domain-name { ca | local | peer  
[ serial serial-num ] }
```

在线证书申请有手工发起和自动发起两种方式。

配置自动申请证书方式后，当有应用与 PKI 联动时，如果没有本地证书(比如 IKE 使用 PKI 证书方式认证时，IKE 协商时发现没有本地证书)，则自动向 CA 服务器发起申请，获取证书。

配置证书申请方式为手工方式后，需要手工完成获取 CA 证书、生成密钥对、申请本地证书的工作。获取 CA 证书的目的在于验证本地证书的真实性和合法性。密钥对的产生是证书申请过程中重要的一步。申请过程使用了一对主机密钥：私钥和公钥。私钥由用户保留，公钥和其他信息则交由 CA 中心进行签名，从而产生证书。

获取证书后，在任意视图下执行 **display** 命令可以显示配置后 PKI 的运行情况，通过查看显示信息验证配置的效果。

11.8 本章总结

本章总结

- 介绍了数据传输存在的安全隐患，并讲解了私密性、完整性、身份验证等基本概念
- 详细描述了对称、非对称等各种加密方法
- 介绍了数字签名的基本概念和实现
- 介绍数字证书概念作用
- 讲解了PKI体系结构及其配置

11.9 习题和解答

11.9.1 习题

1. 接收方进行了下面哪方面的检查就可以判断收到一份数据是否被中间人篡改？（ ）
 - A. 完整性
 - B. 机密性
 - C. 身份验证
 - D. 不可抵赖
2. 下列哪些算法属于对称加密算法？（ ）
 - A. DES
 - B. AES
 - C. RSA
 - D. DH
3. 下列哪些关于组合加密方法的描述是正确的？（ ）
 - A. 发送方使用接收方的公钥加密需要发送的数据，用接收方的私钥加密共享密钥。
 - B. 发送方式用接收方的私钥加密需要发送的数据，用接收方的公钥加密共享密钥。
 - C. 发送方式用接收方的公钥加密共享密钥，用共享密钥加密需要发送的数据。
 - D. 发送方式用共享密钥加密接收方的私钥，用接收方的私钥加密需要发送的数据。
4. 发送方将待发送的数据 A 运行 HASH 算法后得到结果 B，再将 B 运行加密算法得到结果 C，将结果 A 和 C 一起发送给接收方，接收方接收到后将 C 解密后得到结果 D，如果 D 等于 B，则说明（ ）
 - A. 数据没有被中间人篡改。
 - B. 数据已经被中间人篡改。
 - C. 无法判断数据是否被中间人篡改。
 - D. 如果 D 等于 A 则可以判断数据没有被中间人篡改
5. 简单描述一个实体数字证书申请发放到作废的过程。

11.9.2 习题答案

- A
- AB
- C

C

答：

- （一）实体向 RA 提出证书申请；
- （二）RA 审核实体身份，将实体身份信息和公开密钥以数字签名的方式发送给 CA；
- （三）CA 验证数字签名，同意实体的申请，颁发证书；
- （四）RA 接收 CA 返回的证书，发送到 LDAP 服务器以提供目录浏览服务，并通知实体证书发行成功；
- （五）实体获取证书，利用该证书可以与其它实体使用加密、数字签名进行安全通信；
- （六）实体希望撤消自己的证书时，向 CA 提交申请。CA 批准实体撤消证书，并更新 CRL，发布到 LDAP 服务器。

第12章 IPsec 基本原理

数据在公网上传输时，很容易遭到篡改和窃听。普通的 VPN 技术虽然将数据封装在 VPN 承载协议内部，但其本质上并不能防止篡改和窃听。IPsec 通过验证算法和加密算法防止数据遭受篡改和窃听等安全威胁，大大提高了安全性。

12.1 本章目标

课程目标

● 学习完本课程，您应该能够：

- 描述IPsec VPN的功能和特点
- 描述IPsec VPN的体系结构
- 描述AH和ESP两种安全协议的特点和工作机制
- 描述IKE的功能、特点和工作机制



12.2 IPsec VPN概述

IPsec VPN概述



核心企业 | 数字化解决方案领导者

- RFC 2401描述了IPsec (IP Security) 的体系结构
- IPsec是一种网络层安全保障机制
- IPsec可以实现访问控制、机密性、完整性校验、数据源验证、拒绝重播报文等安全功能
- IPsec可以引入多种验证算法、加密算法和密钥管理机制
- IPsec VPN是利用IPsec隧道实现的L3 VPN
- IPsec也具有配置复杂、消耗运算资源较多、增加延迟、不支持组播等缺点

www.h3c.com

由于 IP 不能保证数据的安全性, IETF 在 RFC 2401 中描述了 IP 的安全体系结构——IPsec (IP Security), 以便为 IP 提供安全保障。IPsec 并非单一的协议, 而是由一系列的安全开放标准构成。

IPsec 是一种网络层安全保障机制, 可以在一对通信节点之间提供一个或多个安全的通信路径。它使一个系统能选择其所需要的安全协议, 确定安全服务所使用的算法, 并为相应安全服务配置所需的密钥。

IPsec 可以实现访问控制、机密性、完整性校验、数据源验证、拒绝重播 (replay) 报文等安全功能。IPsec 实现于 OSI 参考模型的网络层, 因此, 上层的 TCP、UDP 以及依赖这些协议的应用协议均可以受到 IPsec 隧道的保护。

IPsec 是一个可扩展的体系, 它并不受限于任何一种特定算法。IPsec 中可以引入多种开放的验证算法、加密算法和密钥管理机制。

IPsec 可以在主机、路由器或者防火墙上实现。这些实现了 IPsec 的中间设备称为“安全网关”。

IPsec VPN 是利用 IPsec 隧道实现的 L3 VPN。IPsec 对 IP 包的验证、加密和封装能力使其可以被用来创建安全的 IPsec 隧道, 传送 IP 包。利用这一隧道功能实现的 VPN 称为 IPsec VPN。

IPsec 也具有一些缺点，例如其协议体系复杂而难以布署；高强度的运算消耗大量资源；增加了数据传输的延迟，不利于语音视频等实时性要求强的应用；仅能对点对点的数据进行保护，不支持组播等。

12.3 IPsec 体系结构

12.3.1 IPsec 体系概述

IPsec 的体系结构

- 安全协议
 - 负责保护数据
 - AH/ESP
- 工作模式
 - 传输模式：实现端到端保护
 - 隧道模式：实现站点到站点保护
- 密钥管理
 - 手工配置密钥
 - 通过IKE协商密钥

紫光集团 H3C
核心企业 数字化解决方案领导者

www.h3c.com

IPsec 使用两种安全协议（Security Protocol）来提供通信安全服务：

- **AH（Authentication Header，验证头）**：AH 提供完整性保护和数据源验证以及可选的抗重播服务，但是不能提供机密性保护。
- **ESP（Encapsulating Security Payload，封装安全载荷）**：ESP 不但提供了 AH 的所有功能，而且可以提供加密功能。AH 和 ESP 不但可以单独使用，还可以同时使用，从而提供额外的安全性。

AH 和 ESP 两种协议并没有定义具体的加密和验证算法，相反，实际上大部分对称算法可以为 AH 和 ESP 采用。这些算法分别在其它的标准文档中定义。为了确保 IPsec 实现的互通性，IPsec 规定了一些必须实现的算法，如加密算法 DES-CBC。

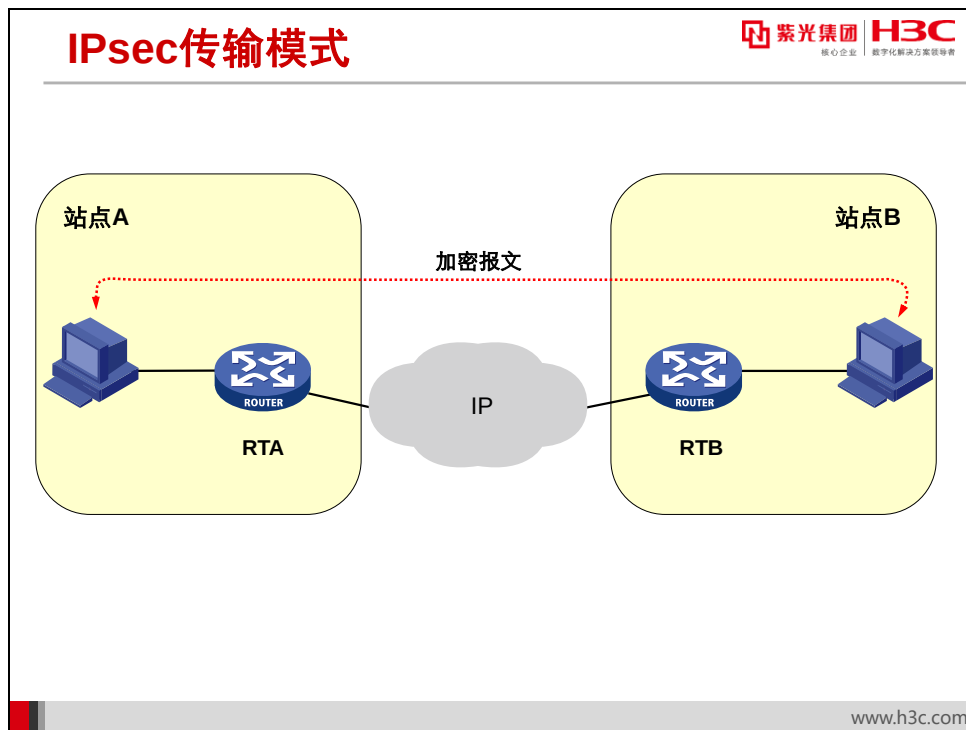
不论是 AH 还是 ESP，都具有两种工作模式：

- **传输模式（Transport Mode）**：用于保护端到端（End-to-End）安全性。
- **隧道模式（Tunnel Mode）**：用于保护站点到站点（Site-to-Site）安全性。

IPsec 的安全保护依赖于相应的安全算法。验证算法和对称加密算法通常需要通信双方拥有相同的密钥。IPsec 通过两种途径获得密钥：

- **手工配置：**管理员为通信双方预先配置静态密钥。这种密钥不便于随时修改，安全性较低，不易维护。
- **通过 IKE 协商：**IPsec 通信双方可以通过 IKE 动态生成并交换密钥，获得更高的安全性。

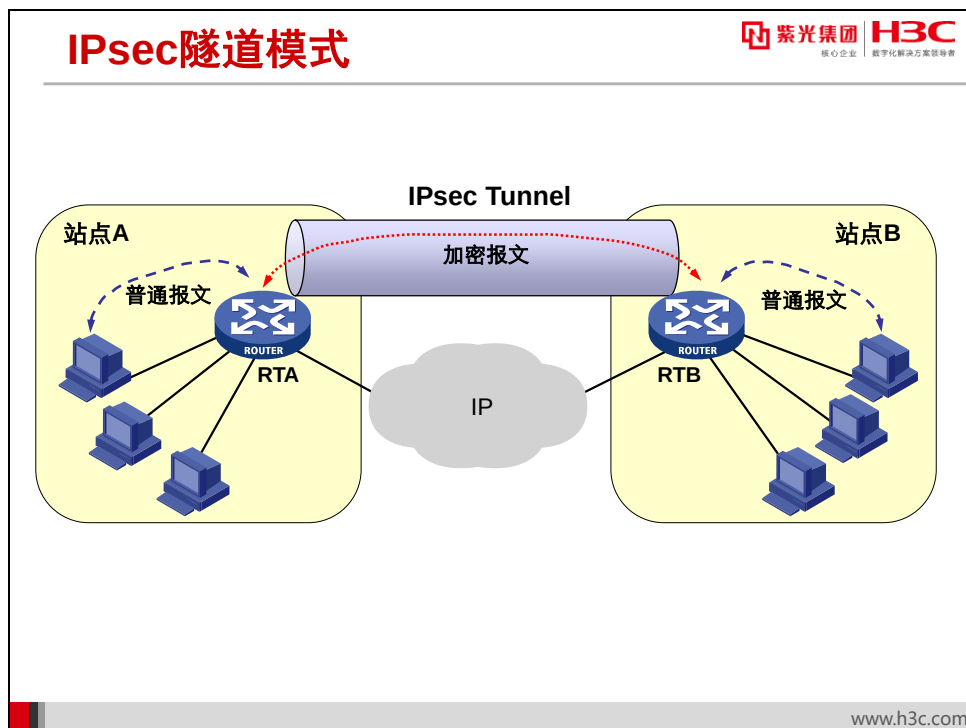
12.3.2 隧道模式和传输模式



在传输模式中，两个需要通信的终端计算机在彼此之间直接运行 IPsec 协议。AH 和 ESP 直接用于保护上层协议，也就是传输层协议。

在使用传输模式时，所有加密、解密和协商操作均由端系统自行完成，网络设备仅执行正常的路由转发，并不关心此类过程或协议，也不加入任何 IPsec 过程。

传输模式的目的是直接保护端到端通信。只有在需要端到端安全性的时候，才推荐使用此种模式。



在隧道模式中，两个安全网关在彼此之间运行 IPsec 协议，对彼此之间需要加密的数据达成一致，并运用 AH 或 ESP 对这些数据进行保护。

用户的整个 IP 数据包被用来计算 AH 或 ESP 头，且被加密。AH 或 ESP 头和加密用户数据被封装在一个新的 IP 数据包中。

隧道模式对端系统的 IPsec 能力没有任何要求。来自端系统的数据流经过安全网关时，由安全网关对其进行保护。所有加密、解密和协商操作均由安全网关完成，这些操作对于端系统来说是完全透明的。

隧道模式的目的是建立站点到站点（Site-to-Site）的安全隧道，保护站点之间的特定或全部数据。

12.3.3 IPsec SA

IPsec SA


核心企业 | 数字化转型方案领导者

- **SA (Security Association, 安全联盟)**
- 由一个 (SPI, IP 目的地址, 安全协议标识符) 三元组唯一标识
- 决定了对报文进行何种处理
 - 协议、算法、密钥
- 每个 IPsec SA 都是单向的
- 手工建立/IKE 协商生成
- **SPD (Security Policy Database)**
- **SAD (Security Association Database)**

www.h3c.com

SA (Security Association, 安全联盟) 是 IPsec 中的一个基础概念。IPsec 对数据流提供的安全服务通过 SA 来实现。

SA 是通信双方就如何保证通信安全达成的一个协定, 它包括协议、算法、密钥等内容, 具体确定了如何对 IP 报文进行处理。

SA 是单向的。一个 SA 就是两个 IPsec 系统之间的一个单向逻辑连接, 入站数据流和出站数据流由入站 SA 与出站 SA 分别处理。

一个 SA 由一个 (SPI, IP 目的地址, 安全协议标识符) 三元组唯一标识。其中:

- SPI (Security Parameter Index, 安全参数索引) 是一个 32 比特的数值, 在每一个 IPsec 报文中都携带该值。
- IP 目的地址是 IPsec 协议对方的地址。
- 安全协议标识符是 AH 或 ESP。

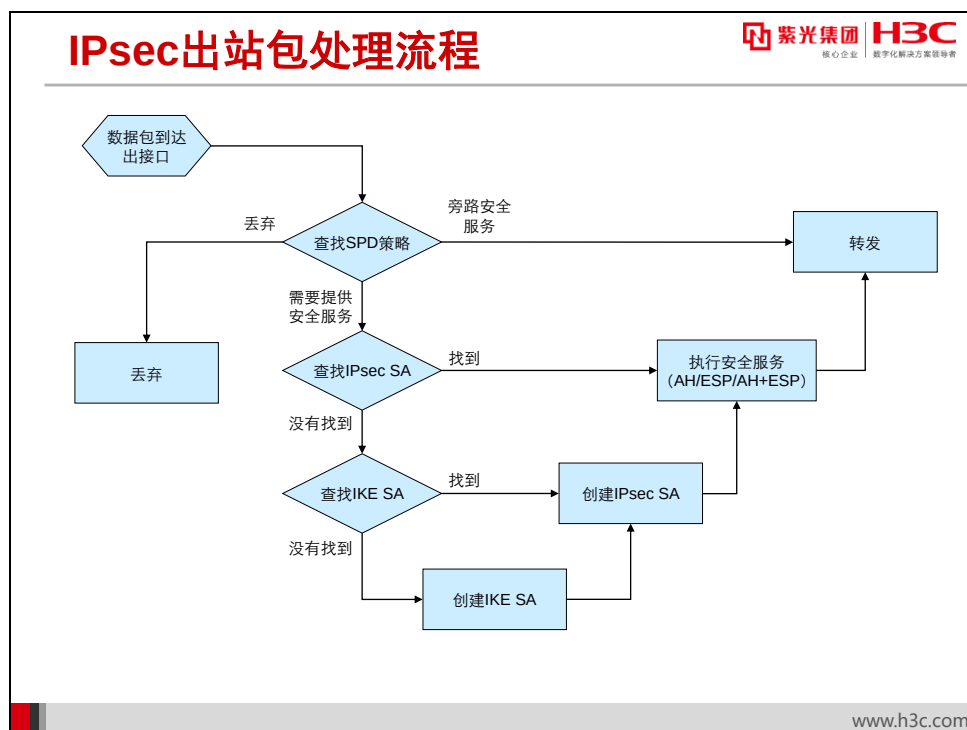
SA 可通过手工配置和自动协商两种方式建立。手工建立 SA 的方式是指用户通过在两端手工设置一些参数, 在两端参数匹配和协商通过后建立 SA。自动协商方式由 IKE 生成和维护, 通信双方基于各自的安全策略库经过匹配和协商, 最终建立 SA 而不需要用户的干预。在手工配置 SA 时, 需要手工指定 SPI 的取值。为保证 SA 的唯一性, 必须使用不同的 SPI 来配置 SA; 使用 IKE 协商产生 SA 时, SPI 将随机生成。

SA 的生存时间 (Life Time) 有“以时间进行限制”和“以流量进行限制”两种方式。前者要求每隔定长的时间就对 SA 进行更新, 后者要求每传输一定字节数量的信息就对 SA 进行更新。一旦生存时间期满, SA 就会被删除。

IPsec 设备把类似“对哪些数据提供哪些服务”这样的信息存储在 SPD (Security Policy Database, 安全策略数据库) 中。而 SPD 中的项指向 SAD (Security Association Database, 安全联盟数据库) 中的相应项。一台设备上的每一个 IPsec SA 都在 SAD 有对应项。该项定义了与该 SA 相关的所有参数。

例如对一个需要加密的出站数据包来说, 系统会将它与 SPD 中的策略相比较。若匹配其中一项, 系统会使用该项对应的 SA 及算法对此数据包进行加密。如果此时不存在一个相应的 SA, 系统就需要建立一个 SA。

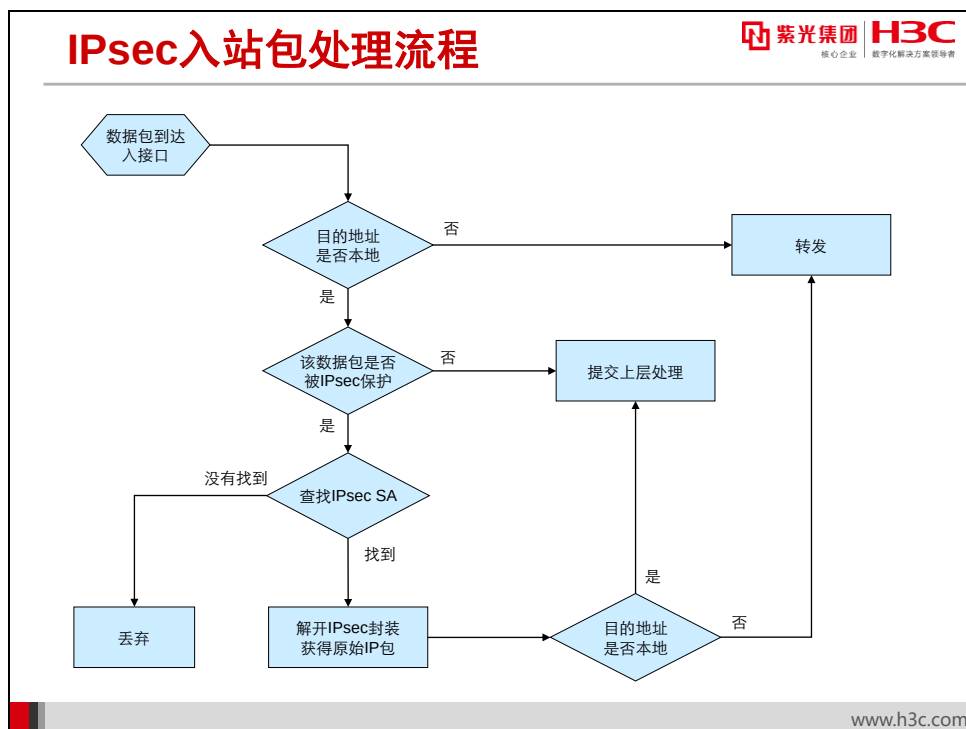
12.3.4 IPsec 包处理流程



在出站数据包被路由器从某个配置了 IPsec 的接口转发出去之前, 需要经以下处理步骤:

- 首先查找 SPD。得到的结果可能有“丢弃”、“旁路安全服务”、“提供安全服务”三种。如果是第一种, 直接丢弃此包; 如果是第二种, 则直接转发此包; 如果是第三种, 则系统会转下一步——查找 IPsec SA。
- 系统从 SAD 中查找 IPsec SA。如果找到, 则利用此 IPsec SA 的参数对此数据包提供安全服务, 并进行转发; 如果找不到相应的 SA, 则系统就需要为其创建一个 IPsec SA。

- 系统转向 IKE 协议数据库，试图寻找一个合适的 IKE SA，以便为 IPsec 协商 SA。如果找到，则利用此 IKE SA 协商 IPsec SA，否则，系统需要启动 IKE 协商进程，创建一个 IKE SA。



对一个入站并且目的地地址为本地的 IPsec 数据包来说，系统会提取其 SPI、IP 地址和协议类型等信息，查找相应的 IPsec SA，然后根据 SA 的协议标识符，选择合适的协议（AH 或 ESP）解封装，获得原始 IP 包，再进一步根据原始 IP 包的信息进行处理。

12.4 AH

12.4.1 AH 介绍

AH介绍



紫光集团 H3C
核心企业 数字化解决方案领导者

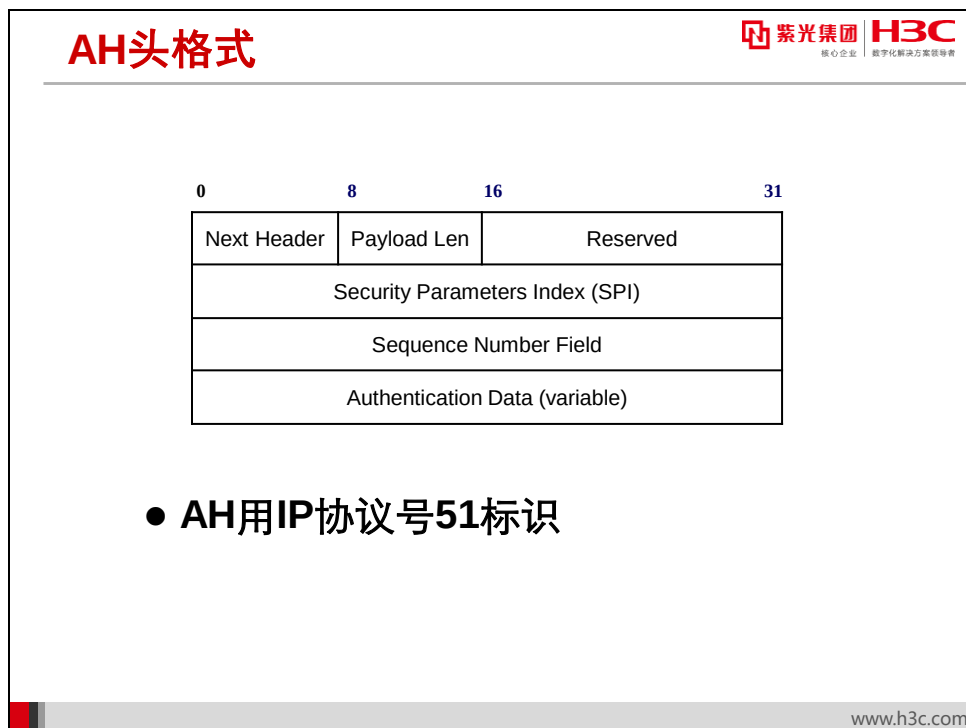
- AH（Authentication Header）
- RFC 2402
- 提供数据的完整性校验和源验证
- 不能提供数据加密功能
- 可提供有限的抗重播能力

www.h3c.com

规范于 RFC 2402 的 AH（Authentication Header，验证头）是 IPsec 的两种安全协议之一。它能够提供数据的完整性校验和源验证功能，同时也能提供一些有限的抗重播服务。

AH 不能提供数据加密功能，因此不能保证机密性。

12.4.2 AH 头格式



紧贴在 AH 头之前的 IP 头，以协议号 51 标识 AH 头。例如对 IPv4 来说，其 Protocol 字段值将为 51；而对 IPv6 来说，其 Next Header 字段值将为 51。

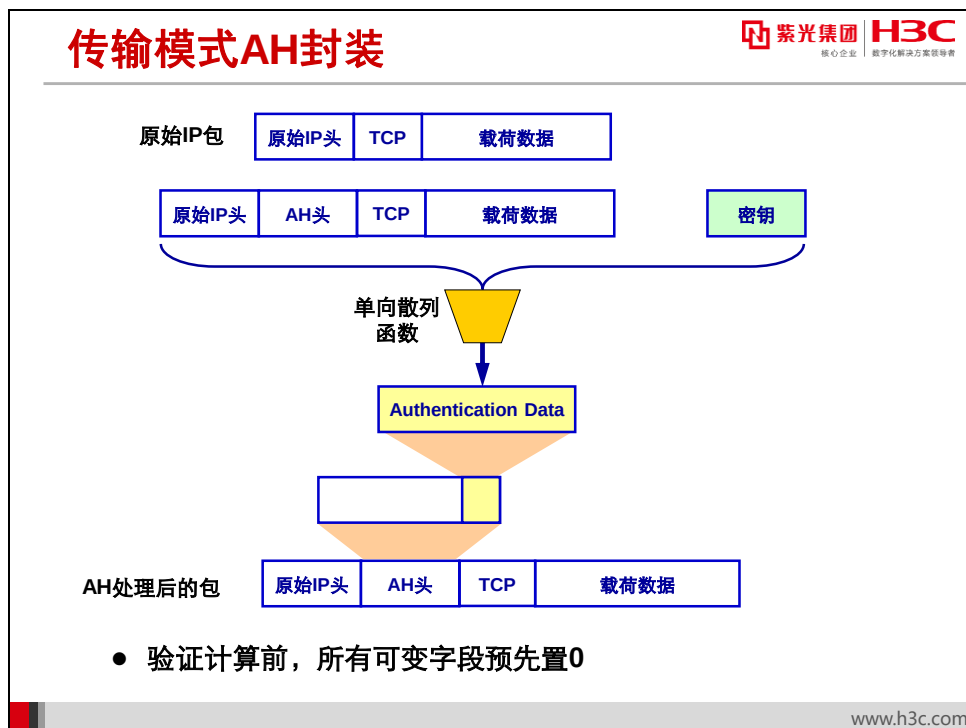
如图所示为 AH 头格式。其中各个字段含义如下：

- **Next Header:** 长度为 8 位。用于指示 AH 头后面的载荷协议头类型。该字段值属于 IANA 定义的 IP 协议号集合。
- **Payload Length:** 长度为 8 位。用于指示 AH 的长度减 2，单位是“32 位”。这是因为 AH 也是一个 IPv6 扩展头，而根据 RFC 2460 规定，所有 IPv6 扩展头必须把负载长度值减去一个“64 位”。
- **Reserved:** 长度 16 位，为将来的应用保留。目前必须设置为 0。
- **Security Parameters Index (SPI):** SPI 是一个长度 32 位的任意数值。SPI 与目的 IP 地址和安全协议标识 (AH/ESP) 结合，可以唯一地标识一个 SA。
- **Sequence Number:** 一个 32 位无符号整型数值。在一个 SA 刚刚建立时，此数值被初始化为 0，并且随着数据包的发送而递增。即使在不执行抗重播服务的情况下，发送方仍然发送序列号。接收方可以利用此数值确认一系列数据包的正确序列。
- **Authentication Data:** 包含了这个数据包的完整性校验值 (Integrity Check Value, ICV)。这个字段是变长的，但是必须为 32 位的整数倍。为了兼容性考虑，AH 强制实现 HMAC-MD5-96 和 HMAC-SHA-1-96 两种验证算法。

AH 使用 HMAC 算法计算 Authentication Data 数值。为了确保包括 IP 头、AH 头和载荷在内的整个包的完整性和正确来源，AH 的 HMAC 以 IP 头、AH 头、载荷以及共享密钥作为算法的输入，并将其 ICV 填入 Authentication Data 字段。

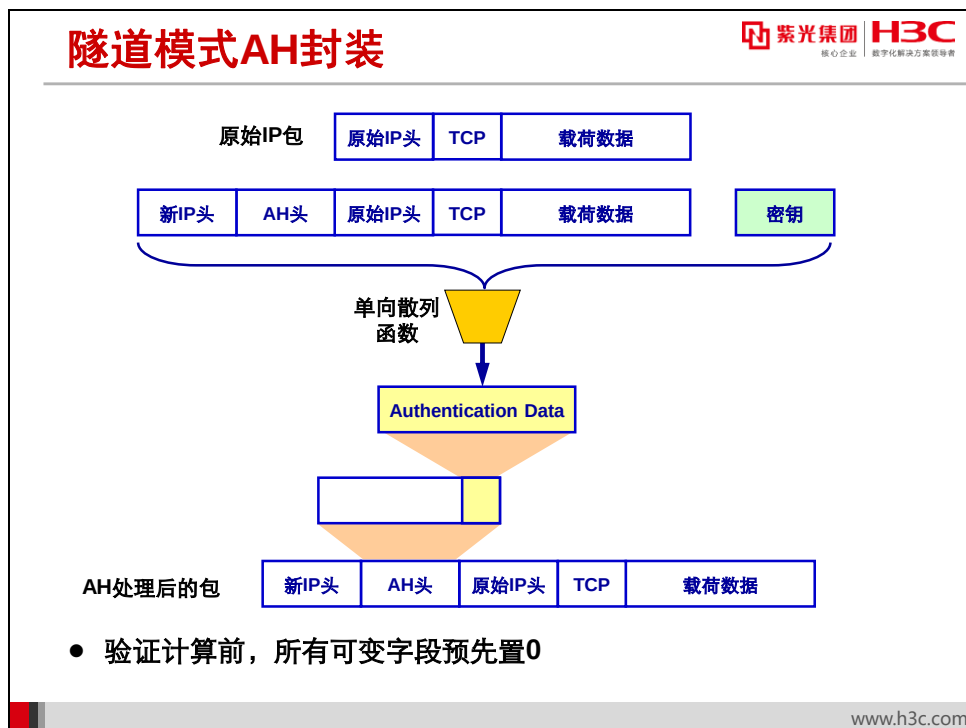
由于在转发过程中，IP 头的一些部分是变化的（如 ToS、Flags、Fragment Offset、TTL、Header Checksum 等），因此在计算 ICV 之前，必须把这些字段设置成 0。Authentication Data 字段本身也加入了 ICV 计算，所以在计算时，这个字段的值设置为 0。

12.4.3 AH 封装



在传输模式中，AH 保护的是 IP 包的上层协议，如 TCP 和 UDP。两个需要通信的终端计算机在彼此之间直接运行 IPsec 协议，通信连接的端点就是 IPsec 协议的端点。中间设备不做任何 IPsec 处理。

在建立好 AH 头并填充了各个字段之后，AH 头被插入原始 IP 头和原始载荷之间。



在隧道模式中，AH 保护的是整个 IP 包。整个原始 IP 包将会以 AH 载荷的方式加入新建的隧道数据包。同时，系统根据隧道起点和终点等参数，建立一个隧道 IP 头，作为隧道数据包的 IP 头。AH 头夹在隧道 IP 头和原始 IP 包之间。

当系统通过 SPD 了解到一个出站 IP 包需要获得 AH 服务时，就开始寻找一个相应的 SA。如果这个 SA 不存在，就呼叫 IKE 去建立一个 SA；如果这个 SA 存在，就利用这个 SA 提供 AH 安全服务。

当一个 SA 刚刚建立时，序列号被初始化为 0，之后随着数据包的数量不断递增。在计算 ICV 之前，要先完成序列号的递增。

系统首先把 IP 包头中的可变字段修改为 0，并把 AH 头的 Authentication Data 字段置 0，然后把 IP 包头、载荷、AH 头以及密钥输入 HMAC 单向散列算法，得到 ICV 数值。如果这个数值不符合 32 位的整数倍，还要进行填充，并且填充值也必须加入 ICV 的计算。

计算完成后，根据相应的工作模式，封装好数据包，就可以发送出去了。

IPsec 包在网络上传输时，可能遭到分段。因此，接收方有必要首先重组被分段的数据包。

接收方根据入站 IP 包的目 IP 地址、安全协议类型(AH)和 SPI 查找 SA。如果没有 SA，就丢弃之；如果有 SA，就可以了解到所使用的算法，以及是否验证序列号，并根据这些信息做相应处理。如果需要验证序列号，就进行序列号的核查。接收方把 IP 头的可变字段清零，并把 Authentication Data 清零，重新计算 ICV。如果结果与收到的 ICV 相等，则验证通过；反之则丢弃该数据包。

12.5 ESP

12.5.1 ESP 介绍

ESP介绍

 紫光集团
核心企业 | 数字化转型方案领导者

 H3C

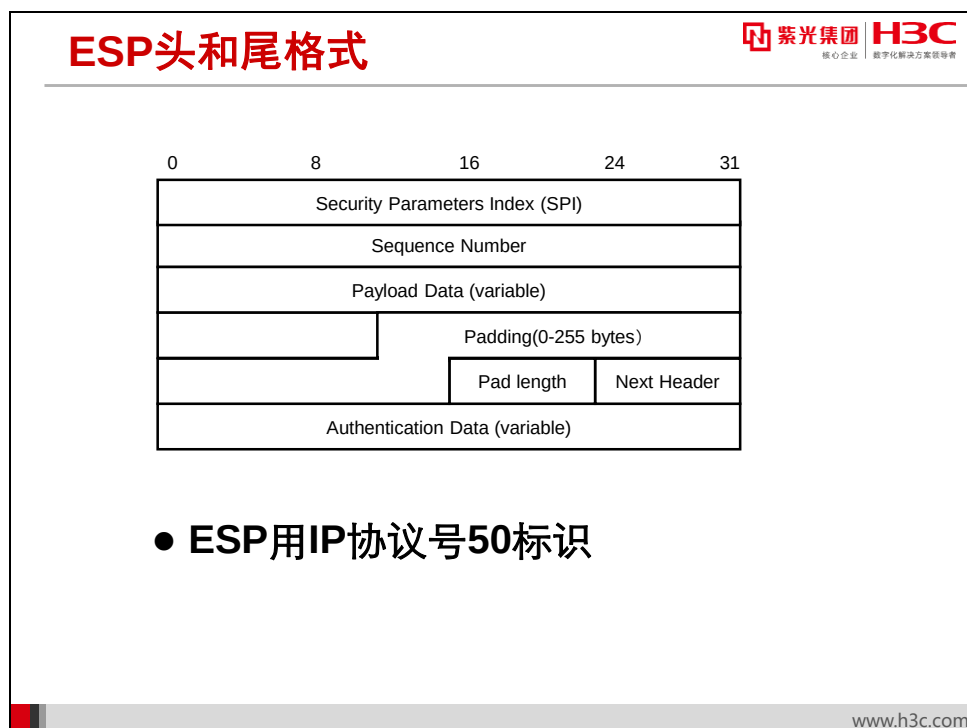
- ESP (Encapsulating Security Payload)
- RFC 2406
- 可提供数据的机密性保证
- 可提供数据的完整性校验和源验证
- 可提供一定的抗重播能力

www.h3c.com

RFC 2406 为 IPsec 定义了安全协议 ESP (Encapsulating Security Payload, 封装安全载荷)。

ESP 协议将用户数据进行加密后封装到 IP 包中, 以保证数据的机密性。同时作为可选项, 用户可以选择使用带密钥的哈希算法保证报文的完整性和真实性。ESP 的隧道模式提供了对于报文路径信息的隐藏。ESP 可以提供一定的抗重播服务。

12.5.2 ESP 头和尾格式



ESP 与 AH 封装格式有所区别。它不但具有一个 ESP 头，而且有一个包含有用信息的 ESP 尾。如图所示为 ESP 头和 ESP 尾格式。

紧贴在 ESP 头之前的 IP 头，以协议号 50 标识 ESP 头。例如对 IPv4 来说，其 Protocol 字段值将为 50。而对 IPv6 来说，其 Next Header 字段值将为 50。

其中各个字段含义如下：

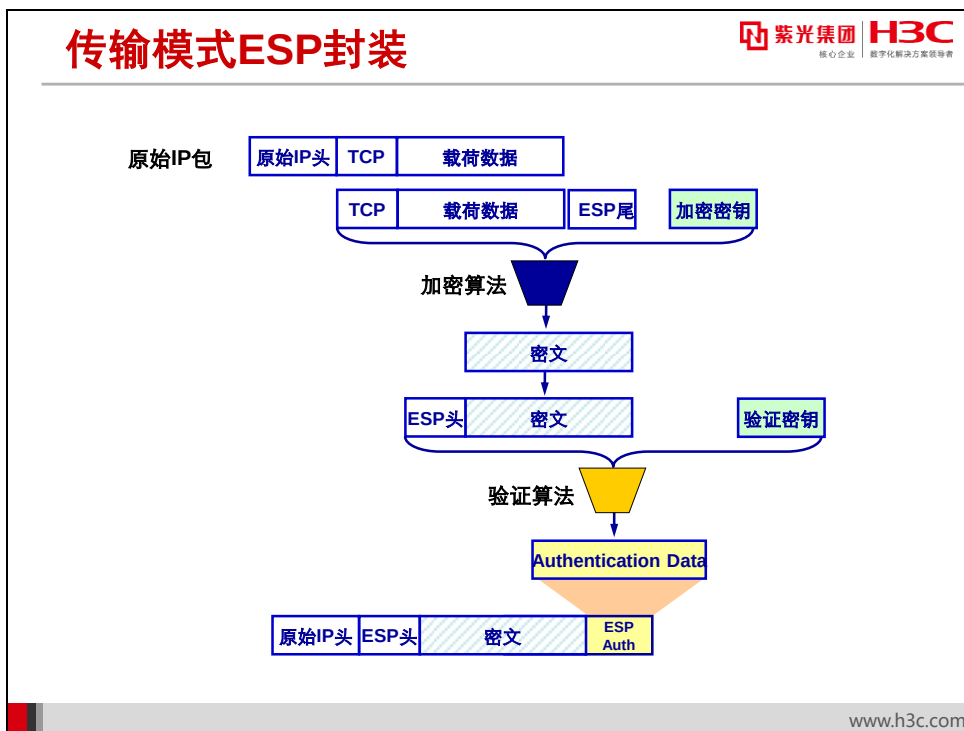
- **Security Parameters Index (SPI):** SPI 是一个任意的 32 位值，它与目的 IP 地址和安全协议（ESP）结合，唯一标识了这个数据包的 SA。
- **Sequence Number:** 一个 32 位无符号整型数值。在一个 SA 刚刚建立时，此数值被初始化为 0，并且随着数据包的发送而递增。即使在不执行抗重播服务的情况下，发送方仍然发送序列号。接收方可以利用此数值确认一系列数据包的正确序列。
- **Payload Data:** 是一个变长的字段，它包含了 Next Header 字段所描述的数据。Payload Data 字段是强制性的，它的长度是字节的整数倍。如果用于加密载荷的算法需要密码同步数据，例如初始向量(IV)，那么这个数据可以显式地装载在载荷字段中。ESP 强制实现的基本加密算法是 DES-CBC。
- **Padding:** 根据特定的加密算法要求，可能会增加填充位。这种情况可能是因为加密算法要求明文是某个数量的整数倍；可能是因为加密算法的输出不是 4 字节的整数倍；也可能是因为出于安全的考虑，故意对明文进行填充修改。

- **Pad Length:** 填充长度字段指出了其前面紧靠着的填充字节的个数。有效值范围是 0 至 255，其中 0 表明没有填充字节。填充长度字段是强制性的。
- **Next Header:** 是一个 8 比特的字段，它标识载荷字段中包含的数据类型。该字段值属于 IANA “Assigned Numbers” 中定义的 IP 协议号集合。字段是强制性的。
- **Authentication Data:** 这是一个变长的字段，它包含一个完整性校验值（ICV），该校验值是对 ESP 报文除去验证数据外的计算。该字段的长度由选择的验证算法决定。对于 ESP 来说，该字段是可选的，选择了验证服务时才包含该字段。为了兼容性考虑，ESP 强制实现 HMAC-MD5-96 和 HMAC-SHA-1-96 两种验证算法。

注意：

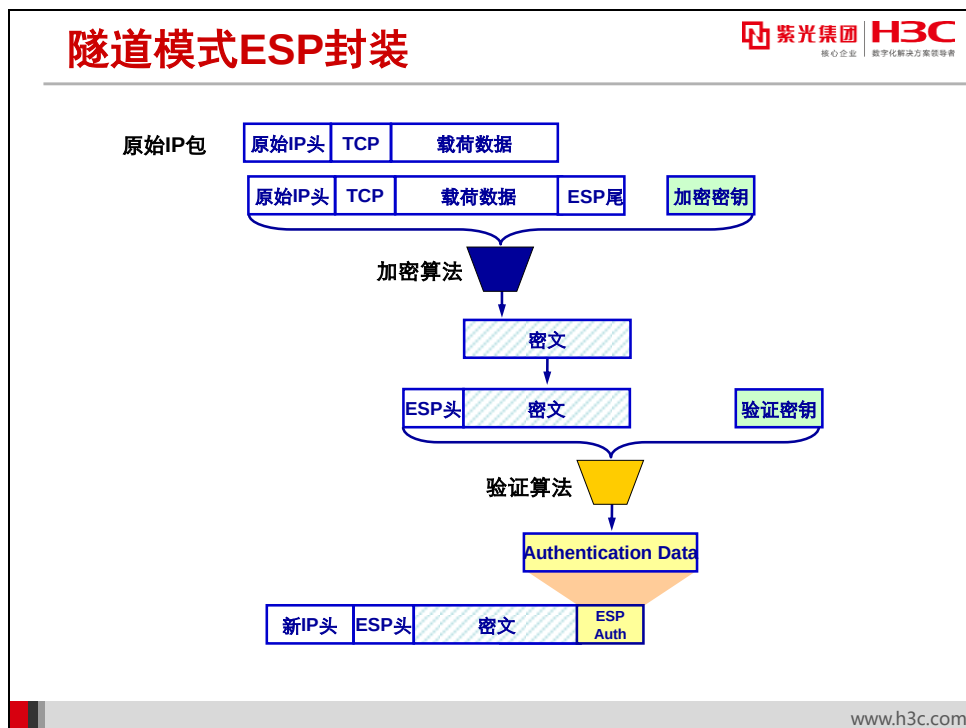
ESP 尾（ESP trailer）指 Padding、Pad Length 和 Next Header 字段。

12.5.3 ESP 封装



在传输模式中，ESP 加密的是 IP 包的上层协议，如 TCP 和 UDP。两个需要通信的终端计算机在彼此之间直接运行 IPsec 协议，通信连接的端点就是 IPsec 协议的端点。中间设备不做出任何 IPsec 处理。

在建立好 ESP 头和尾，并填充了各个字段之后，ESP 头被插在原始 IP 头和原始载荷之间，后缀 ESP 尾，最后将 ICV 写入 ESP 尾之后的 Authentication Data 字段，建立完整的 ESP 封装数据包，并发送之。如果 ESP 提供加密服务，则原始载荷和 ESP 尾将以密文的形式出现。



在隧道模式中，ESP 保护的是整个 IP 包。整个原始 IP 包将会以 ESP 载荷的方式加入新建的隧道数据包。同时，系统根据隧道起点和终点等参数，建立一个隧道 IP 头，作为隧道数据包的 IP 头。ESP 头夹在隧道 IP 头和原始 IP 包之间，并后缀 ESP 尾。如果 ESP 提供加密服务，则原始 IP 包和 ESP 尾将以密文的形式出现。

ESP 的处理流程与 AH 非常相似。

当系统通过 SPD 了解到一个出站 IP 包需要获得 ESP 服务时，就开始寻找一个相应的 SA。如果这个 SA 不存在，就呼叫 IKE 去建立一个 SA；如果这个 SA 存在，就利用这个 SA 提供 ESP 安全服务。

在 ESP 中，如果同时使用加密和验证，则验证在加密之后进行。因此，系统首先选择正确的加密算法，对报文进行加密。除了需要加密的载荷之外，加密的内容还包括了 Padding、Pad Length 和 Next Header 字段。

然后，如同 AH 中一样，建立序列号并写入 ESP 头，并计算 ICV。请注意，与 AH 不同的是，ESP 校验的内容只包括从 ESP 头到 ESP 尾的部分，而不包括 IP 地址。最后将 ICV 写入 ESP 尾之后的 Authentication Data 字段，建立完整的 ESP 封装数据包，并发送之。

与 AH 类似，ESP 在处理入站包时，首先重组被分段的数据包，然后利用三元组信息查找 SA。如果 SA 的抗重播服务被启动，则检查序列号的合法性。通过序列号核查之后，首先进行的是完整性和来源验证。不通过此项验证的数据包将被丢弃。通过完整性检查的包将交付给加密算法进行解密。并用最终结果还原出原本的上层协议报文或 IP 报文。

12.6 IKE

12.6.1 IKE 介绍

IKE介绍

- RFC 2409
- 使用Diffie-Hellman交换，在不安全的网络上安全地分发密钥，验证身份
- 定时更新SA和密钥，实现完善的前向安全性
- 允许IPsec提供抗重播服务
- 降低手工布署的复杂度
- UDP端口500

紫光集团 H3C
核心企业 数字化转型方案领导者
www.h3c.com

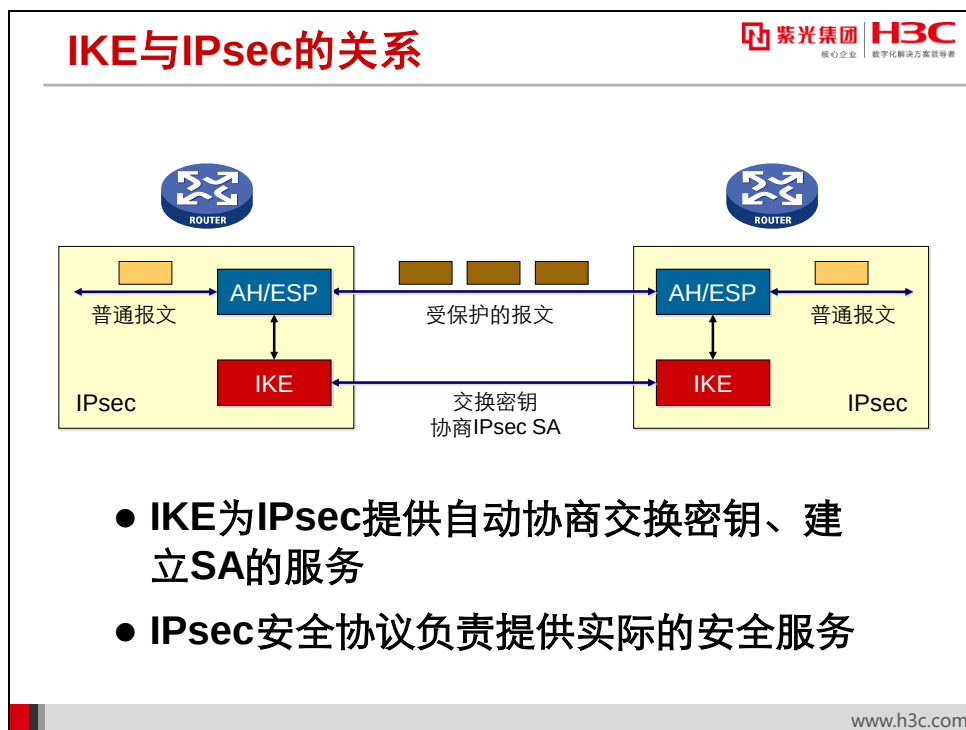
不论是 AH 还是 ESP，其对一个 IP 包执行操作之前，首先必须建立一个 IPsec SA。IPsec SA 既可以手工建立，也可以动态协商建立。RFC 2409 描述的 IKE（Internet Key Exchange，因特网密钥交换）就是用于这种动态协商的协议。

IKE 为 IPsec 提供了自动协商交换密钥、建立 SA 的服务，能够简化 IPsec 的使用和管理，大大简化 IPsec 的配置和维护工作。

IKE 具有一套自保护机制，可以在不安全的网络上安全地分发密钥，验证身份，建立 IPsec SA。IKE 并不在网络上直接传送密钥，而是采用 DH（Diffie-Hellman）交换，最终计算出双方共享的密钥，即使第三者截获了双方用于计算密钥的所有交换数据，也不足以计算出真正的密钥。IKE 可以定时更新 SA，定时更新密钥，而且各 SA 所使用的密钥互不相关，这提供了完善的前向安全性（Perfect Forward Security，PFS）。IKE 可以为 IPsec 自动重新建立 SA，从而允许 IPsec 提供抗重播服务。这一切都避免了频繁地执行繁琐的 IPsec SA 手工配置，在保证安全性的基础上降低了手工布署 IPsec 的复杂度。

IKE 采用了 ISAKMP（Internet Security Association and Key Management Protocol，RFC2408）所定义的密钥交换框架体系，并结合两个早期协议而成的，其中一个为 Oakley，另一个为 SKEME。Oakley 是一个自由的协议，它定义了密钥交换的顺序，提供了多种密钥交换模式。SKEME 则定义了密钥交换的方法。IKE 使用 Diffie-Hellman 算法进行密钥交换，工作于 IANA 为 ISAKMP 指定的 UDP 端口 500 上。

12.6.2 IKE 与 IPsec 的关系



IPsec 利用 SPD 判断一个数据包是否需要安全服务。当其需要安全服务时，就会去 SAD 查找相应的 IPsec SA。IPsec SA 有两种来源，一种是管理员手工配置的，另一种就是通过 IKE（Internet Key Exchange，因特网密钥交换）自动协商生成的。

通过 IKE 交换，IPsec 通信双方可以协商并获得一致的安全参数，建立共享的密钥，建立 IPsec SA。IPsec 安全网关根据 SA，选择适当的安全协议，对数据包提供相应的安全服务。

IKE 可以为 IPsec 提供 PFS 特性。

IKE 不仅用于 IPsec。实际上它是一个通用的交换协议，可以用于交换任何的共享秘密。例如它可以用于为 RIP、OSPF 这样的协议提供安全协商服务。

12.6.3 IKE 协商的阶段

IKE协商的两个阶段

- **阶段1**
 - 在网络上建立一个IKE SA，为阶段2协商提供保护
 - 主模式（Main Mode）和野蛮模式（Aggressive Mode）
- **阶段2**
 - 在阶段1建立的IKE SA的保护下完成IPsec SA的协商
 - 快速模式（Quick Mode）

www.h3c.com

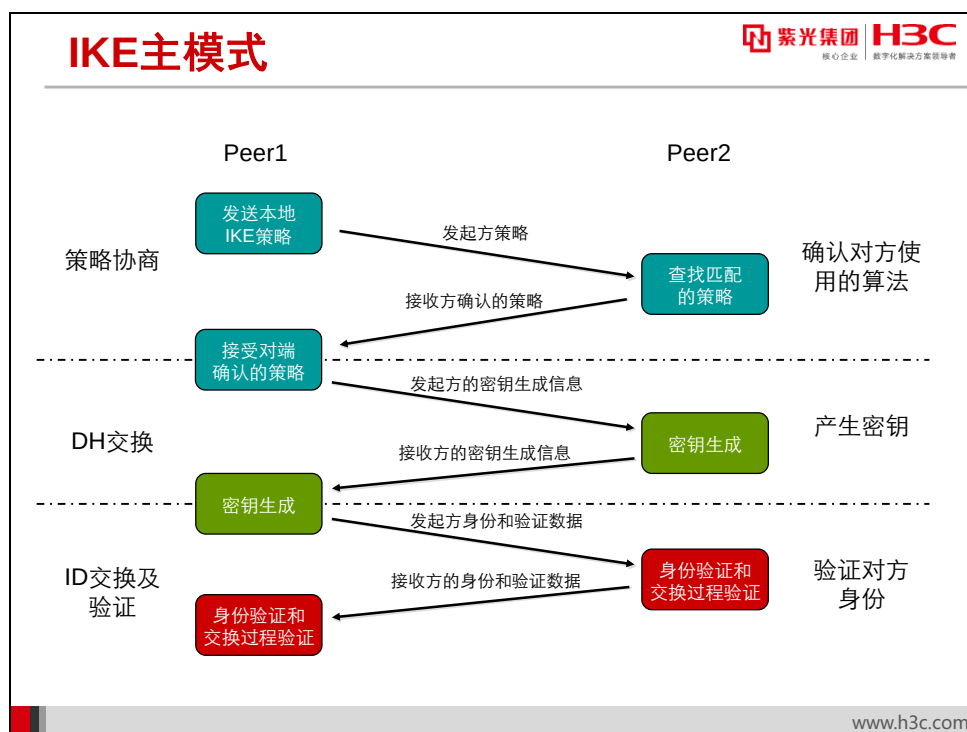
IKE 也使用 SA——IKE SA。与 IPsec SA 不同，IKE SA 是用于保护一对协商节点之间通信的密钥和策略的一个集合。它描述了一对进行 IKE 协商的节点如何进行通信，负责为双方进一步的 IKE 通信提供机密性、消息完整性以及消息源验证服务。IKE SA 本身也经过验证。IKE 协商的对方也就是 IPsec 的对方节点。

IKE 协商分为两个阶段：

- **阶段 1：** IKE 使用 Diffie-Hellman 交换建立共享密钥，在网络上建立一个 IKE SA，为阶段 2 协商提供保护。
- **阶段 2：** 在阶段 1 建立的 IKE SA 的保护下完成 IPsec SA 的协商。

IKE 定义了两个阶段 1 的交换模式——主模式（Main Mode）和野蛮模式（Aggressive Mode）；还定义了一个阶段 2 的交换模式——快速模式（Quick Mode）；另外还定义了两个其它交换，用于 SA 的维护——新组模式（New Group Mode）和信息交换（Informational Exchanges），前者用于协商新的 DH 交换组，后者用于通告 SA 状态和消息。

12.6.4 IKE 主模式



主模式是 IKE 强制实现的阶段 1 交换模式。它可以提供完整性保护。主模式总共有三个步骤，六条消息。

第一个步骤是策略协商。在这个步骤里，IKE 对等体双方用主模式的前两条消息协商 SA 所使用的策略。下列属性被作为 IKE SA 的一部分来协商，并用于创建 IKE SA：

- **加密算法：**IKE 使用诸如 DES、3DES、AES 这样的对称加密算法保证机密性。
- **散列算法：**IKE 使用 MD5、SHA 等散列算法。
- **验证方法：**IKE 允许多种不同的验证方法，包括预共享密钥（Pre-shared Key）、数字签名标准（Digital Signature Standard, DSS）以及从 RSA 公共密钥加密得到签名和验证的方法。
- 进行 Diffie-Hellman 操作的组（group）信息。

IKE 使用的 Diffie-Hellman 交换组包括：

1. MODP 768 位
2. MODP 1024 位
3. EC2N 155 字节
4. EC2N 185 字节
5. MODP 1536 位

其中必须实现的是第 1 种。

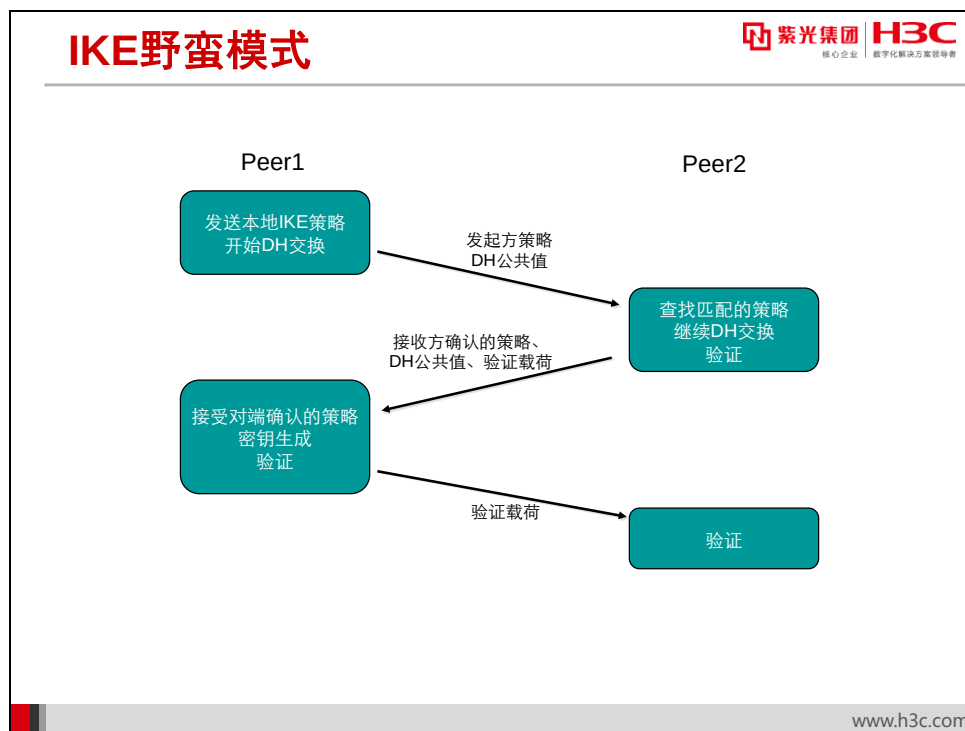
另外，IKE 生存时间（IKE Lifetime）也会被加入协商消息，以便明确 IKE SA 的存活时间。这个时间值可以以秒或者数据量计算。如果这个时间超时了，就需要重新进行阶段 1 交换。生存时间越长，秘密被破解的可能性就越大。

第二个步骤是 Diffie-Hellman 交换。在这个步骤里，IKE 对等体双方用主模式的第三和第四条消息交换 Diffie-Hellman 公共值及一些辅助数据（Nonce）。

在第三个步骤里，IKE 对等体双方用主模式的最后两条消息交换 ID 信息和验证数据，对 Diffie-Hellman 交换进行验证。

通过这六条消息的交换，IKE 对等体双方建立起一个 IKE SA。

12.6.5 IKE 野蛮模式



在使用预共享密钥的主模式 IKE 交换时，通信双方必须首先确定对方的 IP 地址。对于拥有固定地址的站点到站点的应用，这不是个大问题。但是在远程拨号访问时，由于拨号用户的 IP 地址无法预先确定，就不能使用这种方法。为了解决这个问题，需要使用 IKE 的野蛮模式交换。

IKE 野蛮模式的目的是与主模式相同——建立一个 IKE SA，以便为后续协商服务。但 IKE 野蛮模式交换只使用了三条消息。前两条消息负责协商策略、交换 Diffie-Hellman 公共值以及辅助数值（Nonce）和身份信息；同时第二条信息还用于验证响应者；第三条信息用于验证发起者。

首先，IKE 协商发起者发送一个消息，其中包括：

- 加密算法
- 散列算法
- 验证方法
- 进行 Diffie-Hellman 操作的组信息
- Diffie-Hellman 公共值
- Nonce 和身份信息

然后，响应者回应一条消息，不但须包含上述协商内容，还需要包含一个验证载荷。

最后，发起者回应一个验证载荷。

IKE 野蛮模式的功能比较有限，安全性差于主模式。但是在不能预先得知发起者的 IP 地址，并且需要使用预共享密钥的情况下，就必须使用野蛮模式。另外，野蛮模式的过程比较简单快捷，在充分了解对方安全策略的情况下，也可以使用野蛮模式。

12.7 本章总结

本章总结

- IPsec可提供IP通信的机密性、完整性和数据源验证服务
- AH可提供数据源验证和完整性保证，ESP还可提供机密性保证
- IPsec通过SA为数据提供安全服务
- IKE为IPsec提供了安全的密钥交换手段

12.8 习题和解答

12.8.1 习题

1. IPsec SA 可以通过（ ）协商建立。
A. AH B. ESP
C. SPI D. IKE
2. 同时提供完整性、机密性和数据源验证的是（ ）
A. AH B. ESP
C. MD5 D. DES
3. 在两个站点之间建立 IPsec 隧道，应使用（ ）
A. 隧道模式 B. 传输模式
C. 主模式 D. 野蛮模式
4. 下列关于 IPsec SA 的说法，正确的是（ ）
A. IPsec SA 是双向的 B. IPsec SA 是单向的
C. IPsec SA 必须由 IKE 协商建立 D. IPsec SA 必须由手工建立
5. 下列关于 IKE 野蛮模式的说法正确的是（ ）
A. 野蛮模式的安全性强于主模式
B. 野蛮模式的安全性弱于主模式
C. 野蛮模式的安全性等于主模式
D. 野蛮模式可以与主模式同时使用

12.8.2 习题答案

D
B
A
B
B

第13章 IPsec 配置和应用

本章讲解在路由器上配置 IPsec VPN 的方法及信息显示和调试命令。并给出了相关的配置示例。

GRE 和 L2TP 不能提供足够的安全性，因此在需要提供完整性和机密性保证时，可以与 IPsec 结合使用。本章亦将讲解用 IPsec 保护 GRE 和 L2TP 的方法。

13.1 本章目标

课程目标

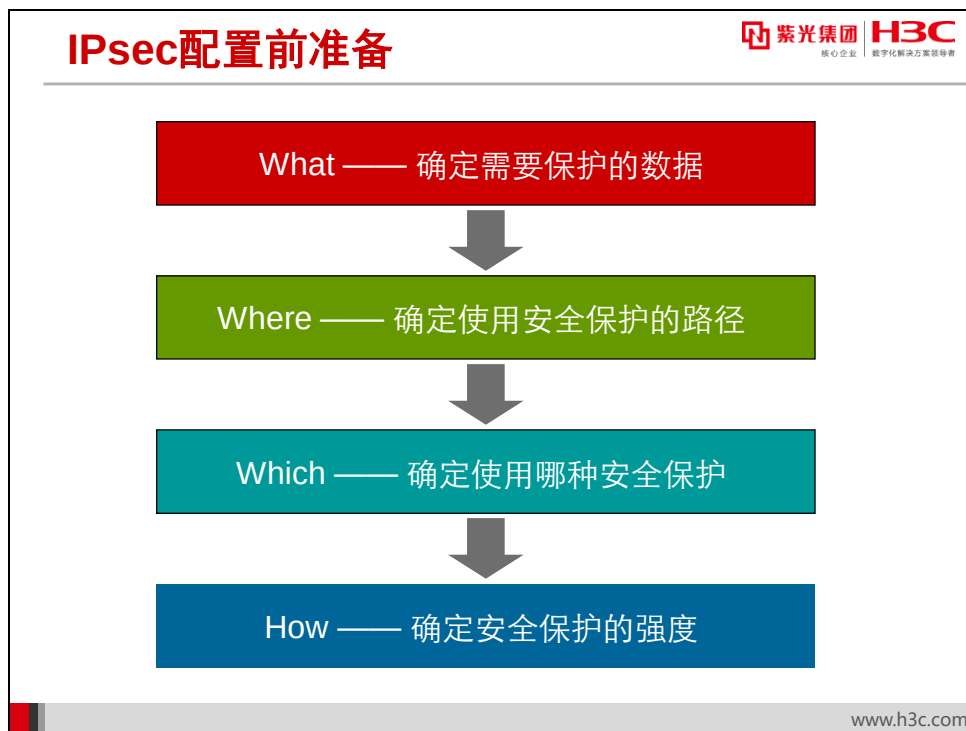
● 学习完本课程，您应该能够：

- 描述IPsec和IKE的配置要点和任务
- 配置IPsec和IKE
- 使用display命令获取IPsec和IKE配置和运行信息
- 使用debugging命令了解IPsec和IKE运行时的重要事件和异常情况
- 配置IPsec保护GRE和L2TP隧道



www.h3c.com

13.2 配置前准备



在配置 IPsec 前需要作好如下的准备：

- **确定需要保护的数据：**由于运行 IPsec 将会占用很多系统资源，并不是所有经过安全网关转发的数据都要进行验证和加密，只需对需要保护的数据进行验证和加密。可以通过定义扩展 ACL 来匹配需要验证和加密的数据。
- **确定使用安全保护的路径：**只有当数据在不安全的路径上进行传输时才需要进行安全保护。例如，如果认为企业网络内部是安全的，而数据在 Internet 上传输则是不安全的，那么只需要对跨越 Internet 传送数据的路径进行保护，通常也就是从一个安全网关到另一个安全网关之间对数据进行加密。
- **确定对数据流采用哪种方式的安全保护：**根据不同的需求，可以对数据只验证而不加密；也可对数据既验证又加密。只加密而不验证的方式是不推荐使用的，因为在对于数据的来源都不清楚的情况下对数据进行加密和解密是没有意义的。对数据只验证而不加密通常使用 AH 协议。对数据既进行验证又进行加密通常使用 ESP 协议。虽然也可以同时使用 AH 和 ESP 协议进行验证和加密，但这样会消耗较多的系统资源。
- **确定安全保护的强度：**不同的算法的强度不同。强度越高的算法，受保护的数据越难被破解，但消耗的计算资源越多。一般来说密钥越长的算法强度越高，如 128 位密钥的算法强度高于 96 位的算法。但不同算法的强度不易比较，例如通常认为 AES 优于 DES，但不能认为 MD5 优于 SHA。

13.3 配置IPsec VPN

13.3.1 IPsec VPN 配置任务

IPsec的配置任务



- 配置安全ACL
- 配置安全提议
 - 创建安全提议
 - 选择安全协议
 - 选择安全算法
 - 选择工作模式
- 配置安全策略
 - 手工配置参数的安全策略
 - 通过IKE协商参数的安全策略
- 在接口上应用安全策略

www.h3c.com

IPsec VPN 的基本配置任务包括：

- **配置安全 ACL：**IPsec 使用 ACL 的条件定义并匹配需获得安全服务的数据包，因此首先需配置一个 ACL 供 IPsec 使用，这种 ACL 称为安全 ACL。
- **配置安全提议：**配置 IPsec 安全网关期望使用的安全参数，包括创建安全提议，选择安全协议，选择安全算法和选择工作模式等。
- **配置安全策略：**通过安全策略允许安全网关为各种数据流提供复杂而截然不同的安全服务，安全策略包括手工配置参数的安全策略和通过 IKE 协商参数的安全策略等。一组同名的安全策略构成一个安全策略组。
- **在接口上应用安全策略组：**要想使安全策略生效，必须将其所在安全策略组应用于适当的接口上，以便使穿过此接口的相应数据包获得安全服务。

13.3.2 配置安全 ACL

配置安全ACL



紫光集团 H3C
核心企业 数字化转型方案领导者

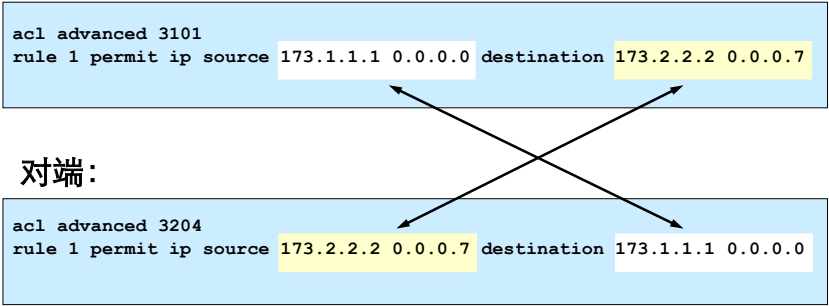
- IPsec通信双方安全ACL的源和目的须对称

本端：

```
acl advanced 3101
rule 1 permit ip source 173.1.1.1 0.0.0.0 destination 173.2.2.2 0.0.0.7
```

对端：

```
acl advanced 3204
rule 1 permit ip source 173.2.2.2 0.0.0.7 destination 173.1.1.1 0.0.0.0
```



www.h3c.com

IPsec 使用 ACL 的条件定义并匹配需获得安全服务的数据包,这种 ACL 也称为安全 ACL。对于发送方来说,安全 ACL 许可 (permit) 的包将被保护,安全 ACL 拒绝 (deny) 的包将不被保护。

在建立 IPsec 隧道的两个安全网关上定义的 ACL 必须是相对称的。即一端的安全 ACL 定义的源 IP 地址要与另一端安全 ACL 的目的 IP 地址一致。

IPsec 对安全 ACL 匹配的数据流进行保护,因此建议精确地配置 ACL,只对确实需要 IPsec 保护的数据流配置 permit,避免盲目地使用关键字 any。

13.3.3 配置安全提议

配置安全提议



- 创建安全提议，并进入安全提议视图

```
[Router] ipsec transform-set transform-set-name
```

- 选择安全协议

```
[Router-ipsec-transform-set-tran1] protocol { ah | ah-esp | esp }
```

- 选择工作模式

```
[Router-ipsec-transform-set-tran1] encapsulation-mode { transport | tunnel }
```

www.h3c.com

安全提议保存 IPsec 提供安全服务时准备使用的一组特定参数，包括安全协议、加密/验证算法、工作模式等，以便 IPsec 通信双方协商各种安全参数。IPsec 安全网关必须具有相同的安全提议才可以就安全参数达成一致。

一个安全策略通过引用一个或多个安全提议来确定采用的安全协议、算法和报文封装形式。在安全策略引用一个安全提议之前，这个安全提议必须已经建立。安全提议的配置内容如下述。

- 创建安全提议，并进入安全提议视图

```
[Router] ipsec transform-set transform-set-name
```

默认情况下没有任何安全提议存在。

- 选择安全协议

```
[Router-ipsec-transform-set-tran1] transform { ah | ah-esp | esp }
```

在安全提议中需要选择所采用的安全协议。可选的安全协议有 AH 和 ESP，也可指定同时使用 AH 与 ESP。安全隧道两端所选择的安全协议必须一致。默认情况下采用 ESP 协议。

- 选择工作模式

在安全提议中需要指定安全协议的工作模式，安全隧道的两端所选择的模式必须一致。默认情况下采用隧道模式。

```
[Router-ipsec-transform-set-tran1] encapsulation-mode { transport | tunnel }
```

配置安全提议 (续)

● 选择安全算法

→ 配置ESP协议采用的加密算法

```
[Router-ipsec-transform-set-tran1] esp encryption-algorithm  
{3des-cbc | aes-cbc-128 | aes-cbc-192 | aes-cbc-256 | des-cbc  
| null }
```

→ 配置ESP协议采用的验证算法

```
[Router-ipsec-transform-set-tran1] esp authentication-  
algorithm { md5 | sha1 }
```

→ 配置AH协议采用的验证算法

```
[Router-ipsec-transform-set-tran1] ah authentication-  
algorithm { md5 | sha1 }
```

● 选择安全算法

不同的安全协议可以采用不同的验证算法和加密算法。目前，AH 支持 MD5 和 SHA-1 验证算法；ESP 协议支持 MD5、SHA-1 验证算法以及 DES、3DES、AES、null 等加密算法，null 表示不加密。

设置 ESP 协议采用的加密算法：

```
[Router-ipsec-transform-set-tran1] esp encryption-algorithm { 3des-cbc |  
aes-cbc-128 | aes-cbc-192 | aes-cbc-256 | des-cbc | null }
```

设置 ESP 协议采用的验证算法：

```
[Router-ipsec-transform-set-tran1] esp authentication-algorithm { md5 | sha1 }
```

设置 AH 协议采用的验证算法：

```
[Router-ipsec-transform-set-tran1] ah authentication-algorithm { md5 | sha1 }
```

ESP 协议允许对报文同时进行加密和验证，或只加密，或只验证。AH 协议没有加密的功能，只对报文进行验证。在安全隧道的两端设置的安全策略所引用的安全提议必须设置成采用同样的验证算法和/或加密算法。

默认情况下，ESP 协议采用的加密算法是 DES，采用的验证算法是 MD5；AH 协议采用的验证算法是 MD5。

注意：

可以对安全提议进行修改。但若一个 SA 已协商成功,则新修改的安全提议并不立即生效,即 SA 仍然使用原来的安全提议,除非使用 **reset ipsec sa** 命令重置 SA;而新协商的 SA 将使用新的安全提议。

13.3.4 理解安全策略

安全策略的两种类型

- **静态——手工配置参数的安全策略**
 - 需要用户手工配置密钥、SPI、安全协议和算法等参数
 - 在隧道模式下还需要手工配置安全隧道两个端点的IP地址
- **动态——通过IKE协商参数的安全策略**
 - 由IKE自动协商生成密钥、SPI、安全协议和算法等参数

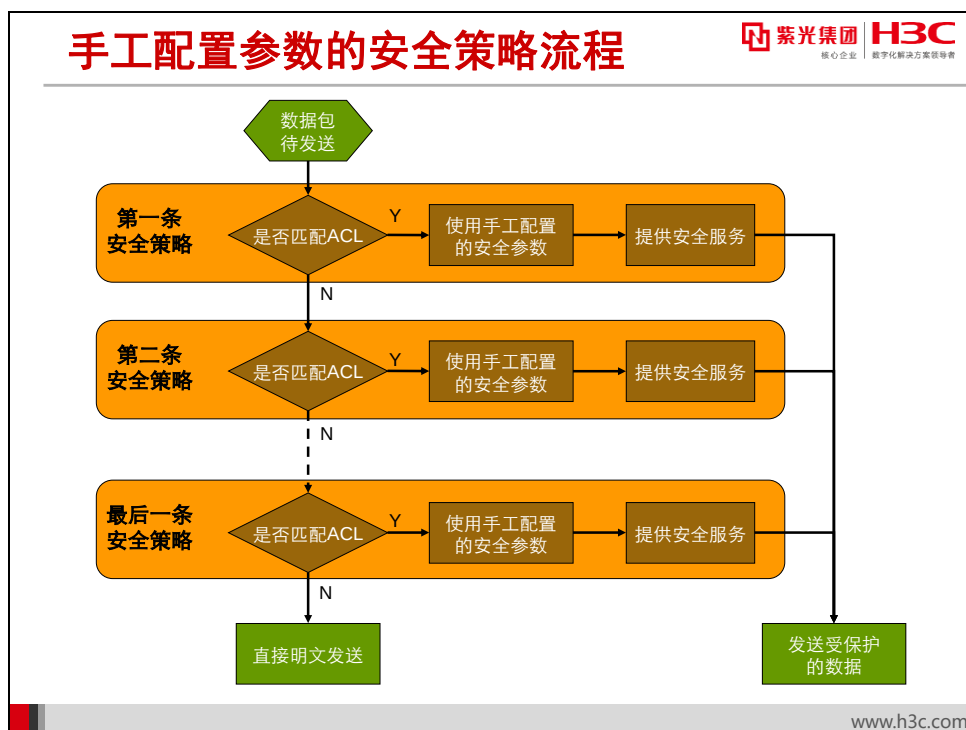
www.h3c.com

安全策略规定了对什么样的数据流采用什么样的安全提议。一条安全策略由“名字”和“序号”共同唯一标识。若干名字相同的安全策略构成一个安全策略组。

安全策略包括两类:

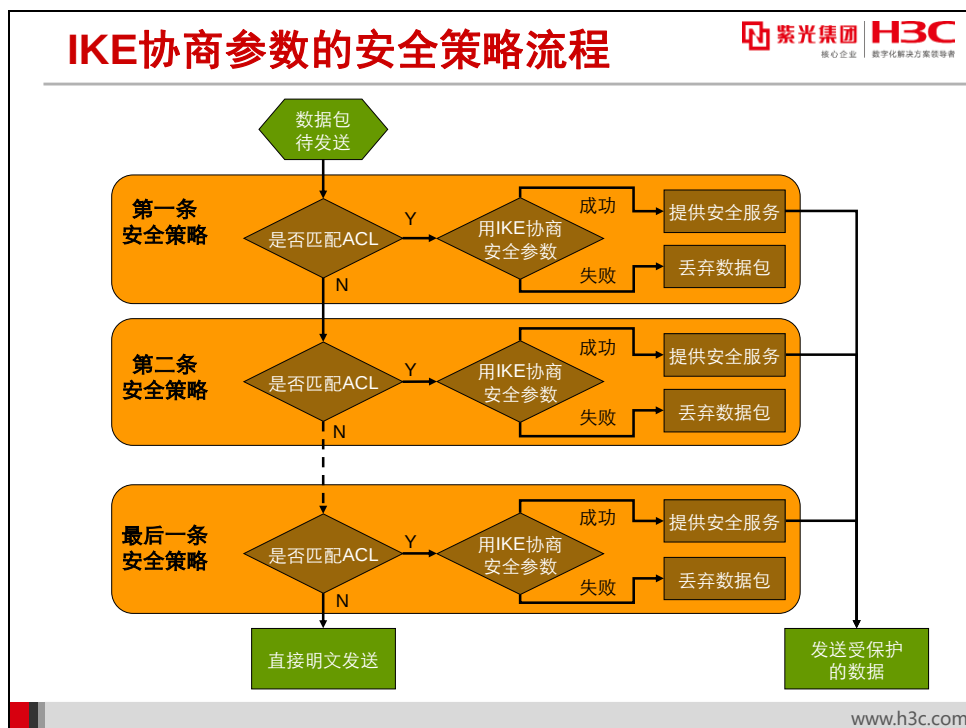
- **静态:** 手工配置参数的安全策略。需要用户手工配置密钥、SPI、安全协议和算法等参数,在隧道模式下还需要手工配置安全隧道两个端点的IP地址。
- **动态:** 通过IKE协商参数的安全策略。由IKE自动协商生成密钥、SPI、安全协议和算法等参数。

如果通过手工方式创建一条安全策略,则不能再修改它为IKE协商创建,而必须先删除该安全策略然后再创建;反之亦然。



如果在一个接口上应用了一个安全策略组，则当从此接口发送数据包时，将按照顺序号从小到大的次序尝试匹配安全策略组中每一条安全策略。

如果数据包匹配了一条手工配置参数的安全策略所引用的 ACL，则使用这条安全策略定义的对数据包提供安全服务；如果数据包没有匹配一条安全策略引用的 ACL，则继续尝试匹配下一条安全策略；如果数据包与所有安全策略引用的 ACL 都不匹配，则不对数据包提供任何安全服务而直接发送之。



如果数据包匹配了一个通过 IKE 协商参数的安全策略所引用的 ACL，则使用这条安全策略定义的参数通过 IKE 协商安全参数，建立 SA，并据此对数据包提供安全服务。如果 IKE 协商失败，则丢弃此数据包。

13.3.5 配置手工配置参数的安全策略

配置手工配置参数的安全策略



紫光集团 H3C
核心企业 数字化转型方案领导者

- 创建一条安全策略，并进入安全策略视图

```
[Router] ipsec policy policy-name seq-number manual
```

- 配置安全策略引用的ACL

```
[Router-ipsec-policy-manual-map1-10] security acl { acl-number | name acl-name }
```

- 配置安全策略所引用的安全提议

```
[Router-ipsec-policy-manual-map1-10] transform-set transform-set-name
```

www.h3c.com

手工配置参数的安全策略主要配置内容如下述。

- 创建一条安全策略，并进入安全策略视图

```
[Router] ipsec policy policy-name seq-number manual
```

具有相同名字、不同顺序号的安全策略共同构成一个安全策略组。在一个安全策略组中，顺序号越小的安全策略优先级越高。默认情况下没有任何安全策略存在。

- 配置安全策略引用的 ACL

```
[Router-ipsec-policy-manual-map1-10] security acl acl-number
```

一条安全策略只能引用一个 ACL，如果设置安全策略引用了多于一个 ACL，最后引用的 ACL 生效。默认情况下，安全策略没有引用 ACL。

- 配置安全策略所引用的安全提议

```
[Router-ipsec-policy-manual-map1-10] transform-set transform-set-name
```

通过手工方式建立 SA，一条安全策略只能引用一个安全提议，并且如果已经引用了安全提议，必须先取消原先的安全提议才能引用新的安全提议。默认情况下，安全策略没有引用任何安全提议。

配置手工配置参数的安全策略 (续)



- 配置IPsec隧道的对端地址

```
[Router-ipsec-policy-manual-map1-10] remote-address  
{ ipv4-address | ipv6 ipv6-address }
```

- 配置SA的SPI

```
[Router-ipsec-policy-manual-map1-10] sa spi { inbound |  
outbound } { ah | esp } spi-number
```

www.h3c.com

- 配置 IPsec 隧道的对端地址

```
[Router-ipsec-policy-manual-map1-10]remote-address ip-address
```

默认情况下，没有配置安全隧道的对端地址。安全隧道建立在本端和对端之间，在安全隧道的两端，当前端点的对端地址需要与对端的本端地址保持一致。IPsec 隧道的本端地址为应用安全策略的接口的主 IP 地址。

- 配置安全联盟的 SPI

```
[Router-ipsec-policy-manual-map1-10] sa spi { inbound | outbound } { ah | esp }  
spi-number
```

为保证安全联盟的唯一性，不同 SA 必须对应不同的 SPI。

配置手工配置参数的安全策略 (续)



- 配置SA使用的密钥

→ 配置协议的验证密钥（以16进制方式输入）

```
[Router-ipsec-policy-manual-map1-10] sa hex-key
authentication { inbound | outbound } { ah | esp } { cipher |
simple } key-value
```

→ 配置协议的验证密钥（以字符串方式输入）

```
[Router-ipsec-policy-manual-map1-10] sa string-key
{ inbound | outbound } { ah | esp } key-value
```

→ 配置ESP协议的加密密钥（以字符串方式输入）

```
[Router-ipsec-policy-manual-map1-10] sa string-key
{ inbound | outbound } esp key-value
```

www.h3c.com

- 配置 SA 使用的密钥

配置协议的验证密钥（以 16 进制方式输入）：

```
[Router-ipsec-policy-manual-map1-10]sa hex-key authentication { inbound |
outbound } { ah | esp } { cipher | simple } key-value
```

配置协议的验证密钥（以字符串方式输入）：

```
[Router-ipsec-policy-manual-map1-10] sa string-key { inbound | outbound } { ah |
esp } key-value
```

配置 ESP 协议的加密密钥（以字符串方式输入）：

```
[Router-ipsec-policy-manual-map1-10] sa string-key { inbound | outbound } esp
key-value
```

配置手工配置参数的安全策略 (续)



- 配置SA使用的密钥

→ 配置ESP协议的加密密钥（以16进制方式输入）

```
[Router-ipsec-policy-manual-map1-10] sa hex-key encryption  
{ inbound | outbound } esp { cipher | simple } key-value
```

www.h3c.com

- 配置 SA 使用的密钥

配置 ESP 协议的加密密钥（以 16 进制方式输入）：

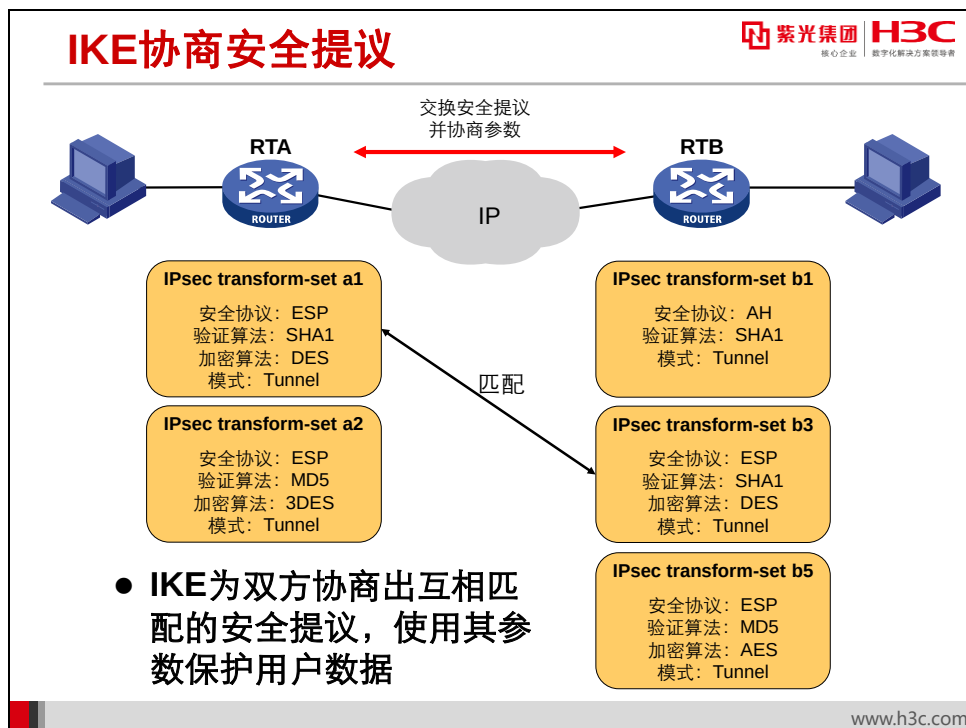
```
[Router-ipsec-policy-manual-map1-10]sa hex-key encryption { inbound |  
outbound } esp { cipher | simple } key-value
```

在安全隧道的两端设置的 SA 参数必须是完全匹配的。本端的入方向 SA 的 SPI 及密钥必须与对端的出方向 SA 的 SPI 及密钥一样；本端的出方向 SA 的 SPI 及密钥必须与对端的入方向 SA 的 SPI 及密钥一样。

如果分别以两种方式输入了密钥，则最后设定的密钥有效。

在为系统配置 SA 时，必须分别设置 **inbound** 和 **outbound** 两个方向 SA 的参数。

13.3.6 配置 IKE 协商参数的安全策略



通过 IKE 协商建立 SA 时，一条安全策略最多可以引用六个安全提议。IKE 对等体之间将交换这些安全提议，并搜索能够完全匹配的安全提议。如果找到互相匹配的安全提议，即使用其参数建立 SA。如果 IKE 在两端找不到完全匹配的安全提议，则 SA 不能建立，需要被保护的报文将被丢弃。

IKE协商下IPsec安全策略两种配置方式

紫光集团 H3C
核心企业 数字化转型方案领导者

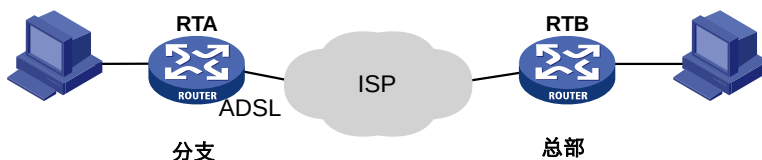
- **直接配置IPsec安全策略**

→ 在安全策略视图中定义需要协商的各参数

- **引用IPsec策略模板配置IPsec安全策略**

→ 首先在IPsec安全策略模板中定义需要协商的各参数，然后通过引用IPsec策略模板创建一条IPsec安全策略

→ 通常适用于VPN对端地址不确定的情况下



www.h3c.com

IKE 协商方式的 IPsec 安全策略有以下两种配置方式：

- **直接配置 IPsec 安全策略：**直接创建一个 IPsec 安全策略，在安全策略视图中定义需要协商的安全提议、安全 ACL 和 IKE 协议框架等参数。
- **引用 IPsec 安全策略模板配置 IPsec 安全策略：**首先在 IPsec 安全策略模板中定义需要协商的安全提议、和 IKE 协议框架等参数，然后通过引用 IPsec 安全策略模板创建一条 IPsec 安全策略

直接配置 IPsec 安全策略的方式中必须指定 IPsec 隧道的对端 IP 地址，适用于隧道对端 IP 地址固定的情况下。引用 IPsec 安全策略模板配置 IPsec 安全策略的方式中隧道对端 IP 地址、安全 ACL 等很多参数都是可选的，而安全策略模板中未定义的可选参数由发起方来决定，而响应方会接受发起方的建议，例如 IPsec 安全策略模板下未配置用于定义保护对象范围的 ACL 时，相当于完全接受协商发起端的 ACL 设置。所以这种方式配置的 IPsec 安全策略通常配置在响应方，并且可以用于隧道对端地址不固定的情况下，允许这些对端设备向本端设备主动发起协商。

直接配置IKE协商参数的安全策略



- 创建一条安全策略，并进入安全策略视图

```
[Router] ipsec policy policy-name seq-number isakmp
```

- 配置安全策略引用的ACL

```
[Router-ipsec-policy-isakmp-map1-10] security acl acl-number
```

- 配置安全策略引用的安全提议

```
[Router-ipsec-policy-isakmp-map1-10] transform-set transform-set-name
```

- 配置安全策略引用的IKE 协议框架

```
[Router-ipsec-policy-isakmp-map1-10] ike-profile profile-name
```

www.h3c.com

直接配置 IKE 协商参数的安全策略主要配置内容如下述。

- 创建一条安全策略，并进入安全策略视图

```
[Router] ipsec policy policy-name seq-number isakmp
```

- 配置安全策略引用的 ACL

```
[Router-ipsec-policy-manual-map1-10] security acl acl-number
```

- 配置安全策略引用的安全提议

```
[Router-ipsec-policy-manual-map1-10] transform-set transform-set-name
```

通过 IKE 协商建立 SA 时，一条安全策略最多可以引用六个安全提议。

- 配置安全策略引用的 IKE 协议框架

```
[Router-ipsec-policy-manual-map1-10] ike-profile profile-name
```

使用 **ike-profile** 命令可以将一条安全策略与一个 IKE profile 关联起来。一旦有数据包匹配此安全策略，系统将使用此 IKE profile 指定的参数与指定的设备协商 IPsec 隧道的安全参数。

注意：

此处仅介绍了 IPsec 对 IKE profile 的引用命令。实际上还需要对 IKE profile 进行一些相关参数的设置，包括 IKE 的安全提议、协商模式、本端身份信息、DPD、预共享密钥、PKI 域、匹配对端身份的规则等。有关 IKE profile 的配置，请参考配置 IKE 的相关内容。

直接配置IKE协商参数的安全策略 (续)



● 配置IPsec隧道的本端IP地址

```
[Router-ipsec-policy-isakmp-map1-10] local-address ip-address
```

● 配置IPsec隧道的对端IP地址

```
[Router-ipsec-policy-isakmp-map1-10] remote-address ip-address
```

● 配置安全策略的SA生存周期

```
[Router-ipsec-policy-isakmp-map1-10] sa duration { time-based seconds | traffic-based kilobytes }
```

● 配置全局的SA生存周期

```
[Router] ipsec sa global-duration { time-based seconds | traffic-based kilobytes }
```

www.h3c.com

● 配置 IPsec 隧道的本端 IP 地址

```
[Router-ipsec-policy-isakmp-map1-10] local-address ip-address
```

IPsec 隧道的本端 IP 地址为应用 IPsec 安全策略的接口的主地址，此处指定的 IPsec 隧道本端 IP 地址必须与 IKE 使用的标识本端身份的 IP 地址一致。缺省情况下，IPsec 隧道的本端 IP 地址为应用 IPsec 安全策略的接口的主 IP 地址。

● 配置 IPsec 隧道的对端 IP 地址

```
[Router-ipsec-policy-isakmp-map1-10] remote-address ip-address
```

缺省情况下，未指定 IPsec 隧道的对端 IP 地址，采用直接配置 IKE 协商方式的 IPsec 安全策略时，必须配置隧道对端 IP 地址，而且发起方的 IPsec 隧道的对端 IP 地址必须与响应方的 IPsec 隧道本端 IP 地址一致。另外，还可以采用主机名的方式配置隧道的对端 IP 地址，采用主机名方式时需要在设备上配置 DNS 服务器或者静态域名。

● 配置安全策略的 SA 生存周期

```
[Router-ipsec-policy-isakmp-map1-10] sa duration { time-based seconds | traffic-based kilobytes }
```

缺省情况下，IPsec 安全策略下的 IPsec SA 生存时间为当前全局的 IPsec SA 生存时间。

● 配置全局的 SA 生存周期

```
[Router] ipsec sa global-duration { time-based seconds | traffic-based kilobytes }
```

默认情况下，安全联盟基于时间的生存周期为 3600s，基于流量的生存周期为 1843200KB。

当 IKE 协商安全联盟时，如果采用的安全策略没有配置自己的生存周期，将采用此命令所定义的全局生存周期与对端协商。如果安全策略配置了自己的生存周期，则系统使用安全策略自己的生存周期与对端协商。

IKE 为 IPsec 协商建立安全联盟时，采用本地配置的生存周期和对端提议的生存周期中较小的一个。

模板方式配置IKE协商参数的安全策略



- 创建一个安全策略模板，并进入模板视图

```
[Router] ipsec policy-template template-name seq-number
```

- 配置安全策略模板引用的ACL

```
[Router-ipsec-policy-isakmp-temp1-10] security acl acl-number
```

- 配置安全策略模板引用的安全提议

```
[Router-ipsec-policy-isakmp-temp1-10] transform-set  
transform-set-name
```

- 配置安全策略模板引用的IKE协议框架

```
[Router-ipsec-policy-isakmp-temp1-10] ike-profile profile-name
```

- 配置IPsec隧道的本端IP地址

```
[Router-ipsec-policy-isakmp-temp1-10] local-address ip-address
```

www.h3c.com

模板方式配置 IKE 协商参数的安全策略主要配置内容如下述。

- 创建一个安全策略模板，并进入模板视图

```
[Router] ipsec policy-template template-name seq-number
```

- 配置安全策略模板引用的 ACL

```
[Router-ipsec-policy-isakmp-temp1-10] security acl acl-number
```

采用模板方式的安全策略中安全 ACL 这个参数是可选配置的，如果不定义，则完全接受协商发起端的 ACL 设置。

- 配置安全策略模板引用的安全提议

```
[Router-ipsec-policy-manual-temp1-10] transform-set transform-set-name
```

通过 IKE 协商建立 SA 时，一个安全策略模板最多可以引用六个安全提议。

- 配置安全策略模板引用 IKE 的协议框架

```
[Router-ipsec-policy-manual-temp1-10] ike-profile profile-name
```

使用 **ike-profile** 命令可以将一个安全策略模板与一个 IKE profile 关联起来。一旦有数据包匹配此安全策略模板，系统将使用此 IKE profile 指定的参数与指定的设备协商 IPsec 隧道的安全参数。

- 配置 IPsec 隧道的本端 IP 地址

[Router-ipsec-policy-isakmp-temp1-10] **local-address** *ip-address*

IPsec 隧道的本端 IP 地址为应用 IPsec 安全策略的接口的主地址，此处指定的 IPsec 隧道本端 IP 地址必须与 IKE 使用的标识本端身份的 IP 地址一致。缺省情况下，IPsec 隧道的本端 IP 地址为应用 IPsec 安全策略的接口的主 IP 地址。

模板方式配置IKE协商参数的安全策略 (续)



- 配置IPsec隧道的对端IP地址

[Router-ipsec-policy-isakmp-temp1-10] **remote-address** *ip-address*

- 配置安全策略的SA生存周期

[Router-ipsec-policy-isakmp-temp1-10] **sa duration** { *time-based seconds* | *traffic-based kilobytes* }

- 配置全局的SA生存周期

[Router] **ipsec sa global-duration** { *time-based seconds* | *traffic-based kilobytes* }

- 引用安全策略模板创建安全策略

[Router-Serial1/0] **ipsec policy** *policy-name* *seq-number* **isakmp template** *template-name*

www.h3c.com

- 配置 IPsec 隧道的对端 IP 地址

[Router-ipsec-policy-isakmp-temp1-10] **remote-address** *ip-address*

缺省情况下，未指定 IPsec 隧道的对端 IP 地址，采用模板方式配置 IKE 协商的 IPsec 安全策略时，如果设备作为响应方，可以不指定隧道对端的 IP 地址。

- 配置安全策略的 SA 生存周期

[Router-ipsec-policy-isakmp-temp1-10] **sa duration** { **time-based** *seconds* | **traffic-based** *kilobytes* }

缺省情况下，IPsec 策略模板下的 IPsec SA 生存时间为前全局的 IPsec SA 生存时间。

- 配置全局的 SA 生存周期

[Router] **ipsec sa global-duration** { **time-based** *seconds* | **traffic-based** *kilobytes* }

默认情况下，安全联盟基于时间的生存周期为 3600s，基于流量的生存周期为 1843200KB。

当 IKE 协商安全联盟时，如果采用的安全策略没有配置自己的生存周期，将采用此命令所定义的全局生存周期与对端协商。如果安全策略配置了自己的生存周期，则系统使用安全策略自己的生存周期与对端协商。

IKE 为 IPsec 协商建立安全联盟时，采用本地配置的生存周期和对端提议的生存周期中较小的一个。

- 引用安全策略模板创建安全策略

```
[Router-Serial1/0]ipsec policy policy-name seq-number isakmp template  
template-name
```

引用 IPsec 安全策略模板创建一条 IKE 协商方式的 IPsec 安全策略，应用了该类 IPsec 安全策略的接口不能发起协商，仅可以响应远端设备的协商请求，这种方式创建的 IPsec 安全策略适用于通信对端（例如对端的 IP 地址）未知的情况下，允许这些对端设备向本端设备主动发起协商。

13.3.7 在接口上应用安全策略

紫光集团 H3C
核心企业 数字化解决方案领导者

在接口上应用安全策略

- 在接口上应用安全策略

```
[Router-Serial1/0] ipsec apply policy policy-name
```

→ IPsec安全策略可以应用到串口、以太网口等物理接口上和Tunnel、Virtual Template等逻辑接口上

→ 一个接口只能应用一个安全策略组

→ IKE协商参数的安全策略可以应用到多个接口上

→ 手工配置参数的安全策略只能应用到一个接口上

www.h3c.com

为使定义的 SA 生效，应在每个要加密的数据流和要解密的数据流所在的接口上应用一个安全策略组，以对数据进行保护。当取消安全策略组在接口上的应用后，此接口便不再具有 IPsec 的安全保护功能。

IPsec 安全策略除了可以应用到串口、以太网口等实际物理接口上之外，还能够应用到 Tunnel、Virtual Template 等虚接口上。可以根据实际组网要求，在如 GRE、L2TP 等隧道上应用安全策略。

要在接口上应用安全策略组，使用命令：

```
[Router-Serial1/0] ipsec apply policy policy-name
```

注意：

一个接口只能应用一个安全策略组。通过 IKE 方式创建的安全策略可以应用到多个接口上，通过手工创建的安全策略只能应用到一个接口上。

13.3.8 IPsec 的信息显示与调试维护

IPsec信息显示命令



紫光集团 H3C
核心企业 数字化解决方案领导者

- 显示安全策略的信息

```
[Router] display ipsec policy [ policy-name [ seq-number ] ]
```

- 显示安全提议的信息

```
[Router] display ipsec transform-set [transform-set-name ]
```

- 显示安全联盟的相关信息

```
[Router] display ipsec sa [ brief | count | policy policy-name [ seq-number ] | interface interface-type interface-number | remote ip-address ]
```

- 显示IPsec处理报文的统计信息

```
[Router] display ipsec statistics [ tunnel-id tunnel-id ]
```

www.h3c.com

要显示所配置的安全策略的信息，使用命令：

```
[Router] display ipsec policy [ policy-name [ seq-number ] ]
```

如果不指定任何参数，则显示所有 IPsec 安全策略的信息，如果指定了 *policy-name* 和 *seq-number*，则显示指定的 IPsec 安全策略表项的信息；如果指定了 *policy-name* 而没有指定 *seq-number*，则显示所有名称相同的 IPsec 安全策略表项的信息。

要显示所配置的安全提议的信息，使用命令：

```
[Router] display ipsec transform-set [transform-set-name ]
```

要显示安全联盟的相关信息，使用命令：

```
[Router] display ipsec sa [ brief | count | policy policy-name [ seq-number ] | interface interface-type interface-number | remote ip-address ]
```

其中,使用 **brief** 关键字显示所有的安全联盟的简要信息;使用 **count** 关键字显示 IPsec SA 的个数使用;使用 **interface** 关键字显示指定接口下的 IPsec SA 的详细信息;使用 **policy** 关键字显示由指定安全策略创建的安全联盟的详细信息。

要显示 IPsec 处理报文的统计信息,使用命令:

[Router] **display ipsec statistics [tunnel-id tunnel-id]**

其中,使用 **tunnel-id** 关键字可以显示指定 IPsec 隧道处理的报文统计信息。

display ipsec sa命令显示示例



紫光集团 H3C
核心企业 数字化解决方案领导者

```
<RTA>display ipsec sa
-----
Interface: GigabitEthernet0/1
-----

IPsec policy: policy1
Sequence number: 1
Mode: ISAKMP
-----

Tunnel id: 0
Encapsulation mode: tunnel
Perfect forward secrecy:
Path MTU: 1427
Tunnel:
  local address: 1.1.1.1
  remote address: 2.2.2.1
Flow:
  sour addr: 192.168.1.0/255.255.255.0 port: 0 protocol: ip
  dest addr: 192.168.2.0/255.255.255.0 port: 0 protocol: ip
```

www.h3c.com

display ipsec sa 命令显示示例

 紫光集团 H3C
核心企业 数字化解决方案领导者

```
[Inbound ESP SAs]
SPI: 2126888239 (0x7ec5bd2f)
Connection ID: 4294967296
Transform set: ESP-ENCRYPT-AES-CBC-128 ESP-AUTH-SHA1
SA duration (kilobytes/sec): 1843200/3600
SA remaining duration (kilobytes/sec): 1843199/2826
Max received sequence-number: 4
Anti-replay check enable: Y
Anti-replay window size: 64
UDP encapsulation used for NAT traversal: N
Status: Active

[Outbound ESP SAs]
SPI: 3349617173 (0xc7a71a15)
Connection ID: 4294967297
Transform set: ESP-ENCRYPT-AES-CBC-128 ESP-AUTH-SHA1
SA duration (kilobytes/sec): 1843200/3600
SA remaining duration (kilobytes/sec): 1843199/2826
Max sent sequence-number: 4
UDP encapsulation used for NAT traversal: N
Status: Active
```

www.h3c.com

display ipsec sa 命令的典型显示信息如图。可见接口 GE0/1 上应用了安全策略 policy1，此安全策略要求工作于隧道模式，隧道本端地址为 1.1.1.1，对端地址为 2.2.2.1。此安全策略通过 IKE 协商生成了一个 inbound 方向的 ESP SA 和一个 outbound 方向的 ESP SA。SPI、生存时间等参数均有显示。

IPsec 调试和维护命令

 紫光集团 H3C
核心企业 数字化解决方案领导者

● IPsec 调试命令

```
<Router> debugging ipsec { all | error | packet [ policy policy-name [ seq-number ] | remote ip-address | spi spi-number ] }
```

● 清除已经建立的安全联盟

```
<Router> reset ipsec sa [ spi spi-number | policy policy-name [ seq-number ] | remote ip-address ]
```

● 清除 IPsec 的报文统计信息

```
<Router> reset ipsec statistics [ tunnel-id tunnel-id ]
```

www.h3c.com

要打开 IPsec 调试功能，使用命令：

```
debugging ipsec { all | error | packet [ policy policy-name [ seq-number ] | remote ip-address spi spi-number ] }
```

要清除已经建立的安全联盟，使用命令：

```
<Router> reset ipsec sa [ spi spi-number | policy policy-name [ seq-number ] | remote ip-address ]
```

要清除 IPsec 的报文统计信息，使用命令：

```
<Router> reset ipsec statistics [ tunnel-id tunnel-id ]
```

13.4 IKE的配置

13.4.1 IKE 配置前准备

IKE配置前准备

- **确定IKE交换过程中安全保护的强度**
 - 包括身份验证方法、加密算法、验证算法、DH组等
- **确定所选验证方法的相应参数**
 - 使用预共享密钥方法需预先约定共享密钥
 - 使用数字签名认证方法需预先约定所属的PKI域

www.h3c.com

配置 IKE 之前需提前确定以下信息：

- 确定 IKE 交换过程中安全保护的强度。包括身份验证方法、加密算法、验证算法、DH 组等。
- 确定所选验证方法的相应参数。如果使用预共享密钥（pre-shared key）方法，需预先约定共享密钥；如果使用数字签名方法需预先约定所属的 PKI 域。

13.4.2 IKE 配置任务

IKE配置任务

- 配置IKE提议
 - 创建IKE提议
 - 选择IKE提议的加密算法
 - 选择IKE提议的验证方法
 - 选择IKE提议的验证算法
 - 选择IKE阶段1密钥协商所使用的DH组
 - 配置IKE提议的SA生存周期
- 配置IKE keychain
 - 创建IKE keychain
 - 配置预共享密钥
 - 配置IKE keychain的使用范围

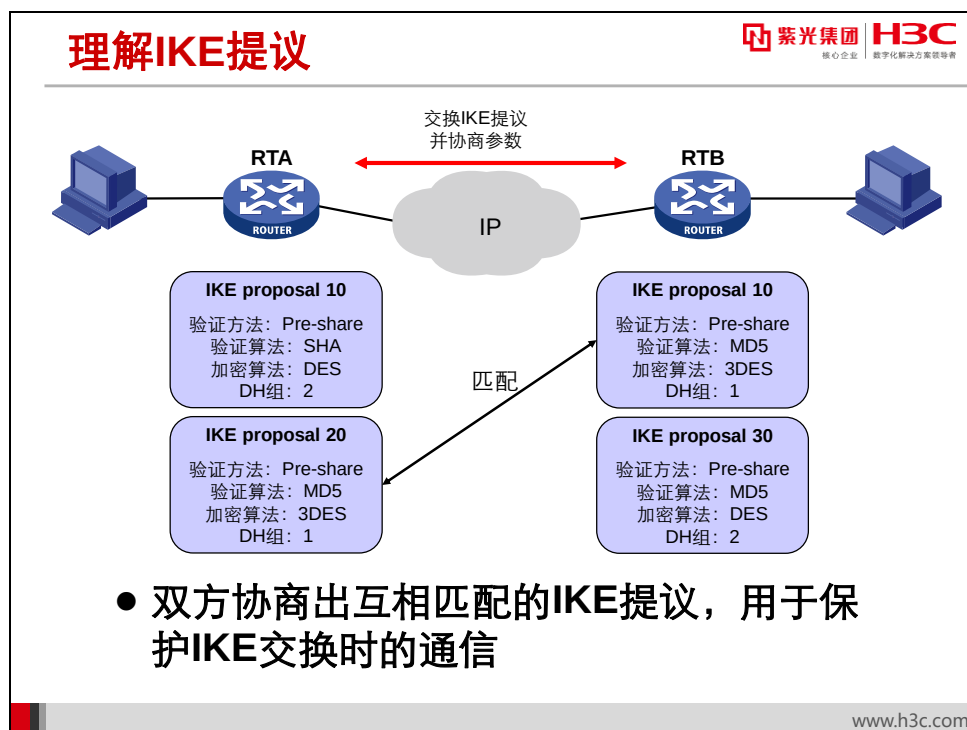
- 配置IKE profile
 - 创建IKE profile
 - 配置IKE第一阶段的协商模式
 - 配置采用预共享密钥认证时使用的keychain
 - 配置采用数字签名认证时，证书所属的PKI域
 - 配置本端身份信息
 - 配置IKE profile引用的IKE提议
 - 配置匹配对端身份的规则
 - 配置IKE profile的使用范围

www.h3c.com

IKE 的主要配置任务包括：

- **配置 IKE 提议：**包括创建 IKE 提议、选择 IKE 提议的加密算法、选择 IKE 提议的验证方法、选择 IKE 提议的验证算法、选择 IKE 阶段一密钥协商所使用的 DH 组、配置 IKE 提议的 ISAKMP SA 生存周期等。
- **配置 IKE keychain：**包括创建 IKE keychain、配置预共享密钥、配置 IKE keychain 的使用范围。
- **配置 IKE profile：**包括创建 IKE profile、配置 IKE 第一阶段的协商模式、配置采用预共享密钥认证时使用的 keychain、配置采用数字签名认证时证书所属的 PKI 域、配置本端身份信息、配置 IKE profile 引用的 IKE 提议、配置匹配对端身份的规则、配置 IKE profile 的使用范围。

13.4.3 理解 IKE 提议



在安全网关之间执行 IKE 协商之初，双方首先协商保护 IKE 协商本身的安全参数，这一协商通过交换 IKE 提议实现。IKE 提议描述了期望在 IKE 协商过程中使用的安全参数，包括验证方法、验证算法、加密算法、DH 组以及用于 IKE 协商的 ISAKMP SA 生存时间等。双方查找出互相匹配的 IKE 提议，用其参数建立 ISAKMP SA 并保护 IKE 交换时的通信。

13.4.4 配置 IKE 提议

配置IKE提议



核心企业 | 数字化解决方案领导者

- 创建IKE提议，并进入IKE提议视图

```
[Router] ike proposal proposal-number
```
- 选择IKE提议所使用的加密算法

```
[Router-ike-proposal-10] encryption-algorithm { 3des-cbc | aes-cbc-128 | aes-cbc-192 | aes-cbc-256 | des-cbc }
```
- 选择IKE提议所使用的验证方法

```
[Router-ike-proposal-10] authentication-method { dsa-signature | pre-share | rsa-signature }
```

www.h3c.com

IKE 提议配置命令如下述。

- 创建 IKE 提议，并进入 IKE 提议视图

```
[Router] ike proposal proposal-number
```

proposal-number 参数指定 IKE 提议序号，取值范围为 1~65535。若发起方使用的 IPsec 安全策略中没有引用 IKE profile，则会将当前系统中所有的 IKE 提议发送给对端，这些 IKE 提议的优先级顺序由 IKE 提议的序号决定，序号越小优先级越高，在进行 IKE 协商的时候，会从序号最小的 IKE 提议进行匹配，如果匹配则直接使用，否则继续查找；若发起方的 IPsec 策略中引用了 IKE profile，则会将该 IKE profile 中引用的 IKE 提议发送给对端。

系统提供一条默认 IKE 提议，此默认 IKE 提议具有最低的优先级。默认 IKE 提议具有默认的参数，包括：

- ◆ 加密算法：DES-CBC
- ◆ 验证算法：SHA-1
- ◆ 验证方法：预共享密钥
- ◆ DH 组标识：Group 1
- ◆ ISAKMP SA 的存活时间：86400 秒
- 选择 IKE 提议所使用的加密算法

```
[Router-ike-proposal-10]encryption-algorithm { 3des-cbc | aes-cbc-128 |
aes-cbc-192 | aes-cbc-256 | des-cbc }
```

默认情况下，IKE 提议使用 CBC 模式的 56 位 DES 加密算法。

- 选择 IKE 提议所使用的验证方法

```
[Router-ike-proposal-10]authentication-method { dsa-signature | pre-share |
rsa-signature }
```

默认情况下，IKE 提议使用预共享密钥的验证方法。

配置IKE提议 (续)



- 选择IKE提议所使用的验证算法

```
[Router-ike-proposal-10] authentication-algorithm { md5 |
sha }
```
- 选择IKE阶段1密钥协商时所使用的DH交换组

```
[Router-ike-proposal-10] dh { group1 | group2 | group5 |
group14 | group24 }
```
- 配置IKE提议的SA生存周期

```
[Router-ike-proposal-10] sa duration seconds
```

www.h3c.com

- 选择 IKE 提议所使用的验证算法

```
[Router-ike-proposal-10] authentication-algorithm { md5 | sha }
```

默认情况下，IKE 提议使用 SHA-1 验证算法。

- 选择 IKE 阶段一密钥协商时所使用的 DH 交换组

```
[Router-ike-proposal-10] dh { group1 | group2 | group5 | group14 | group24}
```

其中 **group1** 指定阶段 1 密钥协商时采用 768 位的 DH 组；**group2** 指定采用 1024 位的 DH 组；**group5** 指定采用 1536 位的 DH 组；**group14** 指定采用 2048 位的 DH 组；**group24** 指定采用含 256-bit 的 sub-group 的 2048-bit DH 组。默认情况下，IKE 阶段 1 密钥协商时所使用的 DH 密钥交换参数为 **group1**。

- 配置 IKE 提议的 SA 生存周期

```
[Router-ike-proposal-10] sa duration seconds
```

在设定的存活时间超时前，双方会提前协商另一个安全联盟来替换旧的安全联盟。在新的安全联盟还没有协商完之前，依然使用旧的安全联盟；在新的安全联盟建立后，将立即使用新的安全联盟，而旧的安全联盟在存活时间超时后，被自动清除。因为 IKE 协商需要进行 DH 计算，在低端设备上需要经过较长的时间，为使 ISAKMP SA 的更新不影响安全通信，建议设置存活时间大于 10 分钟。默认情况下，IKE 提议的 ISAKMP SA 存活时间为 86400 秒。如果协商双方配置了不同的 IKE SA 存活时间，则时间较短的存活时间生效。

13.4.5 配置 IKE Keychain

配置IKE Keychain



紫光集团 H3C
核心企业 数字化解决方案领导者

- 创建IKE keychain，并进入IKE keychain 视图

```
[Router] ike keychain keychain-name
```

- 配置预共享密钥

```
[Router- ike-keychain-keychain1] pre-shared-key { address address [ mask | mask-length ] | hostname host-name } key { cipher cipher-key | simple simple-key }
```

- 配置IKE keychain的使用范围

```
[Router- ike-keychain-keychain1] match local address { interface-type interface-number | address [ vpn-instance vpn-name ] }
```

www.h3c.com

- 创建 IKE keychain，并进入 IKE keychain 视图

```
[Router] ike keychain keychain-name
```

缺省情况下，不存在 IKE keychain，在 IKE 需要通过预共享密钥方式进行认证时，需要创建并指定 IKE keychain

- 配置预共享密钥

```
[Router-ike-keychain-keychain1] pre-shared-key { address address [ mask | mask-length ] | hostname host-name } key { cipher cipher-key | simple simple-key }
```

缺省情况下，未配置预共享密钥，配置预共享密钥的同时，还通过参数 **address** 和 **hostname** 指定了使用该预共享密钥的匹配条件，即与哪些 IP 地址或哪些主机名的对端协商时，才可以使用该预共享密钥。IKE 协商双方必须配置了相同的预共享密钥，身份认证才会成功。

- 配置 IKE keychain 的使用范围

```
[Router-ike-keychain-keychain1] match local address { interface-type
interface-number | address [ vpn-instance vpn-name ] }
```

缺省情况下，未限制 IKE keychain 的使用范围，此命令用于限制 IKE keychain 只能用于指定地址或指定接口的地址上的协商，这里的地址指的是 IPsec 安全策略/IPsec 安全策略模板下配置的本端地址。一个 IKE profile 中最多可以指定六个 IKE keychain，默认情况下，先配置的 IKE keychain 优先级高，若希望本端在匹配某些 IKE keychain 的时候，不按照配置的优先级来查找，则可以通过本命令来指定这类 IKE keychain 的使用范围。例如，IKE keychain A 中的预共享密钥的匹配地址范围大（2.2.0.0/16），IKE keychain B 中的预共享密钥的匹配地址范围小（2.2.2.0/24），IKE keychain A 先于 IKE keychain B 配置。若希望本端 IP 地址为 2.2.2.2 的接口上使用 IKE keychain B，但是按照配置顺序匹配，依据本端 IP 地址 2.2.2.2 总会匹配到预共享密钥地址范围大的 IKE keychain A，而找不到期望的 IKE keychain B。这种情况下，可以通过配置 IKE keychainB 在指定地址 2.2.2.2 的接口上使用，使其找到正确的预共享密钥。

13.4.6 配置 IKE 本端身份信息

配置IKE本端身份信息



紫光集团 H3C
核心企业 数字化转型方案领导者

- 配置本端身份信息

```
[Router] ike identity { address address | dn | fqdn [ fqdn-name ] | user-fqdn [ user-fqdn-name ] }
```

- 配置本端的身份信息从证书的主题字段中获取

```
[Router] ike signature-identity from-certificate
```

www.h3c.com

- 配置本端身份信息

```
[Router] ike identity { address address | dn | fqdn [ fqdn-name ] | user-fqdn [ user-fqdn-name ] }
```

本命令用于全局配置 IKE 对等体的本端身份，适用于所有 IKE SA 的协商，而 IKE profile 下的 local-identity 为局部配置身份，仅适用于使用本 IKE profile 的 IKE SA 的协商。缺省情况下，使用 IP 地址标识本端的身份，该 IP 地址为 IPsec 安全策略或 IPsec 安全策略模板应用的接口地址。

- 配置本端的身份信息从证书的主题字段中获取

[Router-ike-keychain-keychain1] ike signature-identity from-certificate

采用数字签名认证时，如果希望总是从证书中的主题字段取得本端身份，则可以通过 **ike signature-identity from-certificate** 命令实现。如果没有配置 **ike signature-identity from-certificate**，并且 IPsec 安全策略或 IPsec 安全策略模板下指定的 IKE profile 中配置了本端身份（由 **local-identity** 命令指定），则使用 IKE profile 中配置的本端身份；若 IPsec 安全策略或 IPsec 安全策略模板下未指定 IKE profile 或 IKE profile 下没有配置本端身份，则使用全局配置的本端身份（由 **ike identity** 命令指定）。

13.4.7 配置 IKE Profile

配置IKE profile



紫光集团 H3C
核心企业 数字化解决方案领导者

- 创建一个IKE profile，并进入IKE profile 视图

[Router] ike profile profile-name

- 配置IKE第一阶段的协商模式

[Router-ike-profile-profile1] exchange-mode { aggressive | main }

- 配置采用预共享密钥验证时所使用的 keychain

[Router-ike-profile-profile1] keychain keychain-name

www.h3c.com

IKE profile 的配置命令如下述。

- 创建一个 IKE profile，并进入 IKE profile 视图

[Router] ike profile profile-name

- 配置 IKE 第一阶段的协商模式

[Router-ike-profile-profile1] exchange-mode { aggressive | main }

其中 **main** 指定使用主模式，**aggressive** 指定使用野蛮模式。默认情况下，IKE 阶段的协商模式使用主模式。

- 配置采用预共享密钥验证时所使用的 keychain

[Router-ike-profile-profile1] **keychain** *keychain-name*

一个 IKE profile 中最多可以指定六个 IKE keychain，先配置的 IKE keychain 优先级高。

配置IKE profile (续)



- 配置采用数字签名验证时，证书所属的 PKI域

[Router-ike-profile-profile1] **certificate domain** *domain-name*

- 配置本端身份信息

[Router-ike-profile-profile1] **local-identity** { **address** *address* | **dn** | **fqdn** [*fqdn-name*] | **user-fqdn** [*user-fqdn-name*] }

- 配置IKE profile引用的IKE提议

[Router-ike-profile-profile1] **proposal** *proposal-number*

www.h3c.com

- 配置采用数字签名验证时，证书所属的 PKI 域

[Router-ike-profile-profile1] **certificate domain** *domain-name*

如果在 IKE profile 中指定了 PKI 域，则使用指定的 PKI 域发送本端证书请求、验证对端证书请求、发送本端证书、验证对端证书、进行数字签名。如果 IKE profile 中没有指定 PKI 域，则使用设备上配置的 PKI 域进行以上证书相关的操作；一个 IKE profile 中最多可以引用六个 PKI 域。PKI 的相关配置请参考其它章节。

- 配置本端身份信息

[Router-ike-profile-profile1]**local-identity** { **address** *address* | **dn** | **fqdn** [*fqdn-name*] | **user-fqdn** [*user-fqdn-name*] }

缺省情况下，未配置本端身份信息。IKE profile 下的本端身份信息优先级高于系统视图下通过 **ike identity** 命令配置的本端身份信息，如果 IKE profile 下未配置本端身份信息，则使用系统视图下配置的本端身份信息，若两者都没有配置，则使用 IP 地址标识本端的身份，该 IP 地址为 IPsec 安全策略或 IPsec 安全策略模板应用的接口的 IP 地址。一个 IKE profile 中只能配置一条本端身份信息，响应方使用发起方的身份信息查找本地的 IKE profile，通过与 **match remote** 命令中指定的发起方身份信息进行匹配，可查找到本端要采用的 IKE profile。

- 配置 IKE profile 引用的 IKE 提议

[Router-ike-profile-profile1]**proposal** *proposal-number*

如果使用的 IPsec 安全策略下指定了 IKE profile，则使用 IKE profile 中引用的 IKE 提议进行协商，如果 IKE profile 未引用任何 IKE 提议，使用系统视图下已配置的 IKE 提议进行 IKE 协商。

配置IKE profile (续)



- 配置匹配对端身份的规则


```
[Router-ike-profile-profile1]match remote { certificate policy-name | identity { address address [ mask | mask-length ] | range low-address high-address [ vpn-instance vpn-name ] | fqdn fqdn-name | user-fqdn user-fqdn-name } }
```
- 配置IKE profile的使用范围


```
[Router-ike-profile-profile1] match local address { interface-type interface-number | address [ vpn-instance vpn-name ] }
```
- 配置IKE profile的优先级


```
[Router-ike-profile-profile1] priority number
```

www.h3c.com

- 配置匹配对端身份的规则

```
[Router-ike-profile-profile1]match remote { certificate policy-name | identity { address address [ mask | mask-length ] | range low-address high-address [ vpn-instance vpn-name ] | fqdn fqdn-name | user-fqdn user-fqdn-name } }
```

响应方根据发起方的身份信息通过本配置查找 IKE profile 并验证对端身份，发起方根据响应方的身份信息通过本配置验证对端身份。协商双方都必须配置至少一个 match remote 规则，当对端的身份与 IKE profile 中配置的 match remote 规则匹配时，则使用此 IKE profile 中的信息与对端完成认证。

- 配置 IKE profile 的使用范围

```
[Router-ike-profile-profile1]match local address { interface-type interface-number | address [ vpn-instance vpn-name ] }
```

先配置的 IKE profile 优先级高，若希望本端在匹配某些 IKE profile 的时候，不按照配置的优先级来查找，则可以通过本命令来指定这类 IKE profile 的使用范围。例如，IKE profile A 中的 match remote 地址范围大（match remote identity address range 2.2.2.1 2.2.2.100），IKE profile B 中的 match remote 地址范围小（match remote identity address range 2.2.2.1 2.2.2.10），IKE profile A 先于 IKE profile B 配置。若希望本端 IP 地址为 2.2.2.2 的接口上使用 IKE profile B，但是按照配置顺序匹配，依据本端 IP 地址 2.2.2.2 总会匹配到预共享密钥地址

范围大的 IKE profile A，而找不到期望的 IKE profile B。这种情况下，可以通过配置 IKE profile B 在指定地址 2.2.2.2 的接口上使用，使其找到正确的 IKE profile。

- 配置 IKE profile 的优先级

[Router-ike-profile-profile1] **priority number**

配置了 match local address 的 IKE profile，优先级高于所有未配置 match local address 的 IKE profile。即 IKE profile 的匹配优先级首先决定于其中是否配置了 match local address，其次决定于它的优先级，该数值越小，优先级越高，缺省情况下，IKE profile 的优先级为 100。

13.4.8 IKE 的显示信息与维护

IKE信息显示和维护



- 显示IKE提议配置的参数

```
[Router] display ike proposal
```

- 显示当前IKE SA的信息

```
[Router] display ike sa [ verbose [ connection-id connection-id | remote-address remote-address [ vpn-instance vpn-name ] ] ]
```

- 清除IKE SA

```
<Router> reset ike sa [ connection-id connection-id ]
```

- IKE调试命令

```
<Router> debugging ike { all | error | event | packet }
```

www.h3c.com

要显示每个 IKE 提议配置的参数，使用命令：

[Router] **display ike proposal**

要显示当前 IKE SA 的信息，使用命令：

[Router] **display ike sa [verbose [connection-id connection-id | remote-address remote-address [vpn-instance vpn-name]]]**

要清除 IKE SA 的信息，使用命令：

<Router> **reset ike sa [connection-id connection-id]**

要打开 IKE 协议调试功能，使用命令：

<Router> **debugging ike { all | error | event | packet }**

display ike sa 命令显示示例

```
<H3C>dis ike sa
  Connection-ID  Remote      Flag      DOI
-----
      1            2.2.2.1      RD        IPsec
Flags:
RD--READY RL--REPLACED FD-FADING
```

```
<H3C>dis ike sa verbose
-----
Connection ID: 1
Outside VPN:
Inside VPN:
Profile: profile1
Transmitting entity: Initiator
-----
Local IP: 1.1.1.1
Local ID type: IPV4_ADDR
Local ID: 1.1.1.1

Remote IP: 2.2.2.1
Remote ID type: IPV4_ADDR
Remote ID: 2.2.2.1

Authentication-method: PRE-SHARED-KEY
Authentication-algorithm: MD5
Encryption-algorithm: 3DES-CBC

Life duration(sec): 86400
Remaining key duration(sec): 86385
Exchange-mode: Aggressive
Diffie-Hellman group: Group 1
NAT traversal: Not detected
```

display ike sa 命令的两个典型显示信息如图。

由第一个例子可见，设备和对端 2.2.2.1 的 ISAKMP SA 状态为 RD（READY），表示已经建立成功。

第二个例子显示了一个 ISAKMP SA 的详细安全参数。

13.5 IPsec隧道配置示例

13.5.1 IPsec+IKE 预共享密钥方法配置示例

紫光集团 H3C
核心企业 数字化解决方案领导者

IPsec+IKE预共享密钥配置示例

```

[RTA]interface GigabitEthernet 0/0
[RTA-GigabitEthernet0/0]ip address 10.1.1.1 255.255.255.0
[RTA-GigabitEthernet0/0]quit
[RTA]interface Serial 1/0
[RTA-Serial1/0]ip address 202.38.160.1 255.255.255.0
[RTA-Serial1/0]quit
[RTA] ip route-static 10.1.2.0 255.255.255.0 202.38.160.2
[RTA]ike keychain keychain1
[RTA-ike-keychain-keychain1]pre-shared-key address 202.38.160.2 key simple h3c
[RTA-ike-keychain-keychain1]quit
[RTA]ike proposal 1
[RTA-ike-proposal-1]quit
[RTA]ike profile profile1
[RTA-ike-profile-profile1]local-identity address 202.38.160.1
[RTA-ike-profile-profile1]proposal 1
[RTA-ike-profile-profile1]keychain keychain1
[RTA-ike-profile-profile1]match remote identity address 202.160.38.2
[RTA-ike-profile-profile1]quit
  
```

www.h3c.com

紫光集团 H3C
核心企业 数字化解决方案领导者

IPsec+IKE预共享密钥配置示例 (续)

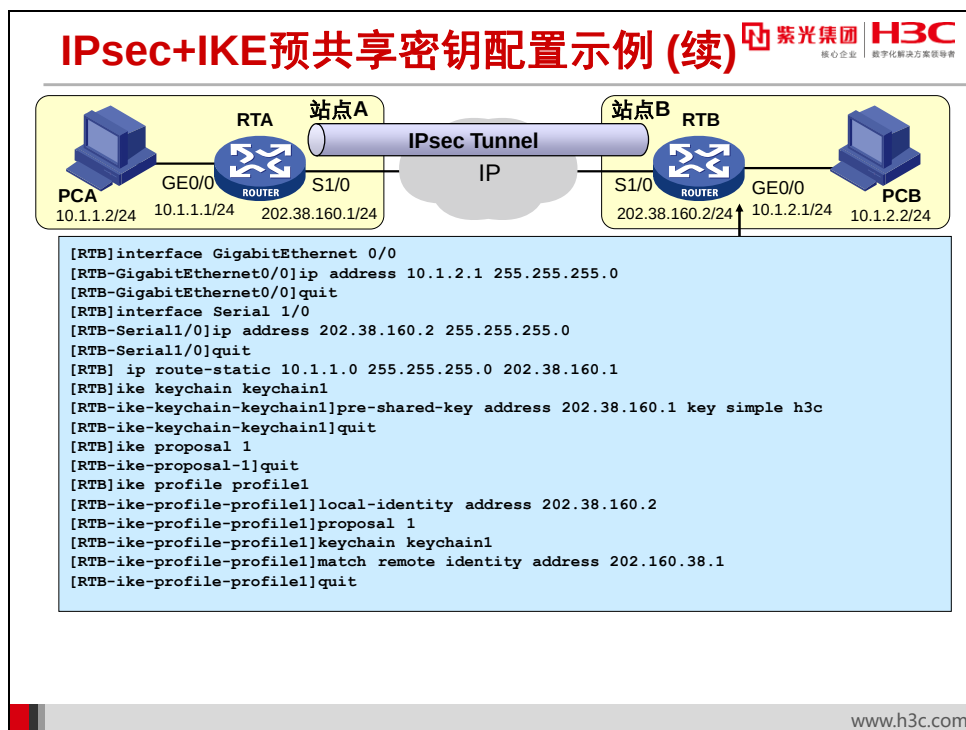
```

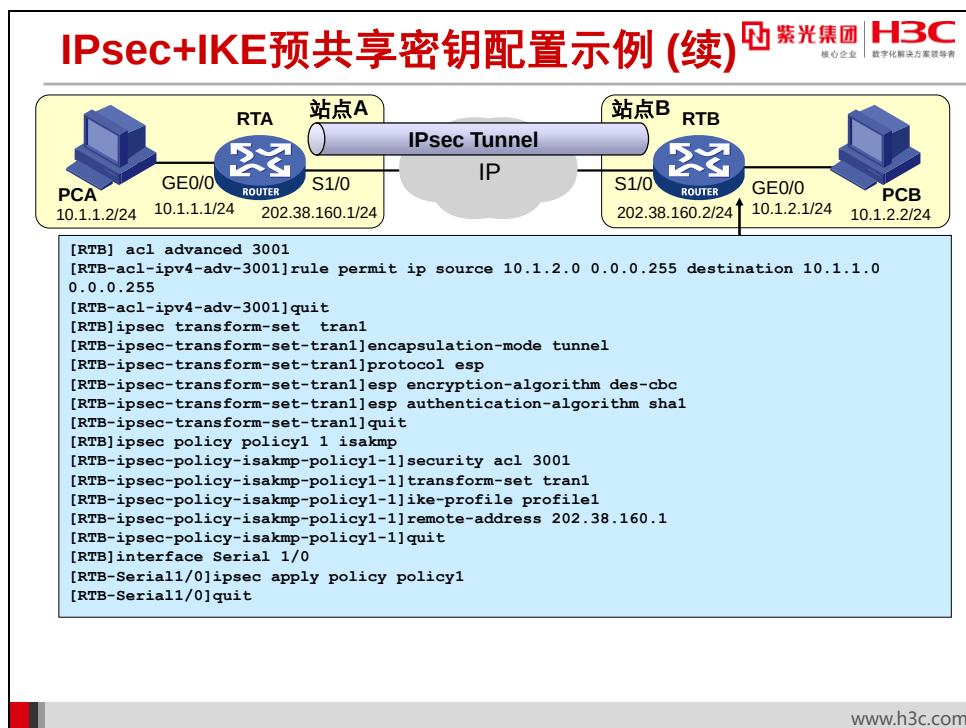
[RTA] acl advanced 3001
[RTA-acl-ipv4-adv-3001]rule permit ip source 10.1.1.0 0.0.0.255 destination 10.1.2.0 0.0.0.255
[RTA-acl-ipv4-adv-3001]quit
[RTA]ipsec transform-set tran1
[RTA-ipsec-transform-set-tran1]encapsulation-mode tunnel
[RTA-ipsec-transform-set-tran1]protocol esp
[RTA-ipsec-transform-set-tran1]esp encryption-algorithm des-cbc
[RTA-ipsec-transform-set-tran1]esp authentication-algorithm sha1
[RTA-ipsec-transform-set-tran1]quit
[RTA]ipsec policy policy1 1 isakmp
[RTA-ipsec-policy-isakmp-policy1-1]security acl 3001
[RTA-ipsec-policy-isakmp-policy1-1]transform-set tran1
[RTA-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[RTA-ipsec-policy-isakmp-policy1-1]remote-address 202.38.160.2
[RTA-ipsec-policy-isakmp-policy1-1]quit
[RTA]interface Serial 1/0
[RTA-Serial1/0]ipsec apply policy policy1
[RTA-Serial1/0]quit
  
```

www.h3c.com

如图所示，RTA 和 RTB 之间建立 IPsec 隧道，为站点 A 局域网 10.1.1.0/24 和站点 B 局域网 10.1.2.0/24 之间的通信提供安全服务。本例采用预共享密钥方式，通过 IKE 协商建立 IPsec SA。

RTA 的配置如上图所示。





RTB 的配置如上图所示。

以上配置完成后，RTA 和 RTB 之间如果有子网 10.1.1.0/24 与子网 10.1.2.0/24 之间的报文通过，将触发 IKE 协商，建立 IPsec SA。IKE 协商成功并创建了 SA 后，两子网之间的数据流将被加密传输。

13.5.2 IPsec+IKE RSA 签名方法配置示例

紫光集团 H3C
核心企业 数字化解决方案领导者

IPsec+IKE RSA签名配置示例

```

[RTA] pki entity ipsecvpn
[RTA-pki-entity-ipsecvpn] common-name rta
[RTA-pki-entity-ipsecvpn] quit
[RTA] pki domain domain1
[RTA-pki-domain-domain1] ca identifier CA
[RTA-pki-domain-domain1] certificate request url http://.....
[RTA-pki-domain-domain1] certificate request from ra
[RTA-pki-domain-domain1] certificate request entity ipsecvpn
[RTA-pki-domain-domain1] undo crl check enable
[RTA-pki-domain-domain1] public-key rsa general name abc length 1024
[RTA-pki-domain-domain1] quit
[RTA] public-key local create rsa name abc
[RTA] pki retrieve-certificate domain domain1 ca
[RTA] pki request-certificate domain domain1
[RTA] ike proposal 1
[RTA-ike-proposal-1] authentication-method rsa-signature
[RTA-ike-proposal-1] encryption-algorithm 3des-cbc
[RTA-ike-proposal-1] dh group2
[RTA-ike-proposal-1] quit
[RTA] ike profile profile1
[RTA-ike-profile-profile1] local-identity dn
[RTA-ike-profile-profile1] certificate domain domain1
  
```

www.h3c.com

紫光集团 H3C
核心企业 数字化解决方案领导者

IPsec+IKE RSA签名配置示例 (续)

```

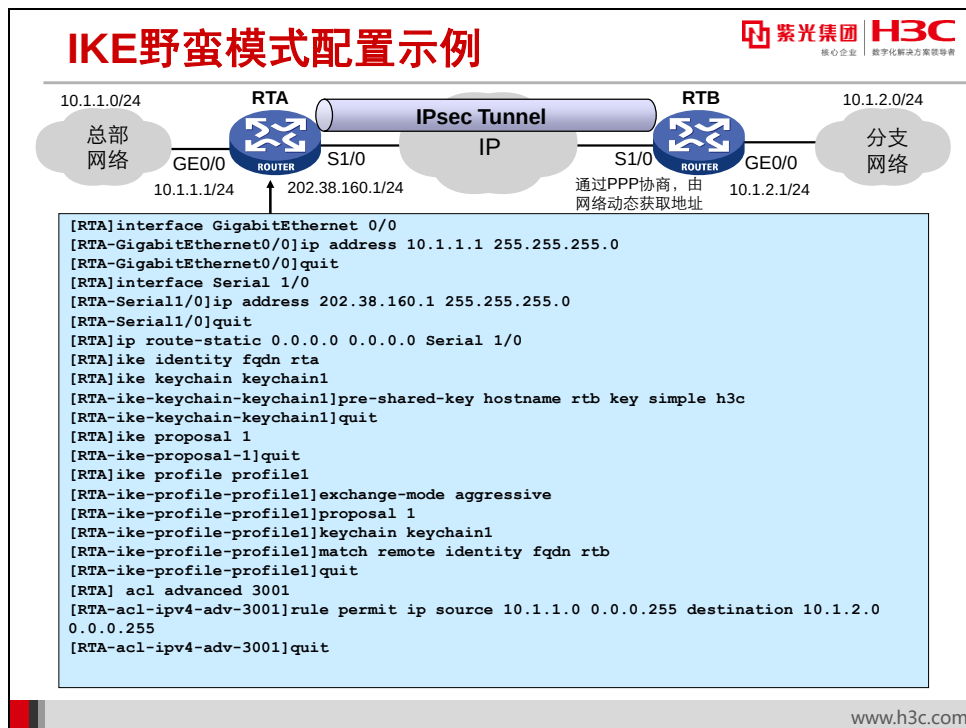
[RTA-ike-profile-profile1] proposal 1
[RTA-ike-profile-profile1] match remote certificate rta
[RTA-ike-profile-profile1] quit
[RTA] ike signature-identity from-certificate
[RTA] acl advanced 3001
[RTA-acl-ipv4-adv-3001] rule permit ip source 10.1.1.0 0.0.0.255 destination 10.1.2.0 0.0.0.255
[RTA-acl-ipv4-adv-3001] quit
[RTA] ip route-static 10.1.2.0 255.255.255.0 202.38.160.2
[RTA] ipsec transform-set tran1
[RTA-ipsec-transform-set-tran1] esp authentication-algorithm sha1
[RTA-ipsec-transform-set-tran1] esp encryption-algorithm 3des
[RTA-ipsec-transform-set-tran1] quit
[RTA] ipsec policy policy1 1 isakmp
[RTA-ipsec-policy-isakmp-policy1-1] security acl 3001
[RTA-ipsec-policy-isakmp-policy1-1] transform-set tran1
[RTA-ipsec-policy-isakmp-policy1-1] ike-profile profile1
[RTA-ipsec-policy-isakmp-policy1-1] remote-address 202.38.160.2
[RTA-ipsec-policy-isakmp-policy1-1] quit
[RTA] interface Serial 1/0
[RTA-Serial1/0] ipsec apply policy policy1
[RTA-Serial1/0] quit
  
```

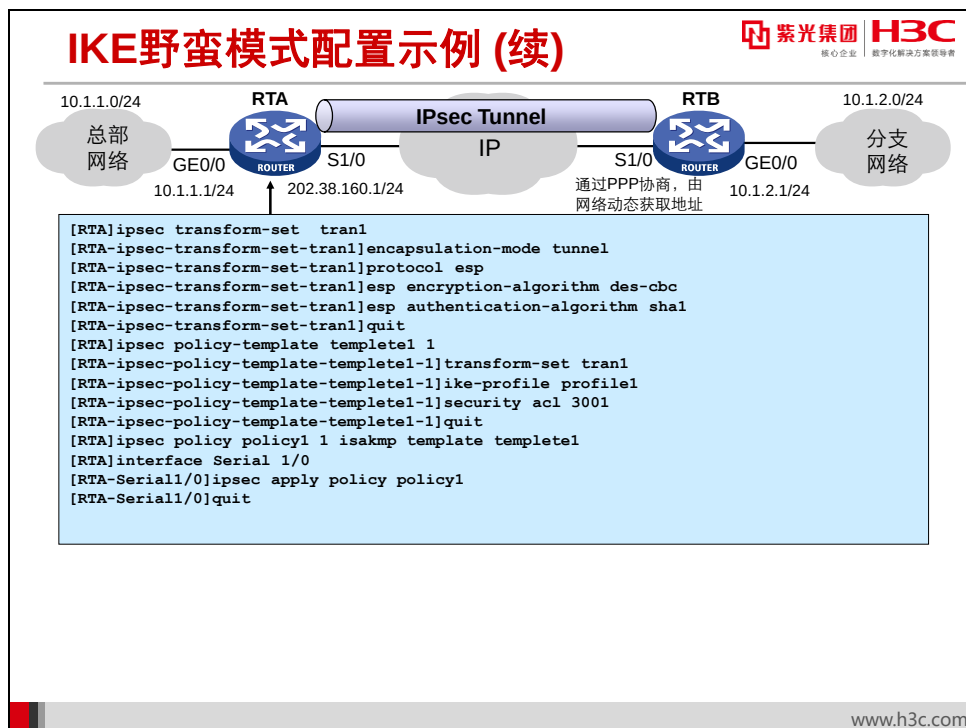
www.h3c.com

除了要求采用 PKI 证书体系的 RSA 证书签名方法进行 IKE 协商验证之外，本例的配置需求与上例相同。RTA 的关键配置如图所示；RTB 的配置类似，此处略去。

与上例相比，除了在 IKE 提议中要求使用 RSA 签名方法以及在 IKE 对等体中关联了认证域之外，IPsec 的配置并没有改变。当然配置 IPsec 之前还需要完成 PKI 相关配置，如配置 PKI 域、配置通过 RA 注册申请证书、配置 CRL 发布点位置、用 RSA 算法生成本地的密钥对、申请证书等。关于 PKI 的配置并非本章内容，读者可参考相关章节或手册。

13.5.3 IPsec+IKE 野蛮模式配置示例



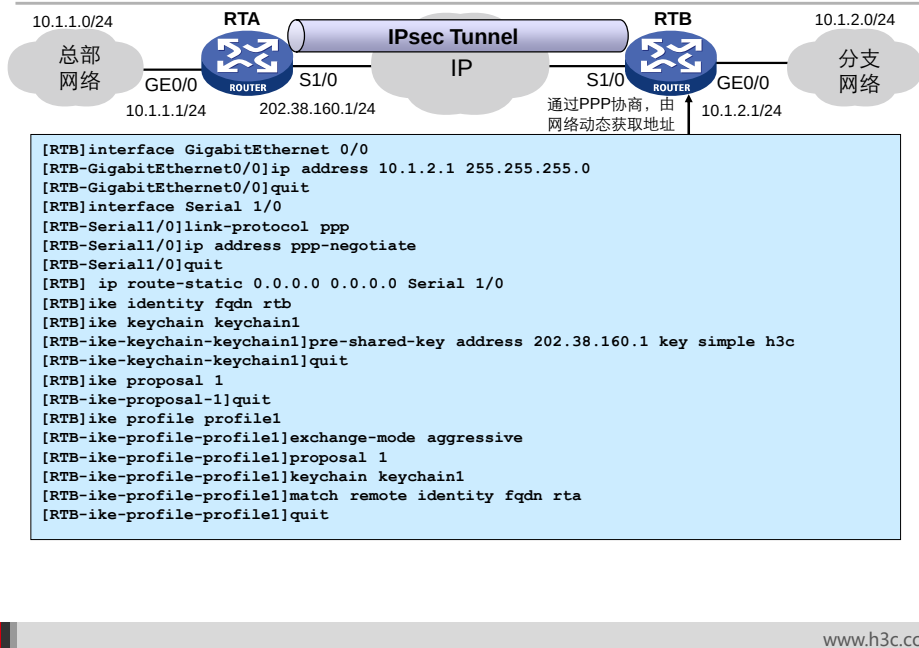


在本例中，RTB 需要与 RTA 建立 IPsec 隧道，要求用 IKE 协商安全参数。但 RTB 的接口 S1/0 无固定 IP 地址，因此不能使用预共享密钥方式，故而采用野蛮模式。

RTA 的配置如上图所示。可见作为总部路由器的 RTA 具有固定的对外网络连接，相应的接口 S1/0 也具有固定的 IP 地址。为了使用野蛮模式，RTA 的相应 IKE 对等体必须配置命令 `exchange-mode aggressive` 以启动野蛮模式。同时必须配置相应的本端和对端安全网关名字。

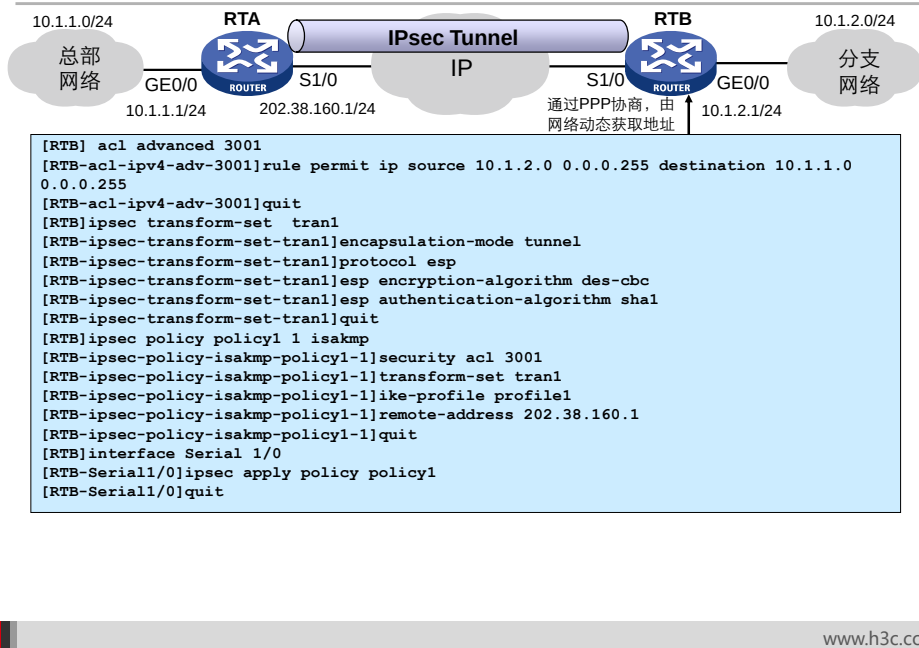
IKE野蛮模式配置示例 (续)

紫光集团 H3C
核心企业 数字化转型方案领导者



IKE野蛮模式配置示例 (续)

紫光集团 H3C
核心企业 数字化转型方案领导者



RTB 的配置如图所示。可见 RTB 的串口 S1/0 从网络获取自动 IP 地址。RTB 的相应 IKE 对等体中也必须配置野蛮模式，同时必须配置相应的本端和对端安全网关名字。此外由于 RTB 是发起方，所以 RTB 上还需指定对端安全网关的 IP 地址。

13.6 IPsec与传统VPN技术结合

13.6.1 GRE over IPsec

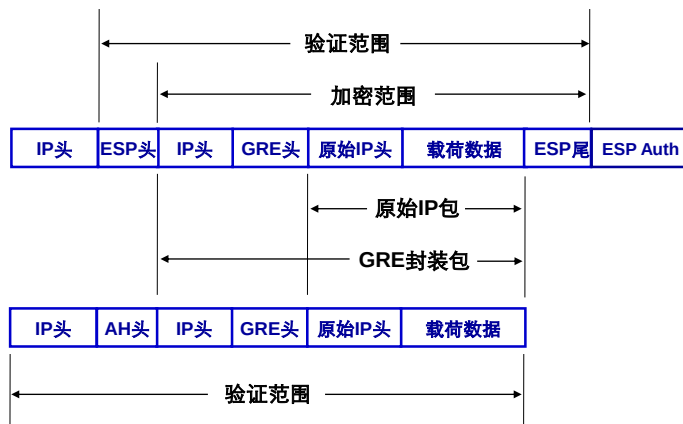
GRE over IPsec的优势			
特性	GRE是否支持	IPsec是否支持	GRE over IPsec是否支持
支持多协议	Y	N	Y
虚拟接口	Y	N	Y
支持组播	Y	N	Y
对路由协议的支持	Y	N	Y
对丰富的IP协议族的支持	Y	支持得不好	Y
机密性	N	Y	Y
完整性	N	Y	Y
数据源验证	N	Y	Y

GRE 是一种通用封装协议，因此其可以支持多种网络层协议。GRE 隧道的实现采用了虚拟的 Tunnel 接口，因而其可以支持组播和广播，并可以支持丰富的 IP 协议族以及路由协议。但是 GRE VPN 不能确保数据的机密性、完整性，也不能验证数据的来源。

而 IPsec 是针对 IP 数据流而设计的，其协议机制决定了其难以支持组播，因而也不便于支持路由协议，并且对 IP 协议族中纷繁的各种协议支持得不好。

然而，GRE 隧道中传送的一切包终究被封装为公网数据包，在两个隧道端点设备之间点到点地传送。如果用 IPsec 对这个点到点的数据流进行保护，就可以同时具有 GRE VPN 和 IPsec VPN 的优良特性，支持丰富的应用场合。

GRE over IPsec封装


 紫光集团 H3C
核心企业 数字化转型领航者


- 原始IP包被封装在GRE隧道封装包中
- GRE隧道封装包被封装在IPsec隧道封装包中

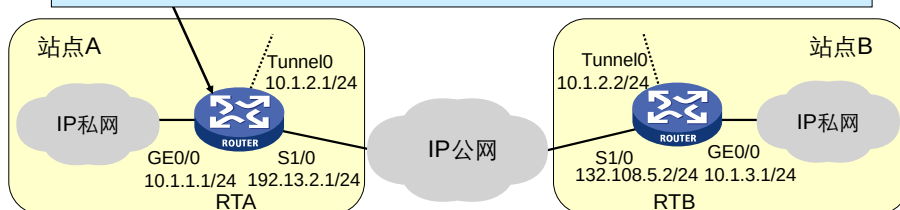
www.h3c.com

使用 GRE over IPsec 时，GRE 隧道封装与 IPsec 隧道封装同时独立工作。原始 IP 包被封装在 GRE 隧道封装包中，GRE 隧道封装包被封装在 IPsec 隧道封装包中，随后在公网上传送。

GRE over IPsec配置示例


 紫光集团 H3C
核心企业 数字化转型领航者

```
[RTA] interface tunnel 0 mode gre
[RTA-Tunnel0] ip address 10.1.2.1 255.255.255.0
[RTA-Tunnel0] source 192.13.2.1
[RTA-Tunnel0] destination 132.108.5.2
[RTA] acl advanced 3001
[RTA-acl-ipv4-adv-3001] rule permit ip source 192.13.2.1 0.0.0.0 destination
132.108.5.2 0.0.0.0
[RTA]ike keychain keychain1
[RTA-ike-keychain-keychain1]pre-shared-key address 132.108.5.2 key simple h3c
[RTA]ike proposal 1
[RTA]ike profile profile1
[RTA-ike-profile-profile1].....
[RTA-ipsec transform-set tran1].....
[RTA-ipsec policy policy1 1 isakmp
[RTA-ipsec-policy-isakmp-policy1-1].....
[RTA]interface Serial 1/0
[RTA-Serial1/0]ipsec apply policy policy1
[RTA]ip route-static 10.1.3.0 255.255.255.0 Tunnel 0
```



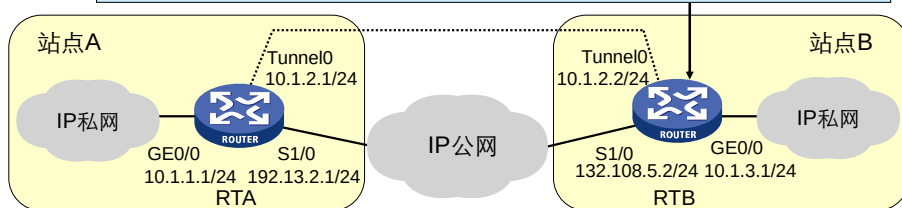
www.h3c.com

在本例中 RTA 和 RTB 同时作为 GRE 隧道的端点和 IPsec 隧道的端点，并要求实现 GRE over IPsec。RTA 的主要配置如下：

```
[RTA]interface Serial 1/0
[RTA-Serial1/0]ip address 192.13.2.1 255.255.255.0
[RTA-Serial1/0]quit
[RTA]interface GigabitEthernet 0/0
[RTA-GigabitEthernet0/0]ip address 10.1.1.1 255.255.255.0
[RTA-GigabitEthernet0/0]quit
[RTA] interface tunnel 0 mode gre
[RTA-Tunnel0]ip address 10.1.2.1 255.255.255.0
[RTA-Tunnel0]source 192.13.2.1
[RTA-Tunnel0]destination 132.108.5.2
[RTA-Tunnel0]keepalive
[RTA-Tunnel0]quit
[RTA] acl advanced 3001
[RTA-acl-ipv4-adv-3001]rule permit ip source 192.13.2.1 0.0.0.0 destination
132.108.5.2 0.0.0.0
[RTA-acl-ipv4-adv-3001]quit
[RTA]ike keychain keychain1
[RTA-ike-keychain-keychain1]pre-shared-key address 132.108.5.2 key simple h3c
[RTA-ike-keychain-keychain1]quit
[RTA]ike proposal 1
[RTA-ike-proposal-1]quit
[RTA]ike profile profile1
[RTA-ike-profile-profile1]local-identity address 192.13.2.1
[RTA-ike-profile-profile1]proposal 1
[RTA-ike-profile-profile1]keychain keychain1
[RTA-ike-profile-profile1]match remote identity address 132.108.5.2
[RTA-ike-profile-profile1]quit
[RTA]ipsec transform-set tran1
[RTA-ipsec-transform-set-tran1]encapsulation-mode tunnel
[RTA-ipsec-transform-set-tran1]protocol esp
[RTA-ipsec-transform-set-tran1]esp encryption-algorithm des-cbc
[RTA-ipsec-transform-set-tran1]esp authentication-algorithm sha1
[RTA-ipsec-transform-set-tran1]quit
[RTA]ipsec policy policy1 1 isakmp
[RTA-ipsec-policy-isakmp-policy1-1]security acl 3001
[RTA-ipsec-policy-isakmp-policy1-1]transform-set tran1
[RTA-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[RTA-ipsec-policy-isakmp-policy1-1]remote-address 132.108.5.2
[RTA-ipsec-policy-isakmp-policy1-1]quit
[RTA]interface Serial 1/0
[RTA-Serial1/0]ipsec apply policy policy1
[RTA-Serial1/0]quit
[RTA]ip route-static 10.1.3.0 255.255.255.0 Tunnel 0
[RTA]ip route-static 0.0.0.0 0.0.0.0 Serial 1/0
```

GRE over IPsec配置示例（续）

```
[RTB] interface tunnel 0 mode gre
[RTB-Tunnel0] ip address 10.1.2.2 255.255.255.0
[RTB-Tunnel0] source 132.108.5.2
[RTB-Tunnel0] destination 192.13.2.1
[RTB] acl advanced 3001
[RTB-acl-ipv4-adv-3001] rule permit ip source 132.108.5.2 0.0.0.0 destination
192.13.2.1 0.0.0.0
[RTB]ike keychain keychain1
[RTB-ike-keychain-keychain1]pre-shared-key address 192.13.2.1 key simple h3c
[RTB]ike proposal 1
[RTB]ike profile profile1
[RTB-ike-profile-profile1].....
[RTB]ipsec transform-set tran1
[RTB-ipsec-transform-set-tran1].....
[RTB]ipsec policy policy1 1 isakmp
[RTB-ipsec-policy-isakmp-policy1-1].....
[RTB]interface Serial 1/0
[RTB-Serial1/0]ipsec apply policy policy1
[RTB]ip route-static 10.1.1.0 255.255.255.0 Tunnel 0
```



www.h3c.com

RTB 的主要配置如下：

```
[RTB]interface Serial 1/0
[RTB-Serial1/0]ip address 132.108.5.2 255.255.255.0
[RTB-Serial1/0]quit
[RTB]interface GigabitEthernet 0/0
[RTB-GigabitEthernet0/0]ip address 10.1.3.1 255.255.255.0
[RTB-GigabitEthernet0/0]quit
[RTB] interface tunnel 0 mode gre
[RTB-Tunnel0]ip address 10.1.2.2 255.255.255.0
[RTB-Tunnel0]source 132.108.5.2
[RTB-Tunnel0]destination 192.13.2.1
[RTB-Tunnel0]keepalive
[RTB-Tunnel0]quit
[RTB] acl advanced 3001
[RTB-acl-ipv4-adv-3001] rule permit ip source 132.108.5.2 0.0.0.0 destination
192.13.2.1 0.0.0.0
[RTB-acl-ipv4-adv-3001]quit
[RTB]ike keychain keychain1
[RTB-ike-keychain-keychain1]pre-shared-key address 192.13.2.1 key simple h3c
[RTB-ike-keychain-keychain1]quit
[RTB]ike proposal 1
[RTB-ike-proposal-1]quit
[RTB]ike profile profile1
[RTB-ike-profile-profile1]local-identity address 132.108.5.2
[RTB-ike-profile-profile1]proposal 1
[RTB-ike-profile-profile1]keychain keychain1
[RTB-ike-profile-profile1]match remote identity address 192.13.2.1
[RTB-ike-profile-profile1]quit
[RTB]ipsec transform-set tran1
[RTB-ipsec-transform-set-tran1]encapsulation-mode tunnel
[RTB-ipsec-transform-set-tran1]protocol esp
[RTB-ipsec-transform-set-tran1]esp encryption-algorithm des-cbc
[RTB-ipsec-transform-set-tran1]esp authentication-algorithm sha1
[RTB-ipsec-transform-set-tran1]quit
```

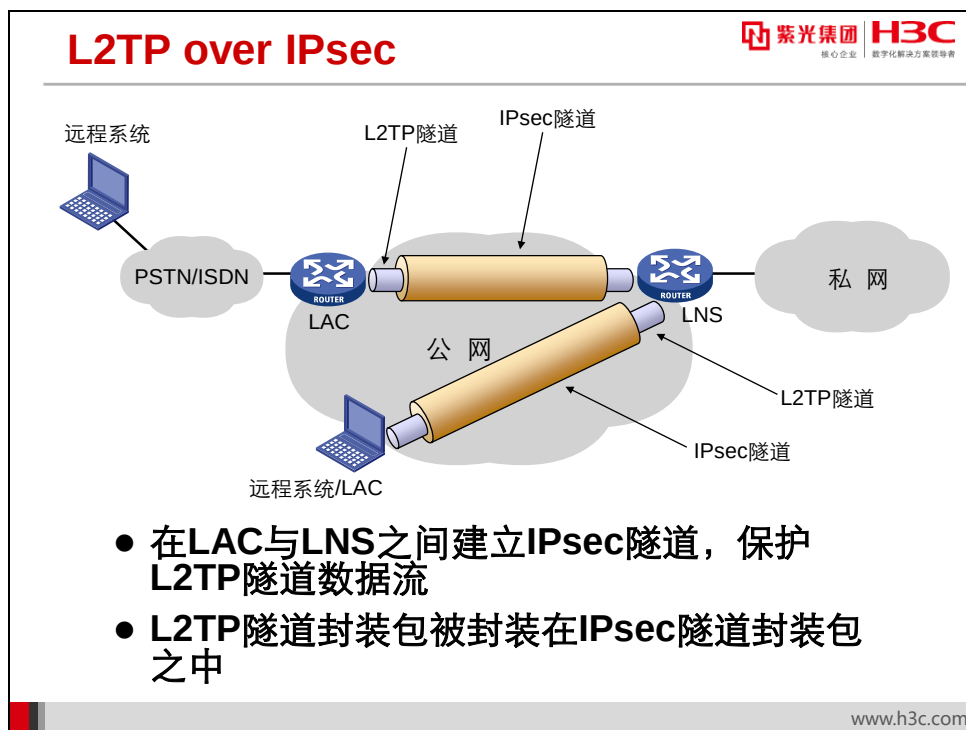
```

[RTB]ipsec policy policy1 1 isakmp
[RTB-ipsec-policy-isakmp-policy1-1]security acl 3001
[RTB-ipsec-policy-isakmp-policy1-1]transform-set tran1
[RTB-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[RTB-ipsec-policy-isakmp-policy1-1]remote-address 192.13.2.1
[RTB-ipsec-policy-isakmp-policy1-1]quit
[RTB]interface Serial 1/0
[RTB-Serial1/0]ipsec apply policy policy1
[RTB-Serial1/0]quit
[RTB]ip route-static 10.1.1.0 255.255.255.0 Tunnel 0
[RTB]ip route-static 0.0.0.0 0.0.0.0 Serial 1/0

```

可见其配置与单独的 GRE 隧道或单独的 IPsec 隧道相比并无特殊之处，只要在配置安全 ACL 时匹配隧道所使用的物理接口的公网地址 192.13.2.1 与 132.108.5.2 之间的数据流，将其纳入 IPsec 保护即可。

13.6.2 L2TP over IPsec



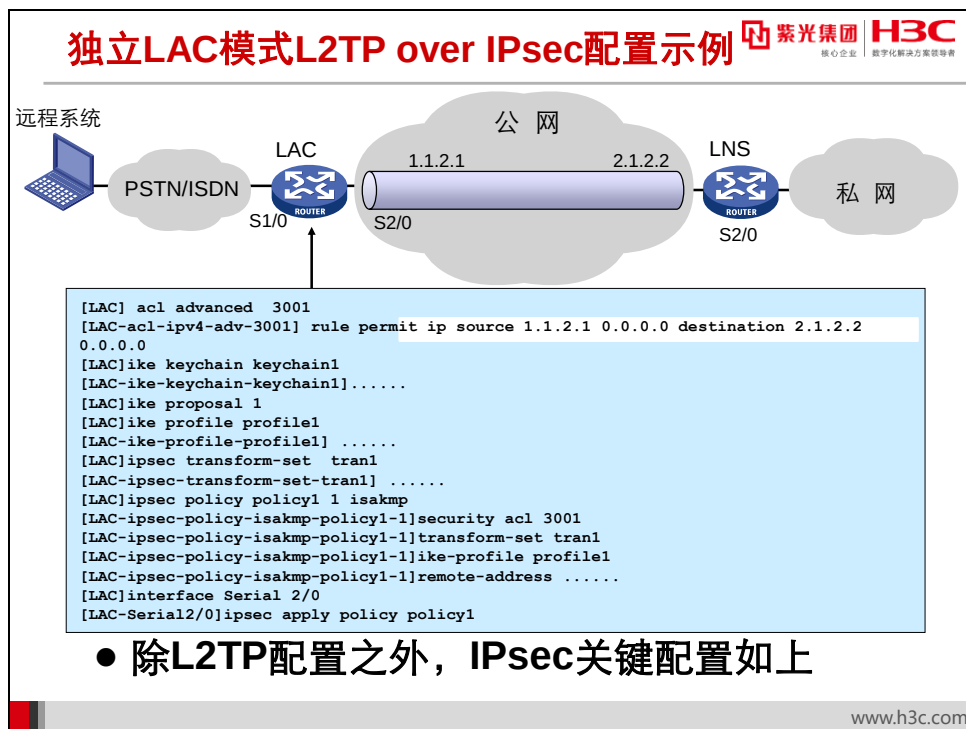
L2TP VPN 经常应用于移动用户通过 Internet 连接企业私网的情况。在 Internet 中数据受到的安全威胁较高，但 L2TP 不能确保数据的机密性和完整性，不能适应日益提高的安全性需求。

然而，L2TP 隧道是在 LAC 和 LNS 之间建立的。如果用 IPsec 对这个点到点的数据流进行保护，就可以同时具有 L2TP VPN 和 IPsec VPN 的特性，提供安全的 Access VPN。

在使用 L2TP over IPsec 时，IPsec 隧道在 LAC 与 LNS 之间建立，保护 L2TP 隧道数据流，L2TP 隧道封装包被封装在 IPsec 隧道封装包之中。

对于独立 LAC 模式而言，虽然远程系统到 LAC 的数据传输没有受到 IPsec 保护，但这一段通常为基于电路交换的连接，其安全性仍然是较高的。

对于客户 LAC 模式而言，IPsec 隧道需要直接在客户端主机与 LNS 之间建立。由于客户端主机通常从 Internet 获取动态 IP 地址，因而应使用 IKE 野蛮模式与 LNS 进行 IKE 协商。



这是一个典型的独立 LAC 模式 L2TP over IPsec 配置示例。在本例中，某企业以 MSR 路由器作为 LAC 和 LNS，远程用户使用 Windows 系统，通过 PSTN 拨号到 LAC 的串口 S1/0 接入，与企业总部互联。为确保 L2TP 的安全性，该公司要求在 LAC 与 LNS 之间配置 IPsec 保护 L2TP 隧道。

为简化起见，图中仅给出了 L2TP over IPsec 的关键配置。由于采用了固定公网 IP 地址，LAC 与 LNS 之间仍然使用预共享密钥方式的 IKE。当然 LAC 和 LNS 还需要相应的路由配置。

LAC 侧的主要配置如下：

```

[LAC]local-user vpdnuser class network
[LAC-luser-network-vpdnuser]password simple Hello
[LAC-luser-network-vpdnuser]service-type ppp
[LAC-luser-network-vpdnuser]quit
[LAC] interface serial 1/0
[LAC-Serial1/0]ppp authentication-mode chap
[LAC-Serial1/0]quit
[LAC] l2tp enable
[LAC]l2tp-group 1 mode lac
[LAC-l2tp1] tunnel name LAC
[LAC-l2tp1]user fullusername vpdnuser
[LAC-l2tp1]lns-ip 1.1.1.2
[LAC-l2tp1] tunnel authentication
[LAC-l2tp1] tunnel password simple aabbcc
[LAC-l2tp1]quit
[LAC] acl advanced 3001
[LAC-acl-ipv4-adv-3001]rule permit ip source 1.1.2.1 0.0.0.0 destination 2.1.2.2 0.0.0.0
[LAC-acl-ipv4-adv-3001]quit
  
```

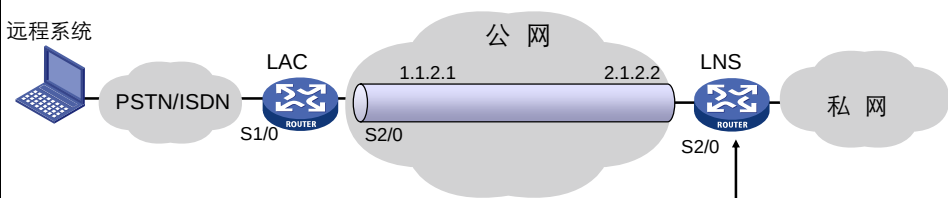
```

[LAC]ipsec transform-set tran1
[LAC-ipsec-transform-set-tran1]encapsulation-mode tunnel
[LAC-ipsec-transform-set-tran1]protocol esp
[LAC-ipsec-transform-set-tran1]esp encryption-algorithm des-cbc
[LAC-ipsec-transform-set-tran1]esp authentication-algorithm sha1
[LAC-ipsec-transform-set-tran1]quit
[LAC]ike proposal 1
[LAC-ike-proposal-1]quit
[LAC]ike keychain keychain1
[LAC-ike-keychain-keychain1]pre-shared-key address 2.1.2.2 255.255.255.0 key simple h3c
[LAC-ike-keychain-keychain1]quit
[LAC]ike profile profile1
[LAC-ike-profile-profile1]local-identity address 1.1.2.1
[LAC-ike-profile-profile1]match remote identity address 2.1.2.2 255.255.255.0
[LAC-ike-profile-profile1]keychain keychain1
[LAC-ike-profile-profile1]proposal 1
[LAC-ike-profile-profile1]quit
[LAC]ipsec policy policy1 1 isakmp
[LAC-ipsec-policy-isakmp-policy1-1]remote-address 2.1.2.2
[LAC-ipsec-policy-isakmp-policy1-1]security acl 3001
[LAC-ipsec-policy-isakmp-policy1-1]transform-set tran1
[LAC-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[LAC-ipsec-policy-isakmp-policy1-1]quit
[LAC]interface Serial 2/0
[LAC-Serial2/0]ipsec apply policy policy1
[LAC-Serial2/0]quit

```


紫光集团 H3C
核心企业 数字化解决方案领导者

独立LAC模式L2TP over IPsec配置示例(续)



```

[LNS] acl advanced 3001
[LNS-acl-ipv4-adv-3001] rule permit ip source 2.1.2.2 0.0.0.0 destination 1.1.2.1 0.0.0.0
[LNS]ike keychain keychain1
[LNS-ike-keychain-keychain1].....
[LNS]ike proposal 1
[LNS]ike profile profile1
[LNS-ike-profile-profile1] .....
[LNS]ipsec transform-set tran1
[LNS-ipsec-transform-set-tran1] .....
[LNS]ipsec policy policy1 1 isakmp
[LNS-ipsec-policy-isakmp-policy1-1]security acl 3001
[LNS-ipsec-policy-isakmp-policy1-1]transform-set tran1
[LNS-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[LNS-ipsec-policy-isakmp-policy1-1]remote-address .....
[LNS]interface Serial 2/0
[LNS-Serial2/0]ipsec apply policy policy1

```

● 除L2TP配置之外，IPsec关键配置如上

www.h3c.com

LNS 的主要配置如下：

```

[LAC]local-user vpdnuser class network
[LAC-luser-network-vpdnuser]password simple Hello
[LAC-luser-network-vpdnuser]service-type ppp
[LAC-luser-network-vpdnuser]quit
[LNS]domain system
[LNS-isp-system]authentication ppp local

```

```
[LNS-isp-system]quit
[LNS]ip pool 1 192.168.0.2 192.168.0.100
[LNS]interface Virtual-Template 1
[LNS-Virtual-Template1]ip address 192.168.0.1 255.255.255.0
[LNS-Virtual-Template1]ppp authentication-mode chap domain system
[LNS-Virtual-Template1]remote address pool 1
[LNS-Virtual-Template1]quit
[LNS]l2tp enable
[LNS]l2tp-group 1 mode lns
[LNS-l2tp1]tunnel name LNS
[LNS-l2tp1]tunnel authentication
[LNS-l2tp1]tunnel password simple aabbcc
[LNS-l2tp1]allow l2tp virtual-template 1 remote LAC
[LNS-l2tp1]quit
[LNS]acl advanced 3001
[LNS-acl-ipv4-adv-3001]rule permit ip source 2.1.2.2 0.0.0.0 destination 1.1.2.1
0.0.0.0
[LNS-acl-ipv4-adv-3001]quit
[LNS]ipsec transform-set tran1
[LNS-ipsec-transform-set-tran1]encapsulation-mode tunnel
[LNS-ipsec-transform-set-tran1]protocol esp
[LNS-ipsec-transform-set-tran1]esp encryption-algorithm des-cbc
[LNS-ipsec-transform-set-tran1]esp authentication-algorithm sha1
[LNS-ipsec-transform-set-tran1]quit
[LNS]ike proposal 1
[LNS-ike-proposal-1]quit
[LNS]ike keychain keychain1
[LNS-ike-keychain-keychain1]pre-shared-key address 1.1.2.1 255.255.255.0 key sim
ple h3c
[LNS-ike-keychain-keychain1]quit
[LNS]ike profile profile1
[LNS-ike-profile-profile1]local-identity address 2.1.2.2
[LNS-ike-profile-profile1]match remote identity address 1.1.2.1 255.255.255.0
[LNS-ike-profile-profile1]keychain keychain1
[LNS-ike-profile-profile1]proposal 1
[LNS-ike-profile-profile1]quit
[LNS]ipsec policy policy1 1 isakmp
[LNS-ipsec-policy-isakmp-policy1-1]remote-address 1.1.2.1
[LNS-ipsec-policy-isakmp-policy1-1]security acl 3001
[LNS-ipsec-policy-isakmp-policy1-1]transform-set tran1
[LNS-ipsec-policy-isakmp-policy1-1]ike-profile profile1
[LNS-ipsec-policy-isakmp-policy1-1]quit
[LNS]interface Serial 2/0
[LNS-Serial2/0]ipsec apply policy policy1
[LNS-Serial2/0]quit
```

13.7 本章总结

本章总结

- IPsec配置任务包括配置安全ACL、配置安全提议、配置安全策略、在接口上应用安全策略组等
- 手工配置参数的安全策略和通过IKE协商参数的安全策略
- IKE配置任务包括配置IKE提议、配置IKE profile等
- 熟练掌握IPsec/IKE相关的命令及典型配置
- IPsec可用于保护GRE、L2TP等VPN隧道的安全性

13.8 习题和解答

13.8.1 习题

1. 对于发送方来说, ()
 - A. 安全 ACL 许可 (permit) 的包将被保护。
 - B. 安全 ACL 拒绝 (deny) 的包将不被保护。
 - C. 安全 ACL 许可 (permit) 的包将不被保护。
 - D. 安全 ACL 拒绝 (deny) 的包将被保护。
2. 指定某 IPsec 策略所引用的安全提议, 使用命令 ()
 - A. **transform-set transform-set-name**
 - B. **proposal proposal-name**
 - C. **ike proposal proposal-name**
 - D. **ipsec policy policy-name proposal proposal-name**
3. 要在 MSR 上配置一个 IPsec 隧道, 必须配置的有 ()
 - A. IPsec 策略
 - B. IKE 提议
 - C. IKE profile
 - D. SA 使用的密钥
4. 要显示 IPsec 策略的信息, 应使用命令 ()
 - A. display ipsec policy
 - B. display ipsec proposal
 - C. display ike policy
 - D. display ike proposal
5. 要查看 IPsec SA 信息, 应使用命令 ()
 - A. display ipsec sa
 - B. display ike sa
 - C. display ipsec
 - D. display ike
6. 配置 GRE over IPsec 隧道时, 应该 ()
 - A. 用 IPsec 保护两端设备 Tunnel 接口之间的数据流
 - B. 用 IPsec 保护两端设备物理接口之间的数据流
 - C. 用 GRE 封装两端设备之间的 IPsec 数据流
 - D. 用 GRE 封装两端设备之间的 IKE 数据包

13.8.2 习题答案

- 1、AB 2、A 3、A 4、A 5、A 6、B

第14章 SSL VPN

随着信息技术在企业中的应用不断深化,企业信息系统对 VPN 网络也提出了越来越高的要求。最初的 VPN 仅实现简单的网络互联功能,采用了 L2TP、GRE 等隧道技术。为了保证数据的私密性和完整性,而产生了 IPsec VPN。

随着接入技术和移动技术的发展,如今的人们可以随时随地以多种方式接入 Internet。企业的员工要求随时可以在家中、网吧、旅馆,使用自己的、别人的、公用的电脑访问公司的信息系统。这些多种多样的远程接入都是动态建立的,远程主机的安全性得不到保证,并且远程终端的多样性也要求 VPN 的客户端具有跨平台、易于升级和维护等特点。另外,随着企业经营模式的改变,企业需要建立 Extranet 与合作伙伴共享某些信息资源,以便提高企业的运作效率。对合作伙伴的访问必须进行严格有效地控制,才能保证企业信息系统的的核心安全。

面对这些新的挑战,SSL VPN 便应运而生了。SSL VPN 以其简单易用的安全接入方式、丰富有效的权限管理,跨平台、免安装、免维护的客户端而成为远程接入市场上的新贵。

14.1 本章目标

课程目标

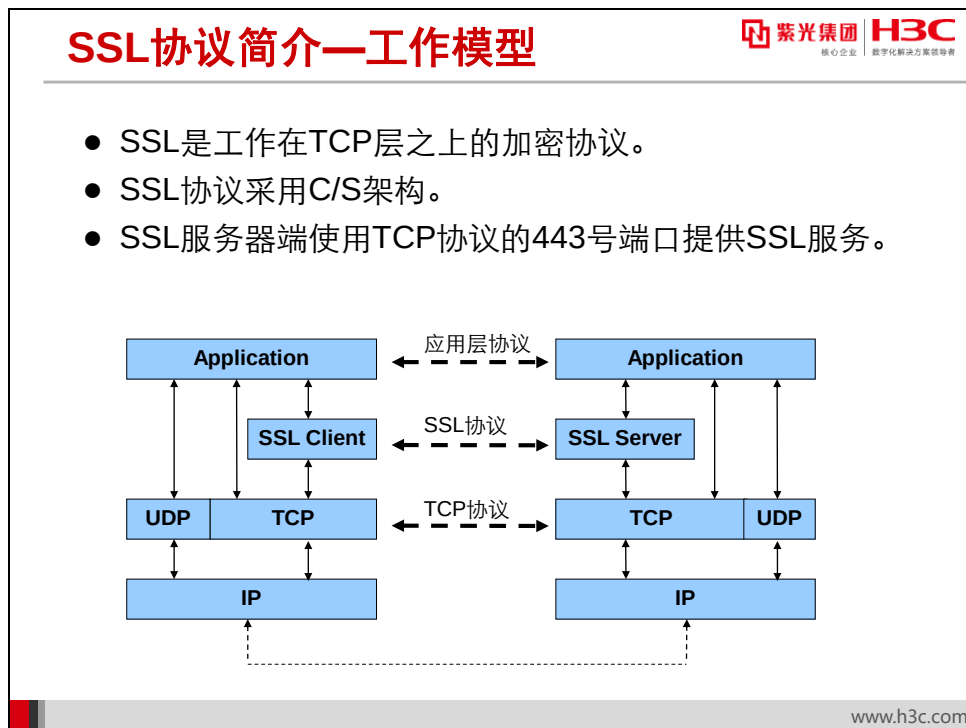
● 学习完本课程,您应该能够:

- 了解SSL协议基本原理
- 叙述SSL VPN架构组成及主要特点
- 掌握SSL VPN主要功能及实现方式
- 掌握SSL VPN主要部署模式



14.2 SSL 协议简介

14.2.1 协议概述

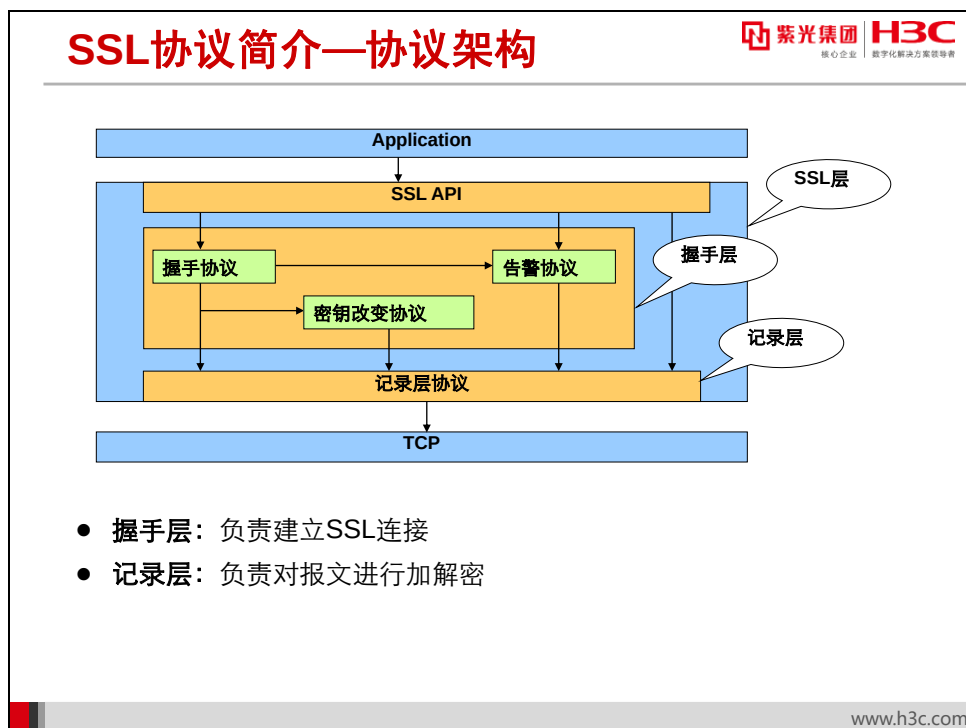


SSL（Secure Sockets Layer，安全套接层）是一个安全协议，为基于 TCP 的应用层协议提供安全连接，如 SSL 可以为 HTTP 协议提供安全连接。SSL 协议广泛应用于电子商务、网上银行等领域，为网络上数据的传输提供安全性保证。

SSL 提供的安全连接可以实现：

- **连接的私密性：**在 SSL 握手阶段生成密钥后，用对称加密算法对传输数据进行加密。
- **身份认证：**对服务器和客户端进行基于证书的身份认证（其中客户端认证是可选的）。
- **连接的可靠性：**消息传输过程中使用基于密钥的 MAC（Message Authentication Code，消息验证码）来检验消息的完整性。

SSL 协议采用 C/S 结构的通讯模式，SSL 服务器服务端端口为 TCP 协议的 443 号端口。



SSL 协议的通讯实体一般分为两层：握手层和记录层。握手层用于协商会话参数，建立 SSL 连接；记录层用于加密传输数据，封装传输报文。

握手层包括握手协议、告警协议、密钥改变协议等三个协议模块。

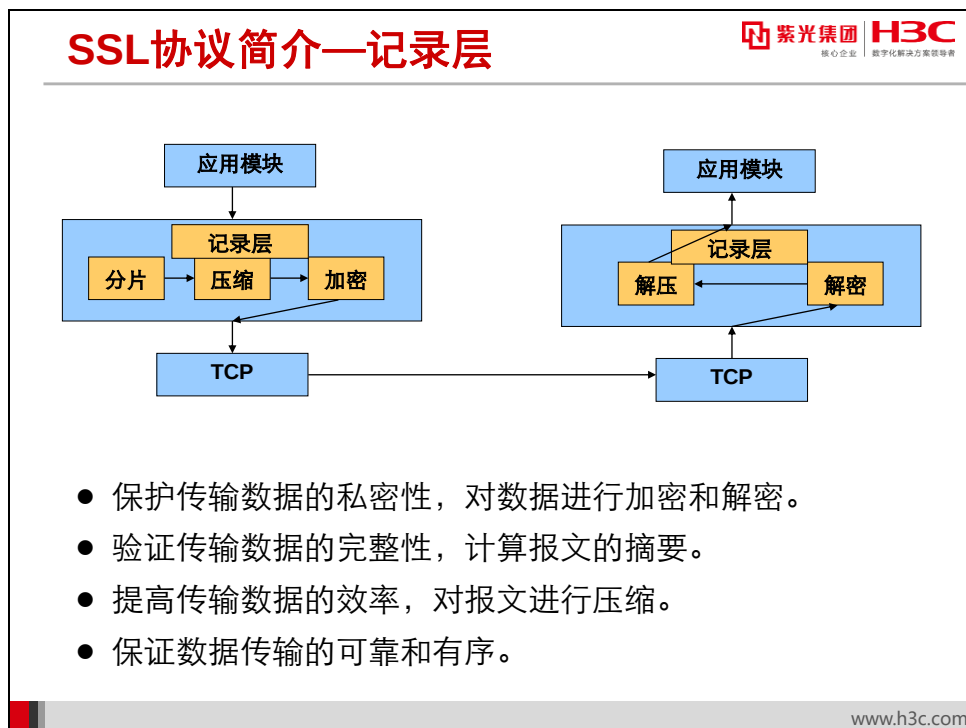
握手协议模块负责建立 SSL 连接，维护 SSL 会话。在建立 SSL 连接的过程中，通讯双方可以协商出一致认可的最高级别的加密处理能力，以及加密所需的各种密钥参数。

在协商出密钥后，握手协议模块通过“密钥改变协议”模块向对方发送一个“密钥改变”报文，通知对方的记录层：本方后续发送的报文将要启用刚才协商好的密钥参数。接收方收到“密钥改变”报文后，将在记录层设置好解密参数，对后续接收到的报文进行解密处理。

在 SSL 通讯期间，如果握手协议模块或者上层应用程序发现了某种异常，可以通过“告警协议”模块发送“告警消息”给另一方。告警消息有多种，如报文校验出错、解密失败、记录报文过长等，其中有一条消息是“关闭通知”消息，用于通知对方本端将关闭 SSL 连接。

除了上述协议功能模块外，为了便于应用程序对 SSL 协议功能的调用，SSL 模块还对外提供了一组 API 接口，使得应用程序可以简单透明地使用 SSL 协议的加密传输功能。

14.2.2 记录层



SSL 协议的记录层用于封装传输报文，加密传输数据，为上层通讯提供了以下的服务：

1. 保护传输数据的私密性，对数据进行加密和解密。
2. 验证传输数据的完整性，计算报文的摘要。
3. 提高数据的传输效率，对数据进行压缩。
4. 保证数据传输的有序性和可靠性。

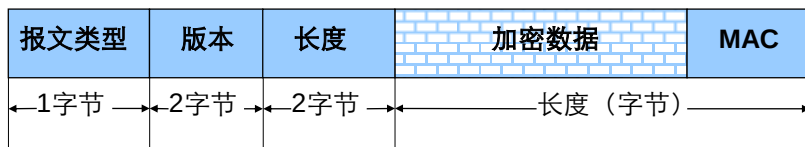
具体操作流程为：

在发送方首先将报文进行分片。SSL 记录层一次最大传输的数据长度为 16K 字节，当上层一次传输数据超过 16K 时，SSL 记录层将会对数据进行分片；为了提高数据传输效率，SSL 可以对数据进行压缩；最后发送方对经过压缩的报文进行加密，然后通过 TCP 连接将报文发送出去。

而在接收方，记录层首先对接收到的报文进行解密，然后对解密完的数据进行解压缩，最后将得到的结果传输给上层应用。

记录层报文格式

紫光集团 H3C
核心企业 数字化转型领导者



报文类型：

密钥改变协议(20)，告警协议(21)，握手协议(22)，应用层数据(23)

版本： TLS1.0(3,1)，SSL3.0(3,0)

长度： 记录层报文的长度，包括加密数据和MAC值的字节数。

MAC： 整个记录报文的消息验证码，包括从报文类型开始的所有字段。

www.h3c.com

记录层报文有固定的格式，包括报文类型、版本、长度、MAC 及加密数据等内容。

版本可以取的值有 3.1（TLS1.0）、3.0（SSL3.0）、2.0（SSL2.0）。

报文类型主要包括以下几种类型：

20： 表明封装的是密钥改变协议报文。该报文用于在握手过程结束时，通知对方本端加密参数已改变。

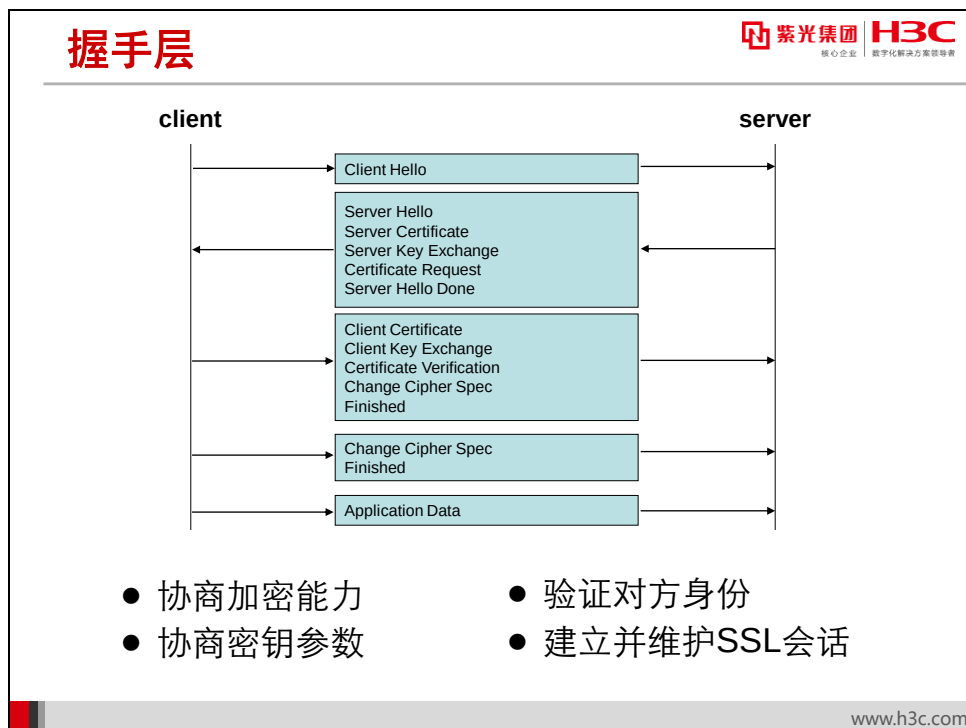
21： 表明封装的是告警报文。任何时候，都可以使用该报文通知对方告警信息。告警信息分警告和致命两个级别。对致命的告警，一般都需要关闭 SSL 连接。对警告级别的信息，有实现方决定如何处理。

22： 表明封装的是握手报文。握手报文用于建立 SSL 连接。

23： 表明封装的是应用层报文，说明正在传输上层应用数据。

而长度字段说明了本条记录报文加密数据段的字节数。

14.2.3 握手层



SSL 握手层是用来建立 SSL 连接。发起 SSL 连接请求的一方称为 SSL 客户端，响应 SSL 连接请求的一方称为 SSL 服务器端。该协议具有下列功能：

- **协商通讯所使用的 SSL 协议版本：**目前在应用中可能遇到的 SSL 版本有：SSL 2.0, SSL3.0, SSL3.1(TLS1.0)。SSL 的客户端与服务器端在正式传输数据前，可以协商出双方都支持的最高协议版本。
- **协商通讯所使用的加密套件：**加密套件是 SSL 通讯过程中所用到的各种加密算法的一种组合，SSL 协议的加密套件包括密钥交换算法、加密算法、HMAC 算法等。
- **协商加密所使用的密钥参数：**SSL 连接是双向的，每个传输方向上都有一套加密密钥。
- **通讯双方彼此验证对方的身份：**SSL 协议通过数字证书来验证双方的真实身份。服务器端必须传送自己的证书给客户端，当服务器端需要验证客户端的真实身份时，可以通过 CertificateRequest 消息向客户端索要证书（客户端验证是可选的）。
- **建立 SSL 连接和维护 SSL 会话：**在完成了上述协商任务，验证了对方的合法身份后，通讯双方就建立起了 SSL 连接。协商出来的参数，如协议版本、加密套件和密钥参数等，都保存到会话(session)中。当 SSL 连接断开后，SSL 会话并不会立即被清除，还会在 SSL 服务器端和客户端保留一段时间。如果客户端后续还要与相同的服务器端进行 SSL 通讯，则可以通过恢复 SSL 会话快速建立起 SSL 连接。

14.2.4 握手过程

SSL协议简介—握手过程

紫光集团 H3C
核心企业 数字化解决方案领导者

SSL握手协议提供了三种握手过程：

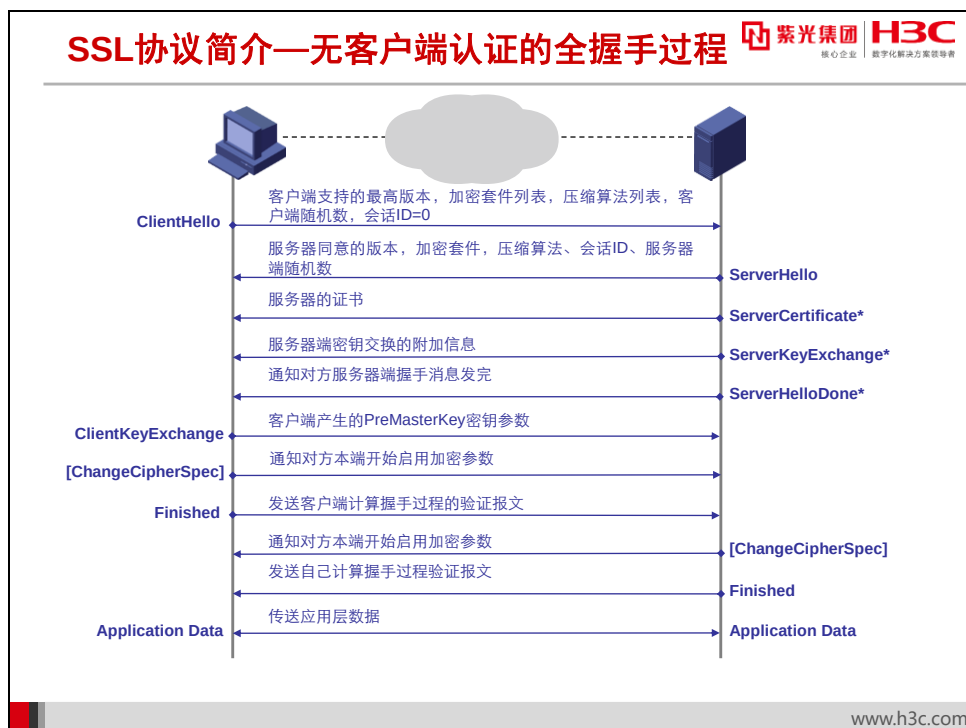
- 无客户端身份认证的全握手过程
- 有客户端身份认证的全握手过程
- 会话恢复过程



www.h3c.com

SSL 握手协议规定了三种握手过程：

- **无客户端认证的全握手过程：**所谓全握手过程是指一个完整的 SSL 连接建立过程，在其中需要建立新的 SSL 会话，协商出新的会话参数。“无客户端认证”是指在该过程中服务器端并不验证客户端的身份。但是，服务器端需要传递证书给客户端，客户端是否对服务器的证书进行验证由客户端的具体实现来决定。
- **有客户端身份认证的全握手过程：**如果服务器端想验证客户端的真实身份，在原来无客户端身份认证过程的基础上，增加了索取客户端证书以及验证客户端身份的消息。这样在握手过程结束时，双方不但协商出了加密参数，还使得服务器端验证了用户的真实身份。
- **会话恢复过程：**一般情况下，一次页面请求结束后，SSL 连接就会被关闭。为了提高 SSL 通讯的效率，避免重复的 SSL 连接建立过程，SSL 提供了会话恢复机制，后续的对同一服务器的 SSL 通讯可以使用上一次保存在缓存中的 SSL 会话参数。



无客户端认证的全握手通讯过程以及使用的报文如下：

1. **ClientHello**：客户端首先发出 ClientHello 报文，向服务器端请求建立 SSL 连接。报文携带了客户端最高支持的 SSL 协议版本、可以支持的加密套件列表、用于生成密钥的客户端随机数等信息。如果是新建立的 SSL 连接，报文中的会话 ID 字段就为 0。

2. **ServerHello**：服务端通过此报文向客户端表明自己可以接收的协议版本、加密套件、用于生成密钥的服务器端随机数。服务器端为本次 SSL 通讯会话分配了一个会话 ID，通过此报文返回给客户端。

3. **ServerCertificate**：传送服务器端的证书给客户端，客户端可以对此证书进行验证。

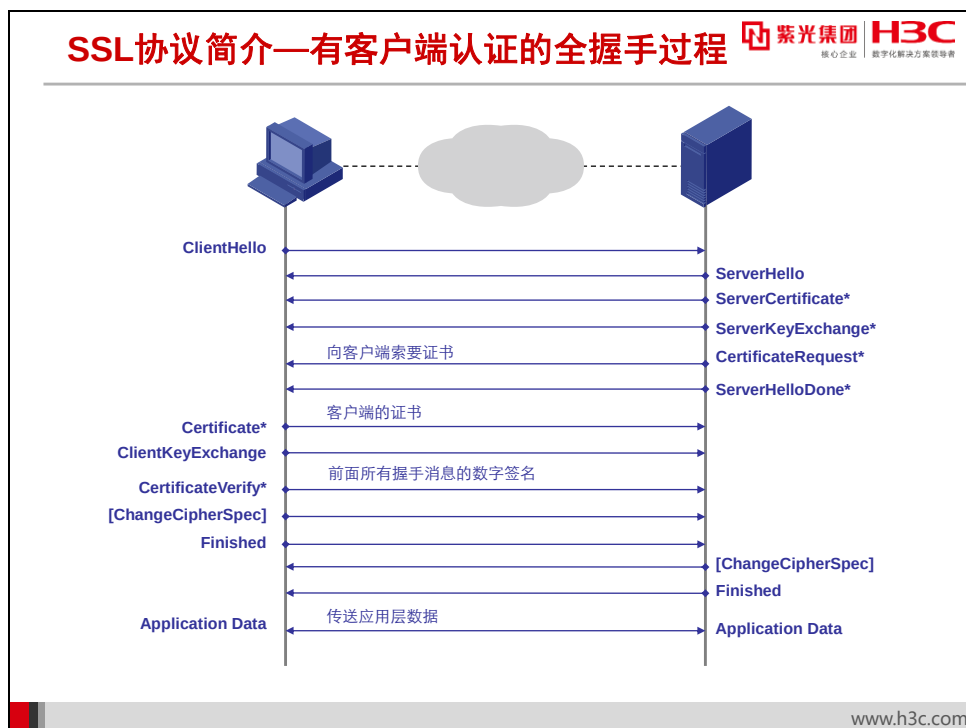
4. **ServerKeyExchange**：当采用 DH 密钥交换算法时，ServerCertificate 消息不足以携带足够多的信息用于密钥交换，便采用 ServerKeyExchange 消息携带附加的信息。该消息是可选的。

5. **ClientKeyExchange**：用于传送密钥交换报文。客户端用随机函数生成一个密钥参数 PreMasterKey，然后用服务器端证书中的公钥对密钥参数进行加密，通过 ClientKeyExchange 消息将加密了的密钥参数传给对方。Server 端收到该消息后，用自己的私钥对报文进行解密，得到 PreMasterKey。然后由 PreMasterKey 派生出记录层加密所需要的多个加密参数。客户端直接使用 PreMasterKey 计算记录层的密钥参数。计算完加密参数后，向对方发送 ChangeCipherSpec 消息。

6. **ChangeCipherSpec**：通知对方本端开始启用加密参数，后续发送的数据将是密文。

7. **Finished:** 对前面所有的握手消息计算摘要。收发双方都计算 Finished 报文，然后比较对方计算的 Finished 报文，如果一致，说明握手过程没有被破坏。Finished 报文是双方发送的第一个加密报文。

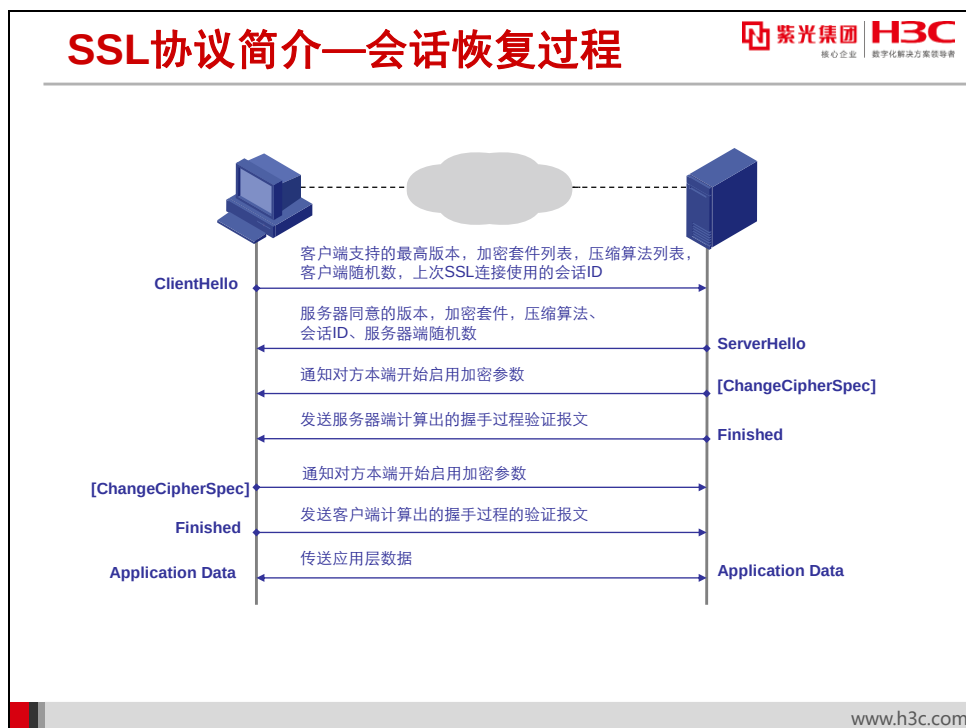
Finished 报文验证完后，通讯双方就建立起了一条 SSL 连接。其后双方就可以通过该 SSL 连接传输应用层数据了。



SSL 协议提供了一种机制，在通讯双方握手的过程中，服务器端可以通过客户端的数字证书和私钥数字签名验证客户端的真实身份。

与无客户端认证的全握手过程相比，有客户端认证的过程多了三个消息：

- **CertificateRequest:** 服务器端向客户端要证书。
- **Certificate:** 客户端将包含自己公钥的证书传送给了服务器端。
- **CertificateVerify:** 客户端对在此之前发送和接收的所有握手报文计算摘要，并用自己的私钥进行加密。这样就获得了对前面所有握手消息的数字签名。服务器端收到该消息后，用客户端证书中的公钥对数字签名进行解密，并比较该摘要与自己一方计算的摘要是否一致。如果一致就说明摘要正确，且客户端拥有与客户端证书中公钥相匹配的私钥，因而证明客户端的身份就是其证书中所声明的。



会话恢复机制避免了重复的 SSL 连接建立过程，使得后续的对同一服务器的 SSL 通讯可以使用上一次保存在缓存中的 SSL 会话参数

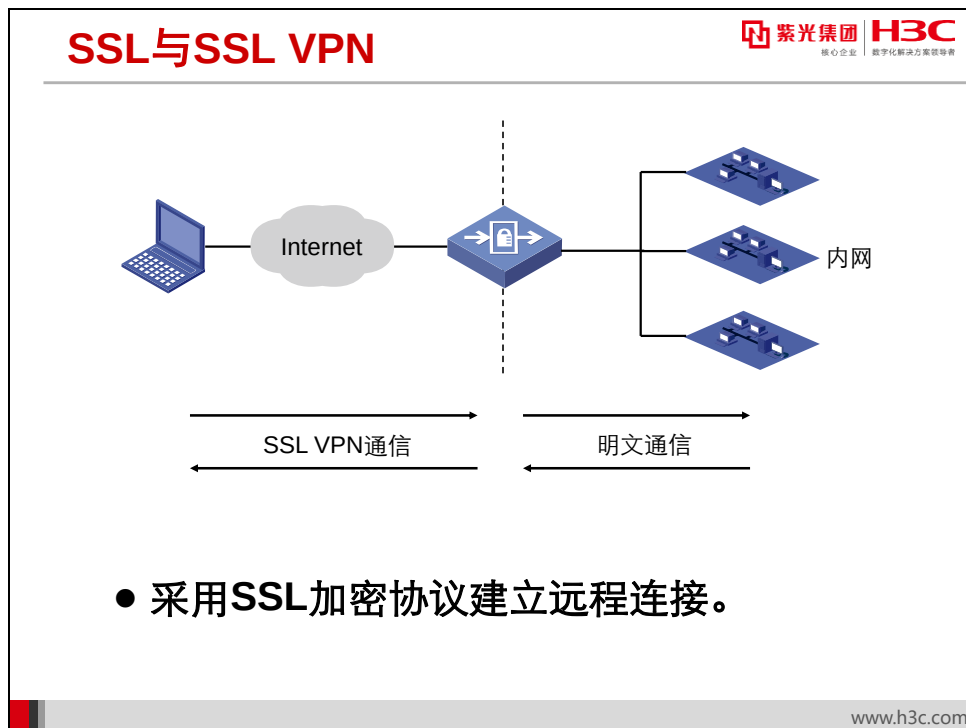
在会话恢复过程中，**ClientHello** 报文中携带了上次会话的 ID，服务器端可以根据此 ID 找到服务器端缓存中保存的会话参数。

如果服务器端没有找到保存的会话，就在回应的 **ServerHello** 报文中携带一个不同的会话 ID；客户端如果发现服务器端返回的会话 ID 与自己提供的不一致，就知道要开始一个全握手过程了，需要重新协商加密参数。

如果服务器端找到了保存的会话，就根据此会话中的参数回应一个 **ServerHello** 报文。接下来，通讯双方跳过密钥参数协商过程，直接发送 **ChangeCipherSpec** 启用原来会话中的加密参数，开始加密通讯。

14.3 SSL VPN概述

14.3.1 SSL 与 SSL VPN

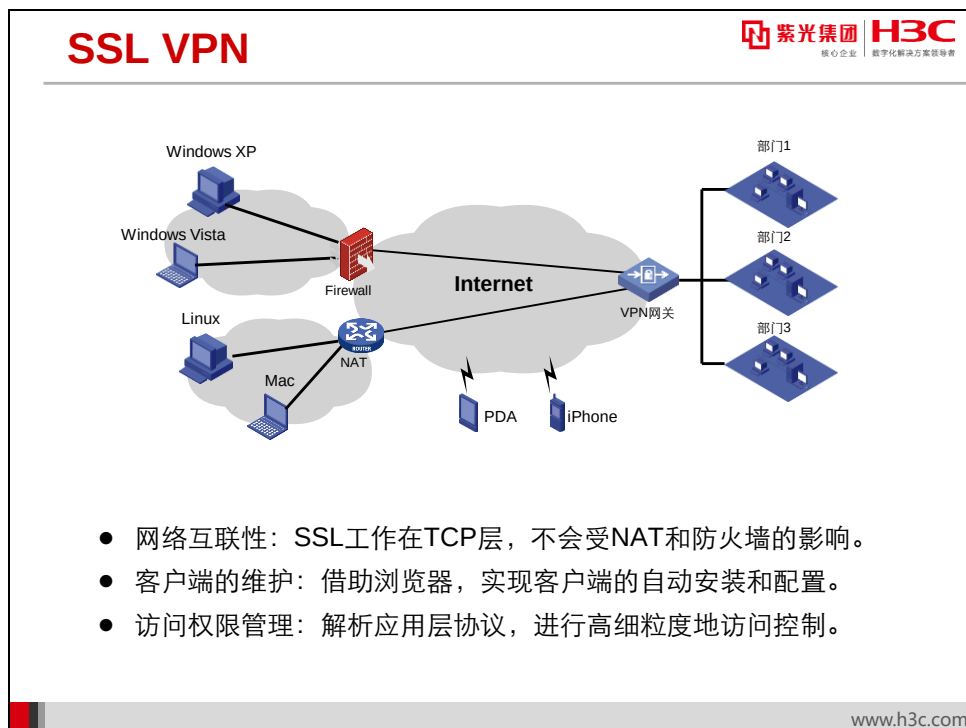


SSL VPN 其实就是采用 SSL 加密协议建立远程连接的一种 VPN。SSL 本身一些特性使得 SSL VPN 具有一些独特的优势：

首先，SSL 协议是一种加密协议，可以很好地保证数据传输的私密性和完整性。

其次，SSL 协议还是一种工作在 TCP 协议层之上的协议。使用 SSL 进行通讯，不改变 IP 报文头和 TCP 报文头，因而 SSL 报文对 NAT 和防火墙来说都是透明的，SSL VPN 的部署不会影响现有的网络。这样用户从任何地方上网，只要能接入 Internet，就能使用 SSL VPN。

另外，SSL 加密协议受到了目前绝大多数软件平台的支持。常用的操作系统 Windows、Linux，浏览器 IE、Firefox 等都支持 SSL。

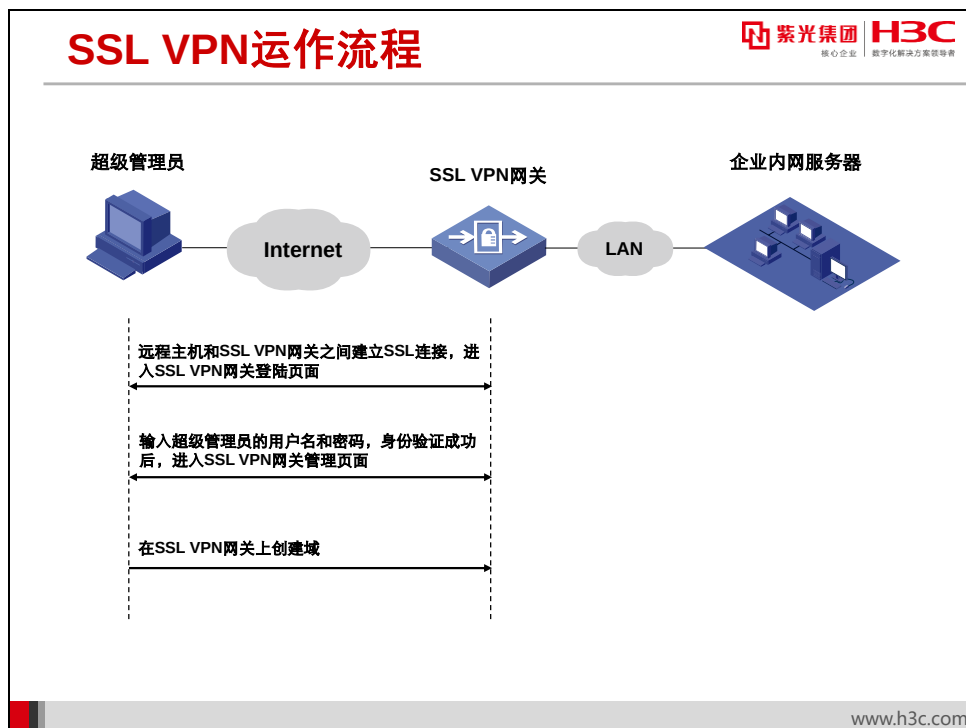


除了 SSL 特点使得 SSL VPN 有较为灵活的网络互联性外，SSL VPN 还有不少其他特点。

- 提供了全面的接入手段，包括 web 接入、TCP 接入和 IP 接入，且客户端维护简单。使用 web 接入方式，用户只需要使用 Web 浏览器就可以从 Internet 上访问私网中的网络资源，SSL VPN 系统本身并不需要提供额外的 VPN 客户端，而是借用 Web 浏览器作为 VPN 客户端，因而在这种情况下 SSL VPN 可以实现所谓的“免客户端”特性。对于一些非 web 应用，TCP、IP 接入方式借助 Web 的控件技术，SSL VPN 可以实现 VPN 客户端的自动下载、自动安装、自动运行和自动清除等功能，从而减少了 VPN 客户端的维护工作，也方便了用户的使用。
- 可以对用户的访问权限进行较细致的管理。

SSL VPN 网关可以解析一定深度的应用层报文。对 http 协议，网关可以控制对 URL 的访问；对 TCP 应用，不但可以控制对 IP 地址和端口号的访问，还可以进一步解析应用层协议，控制具体的访问内容。此外，SSL VPN 可以实现基于用户角色的权限管理，从而使得权限管理可以精确到对用户个人的访问控制，除此之外 SSL VPN 还提供了动态授权机制，根据用户的自身权限结合客户端主机安全情况决定授予登陆用户的权限级别。

14.3.2 SSL VPN 运作流程



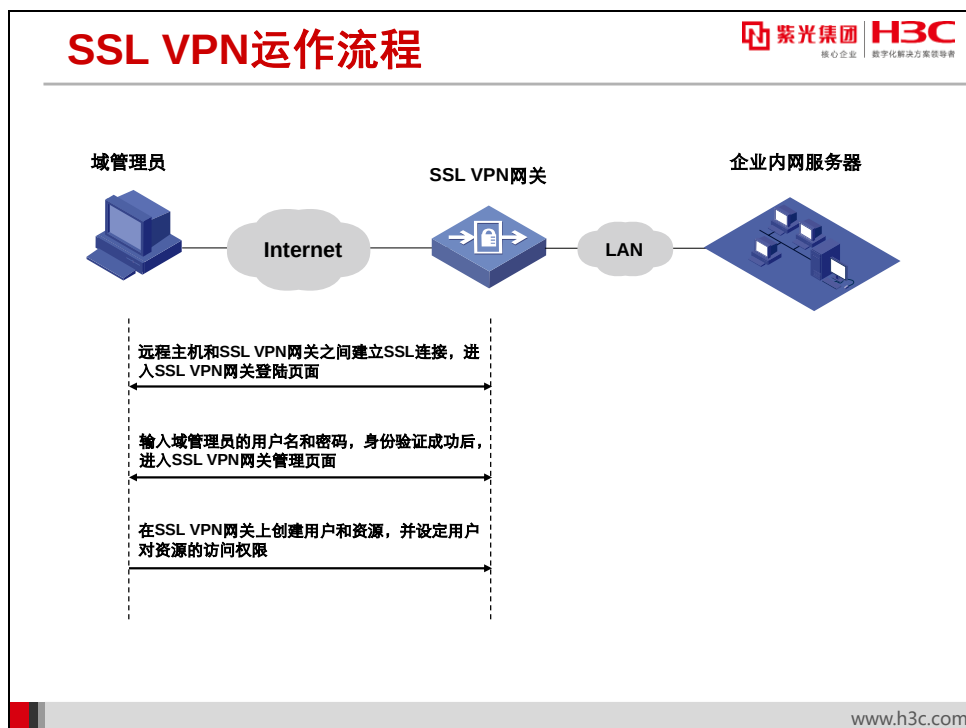
典型的 SSL VPN 构成其实非常简单, 包括远程主机、SSL VPN 网关、内网资源服务器及相关认证及 CA 类服务器等。

远程主机是用户远程接入的终端设备, 一般就是一台普通 PC。

SSL VPN 网关是 SSL VPN 的核心, 负责终结客户端发来的 SSL 连接; 检查用户的访问权限; 代理远程主机向资源服务器发出访问请求; 对服务器返回的应答进行转化, 并形成适当的应答转发给远程客户端主机。

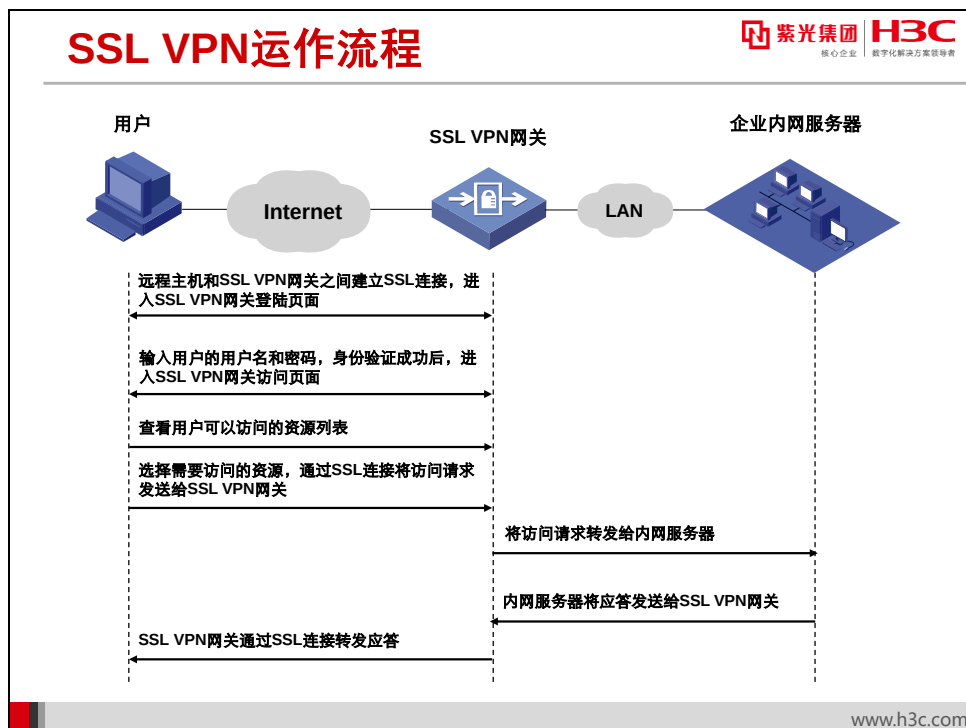
SSL VPN 网关上配置了三种类型的账号: 超级管理员、域管理员和普通用户。超级管理员为系统域的管理员, 可以创建新的域, 并初始化域的管理员密码, 给域授予资源组, 并授权域是否能够创建新的资源。

超级管理员可以创建若干个域, 并指定每个域的域管理员。



域管理员是一个 SSL VPN 域的管理人员，主要是对一个域的所有用户进行访问权限的限制。域管理员可以创建域的本地用户、用户组、资源和资源组等。

以域管理员账号登陆到 SSL VPN 网关后，可以配置本域的资源 and 用户，将资源加入到资源组，将用户加入到用户组，然后为每个用户组指定可以访问的资源组。

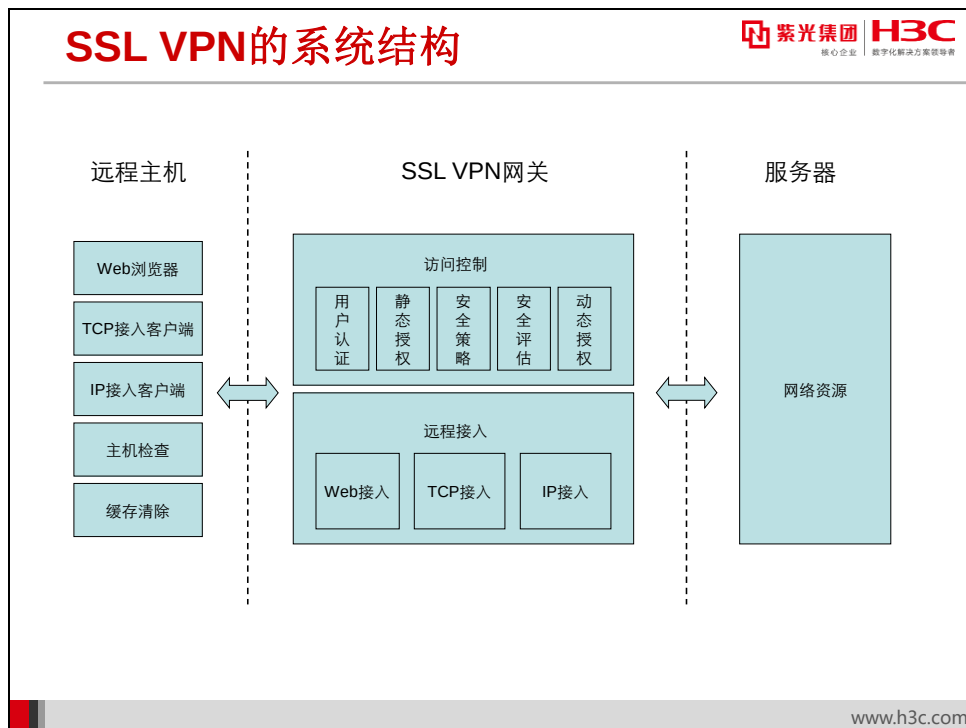


而 SSL VPN 用户帐号是真正的最终用户, 是使用 SSL VPN 访问网络资源的用户。

以 SSL VPN 用户账号登录后可以访问 SSL VPN 网关访问页面, 选择需要访问的资源, 通过 SSL 连接将访问请求发送给 SSL VPN 网关; SSL VPN 网关根据域管理员配置的用户权限及该用户使用的主机安全情况决定该用户可以访问的资源, 将访问请求转发给内网资源服务器; 内网资源服务器将应答 SSL VPN 网关, SSL VPN 网关将该应答通过 SSL 连接转发给远程客户端。

14.4 SSL VPN功能与实现

14.4.1 接入方式



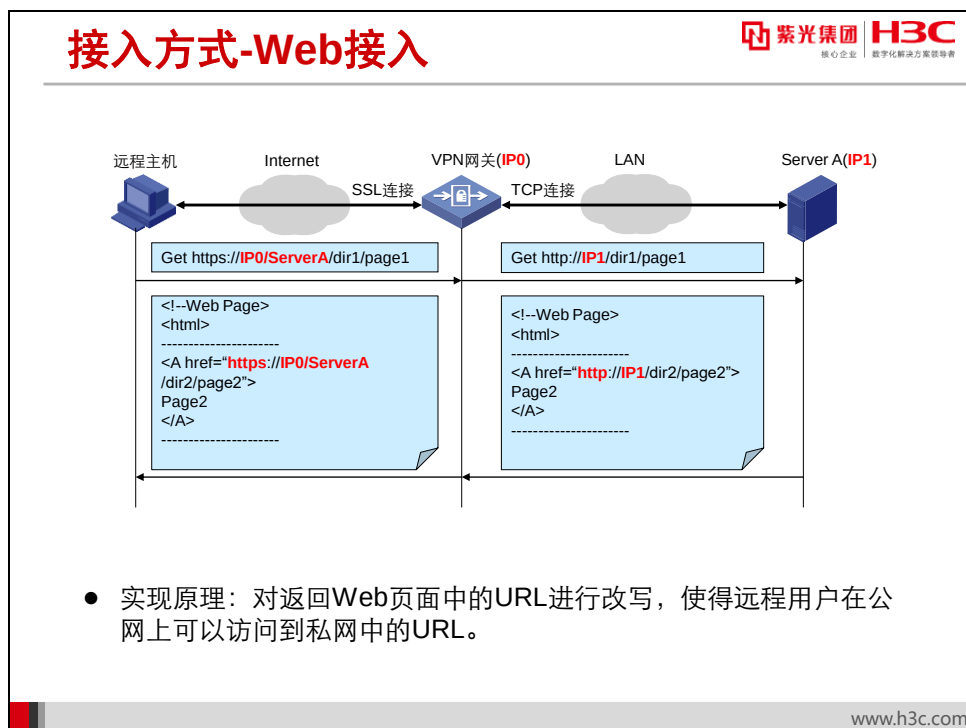
远程主机其实就是 SSL VPN 客户端机器，上面运行 Web 浏览器、主机检查器、缓存清除器、TCP/IP 接入客户端等。除 Web 浏览器是远程主机自带的以外，其它都是从 SSL VPN 网关下载的。而且这些客户端一般都是自动下载、自动安装、自动配置、自动建立连接。

主机检查器主要用户检查该远程主机的安全情况，包括操作系统补丁、防病毒软件版本等，以决定从该主机登录的用户到底应该授予多大的权限。为了进一步提高安全性，在用户退出后，主机会将访问 SSL VPN 过程中遗留的信息清除，这就需要缓存清除器了。

SSL VPN 网关是 SSL VPN 的核心组件，负责终结客户端发来的 SSL 连接，并与资源服务器之间建立连接，起到中继的作用。其核心功能是远程接入和访问控制。

SSL VPN 提供了 Web 接入、TCP 接入、IP 接入三种接入方式。

而在访问控制方面提供了用户认证、安全评估、动态和静态授权等功能。



Web 接入是 SSL VPN 最为常见的一种接入方式，其实就是 Web 反向代理技术。上图是以一个例子说明此种接入方式的典型过程。在该例子中，SSL VPN 网关的公网地址是 IP0，内部的资源服务器 Server A 使用的地址是 IP1：

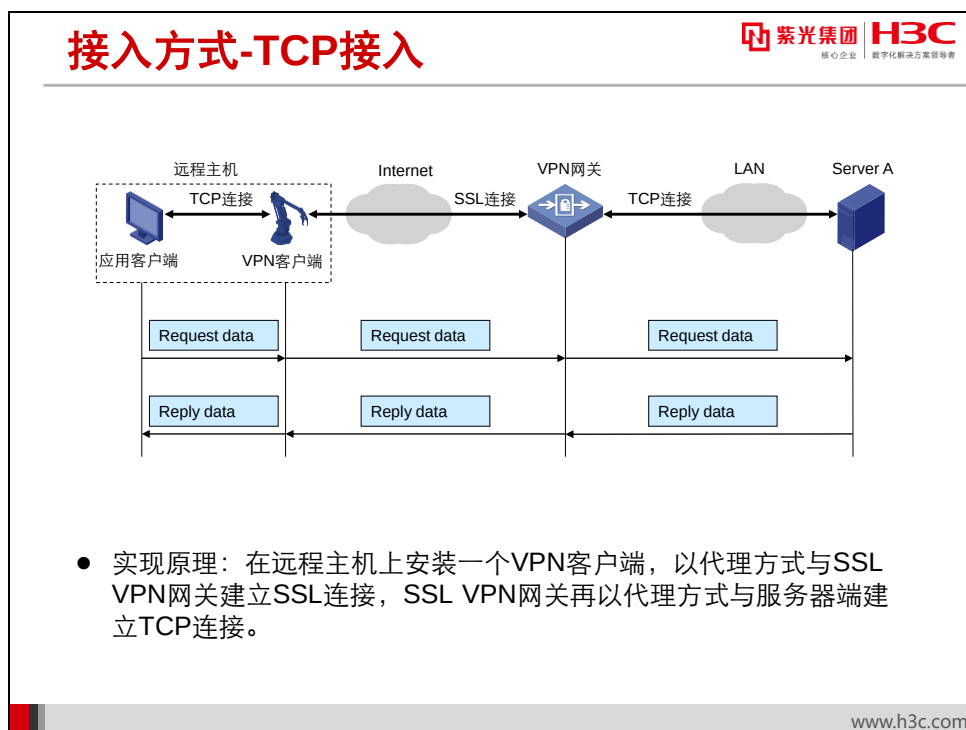
1. 远程用户通过 Web 浏览器与 SSL VPN 网关(IP0)之间建立 SSL 连接，通过 SSL 连接发送 http 请求，请求的地址是” https://IP0/ServerA“，这个 URL 并不是一个真实的路径，而是 VPN 网关给内网服务器 ServerA 建立的虚拟路径。

2. VPN 网关解析 http 请求，将报文中的请求路径” IP0/ServerA/dir1/page1“修改成为” IP1/dir1/page1 “，将修改后的请求报文通过 TCP 连接转发给 ServerA(IP1)进行处理。

3. ServerA 处理完远程主机发来的 http 请求后，返回应答报文。该报文一般情况下是一个 web 页面。Web 页面文件中的连接<A>...指向的是内网服务器上的地址，如”http://IP1/dir2/page2”（这个 URL 外网是不可见的）。

4. VPN 网关解析 ServerA 返回的 Web 页面，对页面中的链接逐一修改，使之映射成为外网可见的 URL 地址。如图中所示，将”http://IP1/dir2/page2” 改写成为”https://IP0/ServerA/dir2/page2”。

这样被改写过的页面传回给远程主机后，远程用户就可以访问页面中的链接了。



虽然 Web 接入具有免客户端的好处，但是这种接入方式主要适用于访问 Web 类资源。目前已有的很多网络应用都有各自的应用层协议，也有不同于 Web 浏览器的客户端，如：Telnet、FTP、Notes 等。对于这些拥有自己客户端的 C/S 架构的 TCP 应用，SSL VPN 提供了“TCP 接入”。TCP 接入也称为“端口转发”。

上图展示了其主要流程：

第1步：用户登录 SSL VPN 系统后，会通过 Web 页面在远程主机上自动下载、安装和运行一个 VPN 客户端程序，该客户端程序启动后会完成以下任务：

- 在 hosts 文件中添加内网计算机的主机名，将这些主机名指向本机的环回地址。

例如：用户被授权访问内网的一台服务器，其主机名为“ServerA”，在 Windows 系统的 hosts 文件中将添加如下的条目：127.0.0.3 ServerA。

- 监听本机环回地址上的服务端口。

例如：用户被授权访问内网服务器 ServerA 的 telnet 服务，则 VPN 客户端将监听在端口 127.0.0.3:23 上。

第2步：用户在远程主机上启动网络应用的客户端程序，该客户端向内网服务器发起的建立 TCP 连接请求被 VPN 客户端截获，于是应用程序的客户端与 VPN 客户端之间将建立起 TCP 连接。

例如：用户在命令行上执行“telnet ServerA”命令，telnet 客户端启动后将向 127.0.0.3:23 这个端口发起建立 TCP 连接请求。该端口正被 VPN 客户端所监听，于是 VPN 客户端便作

为内网服务器的代理与本地的应用客户端应答,在应用客户端与 VPN 客户端之间建立起了 TCP 连接。

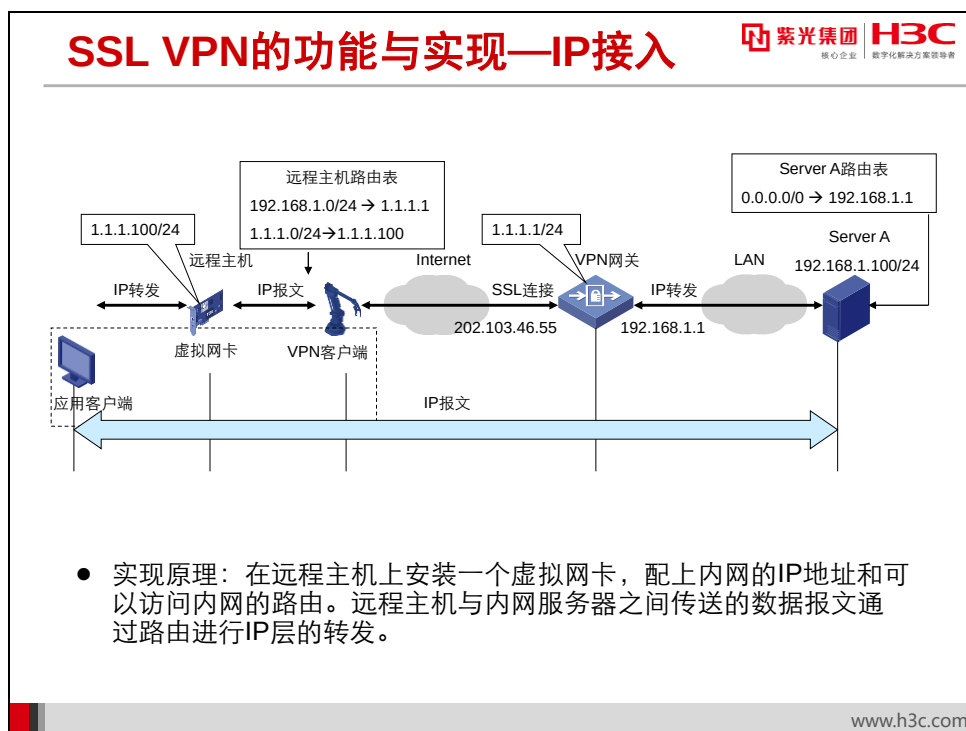
第3步: VPN 客户端与 SSL VPN 网关之间建立起 SSL 连接。

在 SSL 连接建立起来后,VPN 客户端通知 SSL VPN 网关远程主机希望访问内网服务器上的某种 TCP 服务。

第4步: SSL VPN 网关与指定的内网服务器上的 TCP 服务建立 TCP 连接。

例如: SSL VPN 网关与内网服务器 ServerA 上的 Telnet 服务之间建立 TCP 连接。

经过上述步骤后,从应用程序的客户端到内网服务器之间就建立起了一条首尾贯通的全双工的数据通道。



有些网络应用的通讯机制比较复杂,尤其是一些采用动态端口建立连接的通讯方式,往往需要 SSL VPN 解析应用层的协议报文才能确定通讯双方所要采用的端口,上述两种接入方式就显得力不从心,对于这些通讯机制比较复杂的网络应用,SSL VPN 还提供了被称为“IP 接入”的网络互联手段。“IP 接入”也称为“网络扩展”。

为了便于说明 IP 接入的工作原理,以图中实例的配置进行讲解。

在该示例中 SSL VPN 网关的配置为:

1. 在 SSL VPN 网关上为 IP 接入配置一个 IP 地址池,用于给接入的用户分配 IP 地址。如 1.1.1.1~1.1.1.255。
2. 在 SSL VPN 网关上建立一个虚接口 sve1/0,配置 IP 地址 1.1.1.1/24。

3. 在内网服务器上设置默认路由指向 VPN 网关，如图中所示：0.0.0.0/0 192.168.1.1。

SSL VPN 客户端的准备：

1. 在用户采用 IP 接入时，SSL VPN 会通过 Web 页面在远程主机上下载并安装一个 IP 接入客户端和一个虚拟网卡。

2. 在虚拟网卡上，配置一个由 SSL VPN 网关分配的内网 IP 地址。如图中所示的 1.1.1.100。

3. 在远程主机上，VPN 客户端设置若干条路由，这些路由设置了允许该用户访问的 IP 网段。而路由的下一跳都指向 SSL VPN 网关上的虚接口地址。如图所示，网段 192.168.1.0/24 的下一跳为 1.1.1.1。

4. VPN 客户端与 SSL VPN 网关之间建立起一条 SSL 连接。

IP 接入的通讯过程：

1. 应用客户端要访问内网服务器 Server A，已知 Server A 的 IP 地址是 192.168.1.100，于是向该地址发送一个 IP 报文，该 IP 报文的地址是 192.168.1.100，源地址是 1.1.1.100。

2. 在转发该 IP 报文时，远程主机查询本地路由表，得知应该 IP 报文应该发送给默认网关 1.1.1.1。而去往 1.1.1.0 网段的报文应该交给虚拟网卡处理。

3. 虚网卡接收到 IP 报文后，交给 VPN 客户端转发给 SSL VPN 网关。

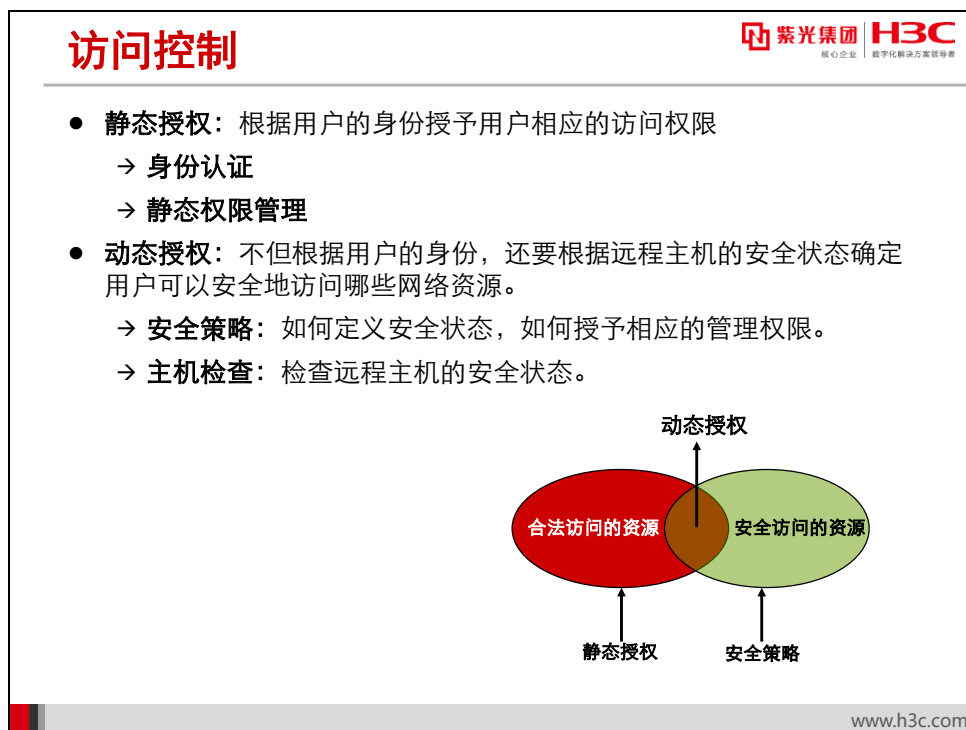
4. 在 SSL VPN 网关上，IP 报文被送到虚接口 sve1/0。从此处再按照目的 IP 地址 192.168.1.100 进行路由转发，IP 报文被送到了 Server A。

5. Server A 的回应报文源地址是 192.168.1.100，目的地址是 1.1.1.100。该报文通过查找本地的路由，将报文发送给 VPN 网关。

6. 在 VPN 网关上，查找本地路由，得知 IP 报文应该发送给远程主机上的虚网卡，通过相应的 SSL 连接将报文发送到了 VPN 客户端程序。

7. VPN 客户端将 IP 报文发送给虚拟网卡，再由虚拟网卡上送到远程主机的 TCP/IP 协议栈，最后送达应用程序的客户端。

14.4.2 访问控制



SSL VPN 可以提供高细粒度的访问控制，控制的粒度可以达到 URL、文件目录、服务器端口和 IP 网段等。访问控制的核心技术在于授权管理，SSL VPN 有两种授权管理的方式：静态授权和动态授权。

普通的授权是静态的，即用户的身份与所授予的权力是绑定的，无论在什么时间、从什么地方、远程主机处于什么样的安全状态，用户登录后，都被授予同样的访问权限，权限的大小只是和用户账号有关。

对于远程接入，网络系统必须考虑这样一个问题：远程主机如果不够安全，染上了病毒、或者存在安全漏洞，在访问内部网络时，也有可能给内网带来很大的风险。所以对不安全的远程主机应该限制或禁止其对内网资源的访问。远程主机越安全，被授予的访问权限应该越大，反之则越小。

结合远程接入的应用需求与现有的软件技术，SSL VPN 可以实现更为高级的“动态授权”方式。一方面根据用户的身份确定用户可以合法访问的网络资源，另一方面通过安全策略和主机检查确定用户目前可以安全访问的网络资源，然后取两者的交集就得到了用户在当前的网络环境中可以既安全又合法地访问哪些网络资源。

动态授权是静态授权与安全策略授权的交集。

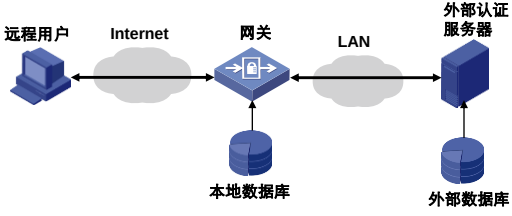
14.4.3 静态授权

静态授权—身份认证


核心企业 | 数字化转型方案领导者

- **本地认证：**用户的帐号和密码保存在网关本地的数据库中，由网关独立地对用户身份进行认证。
- **外部认证：**用户的帐号和密码保存在外部服务器上。在接收到用户提交的帐号和密码后，网关将其交给外部服务器进行验证。网关根据服务器返回的验证结果决定是否允许用户登录SSL VPN。

- 几种外部认证
 - Radius
 - Ldap
 - AD



```
graph LR
    RU[远程用户] -- Internet --> GW[网关]
    GW -- LAN --> EAS[外部认证服务器]
    GW <--> LD[本地数据库]
    EAS <--> ED[外部数据库]
```

www.h3c.com

身份认证是静态授权的核心内容，用户权限的大小只是和账号有关，而非法用户是不能够登陆系统的。

目前网络上常用的身份认证方法就是对用户名和密码的验证。根据用户是否能提供正确的私密信息来判断用户身份的合法性。这种认证方法的好处是简单可行。根据服务器端保存验证信息的位置可以分为本地认证和外部认证。

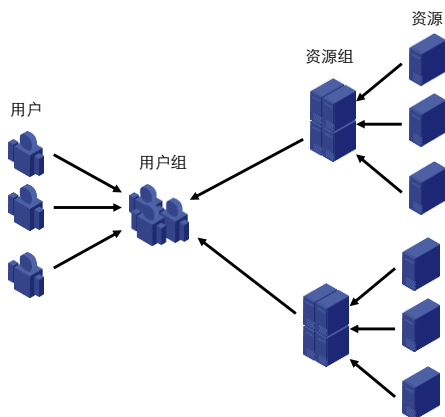
在本地认证过程中，网关设备上保存着用户名和密码的验证信息，由网关对认证请求中的用户名和密码进行验证，以确认用户身份。如果认证成功，则可以与远端建立受信任的连接。

如果用户身份的验证信息保存在外部服务器上，则网关设备就相当于一个认证代理，负责转送认证信息，并接收认证结果。如果外部认证服务器对用户身份认证成功，网关设备就与远程用户建立受信任的连接，允许用户访问内部网络。反之，则拒绝接入。

网关与外部认证服务器之间可以有多种交互协议。在拨号上网时代，使用最多的是 RADIUS 协议。随着网络信息容量的增大，人们对信息的组织和查询提出了更高的要求。一种称为 LDAP 的服务就应运而生了。LDAP 服务器可以很好地管理和组织一个企业的数据，也可以存储用户身份认证信息。网关设备可以通过查询 LDAP 数据库来确认远程用户提交的用户名和密码是否正确。

另外 SSL VPN 还支持一些高级认证技术：证书认证、动态令牌认证、双因子认证等。

静态授权实现



- 在一个资源组中加入多个资源，以方便对资源的管理。
- 用户组，用以标识系统中不同的用户角色。
- 在用户组中加入合适的用户，就给该用户赋予了相应的“角色”权力。
- 在用户组中加入可以访问的资源组，完成了对用户组以及用户的访问授权。

在静态授权中用户登录进 SSL VPN 系统后，能访问哪些合法的资源？SSL VPN 资源和用户账号是如何组织的呢？

SSL VPN 中有资源和资源组，可以在一个资源组中加入多个资源，以方便对资源的管理。在 SSL VPN 中可以创建多个用户组，用以标识系统中不同的用户角色，如：在一个企业里，可以有开发人员、项目经理、部门经理等不同的角色。在用户组中加入合适的用户，就给该用户赋予了相应的“角色”权力。在用户组中加入可以访问的资源组，就完成了对用户组以及用户的访问授权

14.4.4 动态授权

动态授权—安全策略

紫光集团 H3C
核心企业 数字化解决方案领导者

- 安全策略
在SSL VPN系统中，安全策略用于定义远程主机所处的安全状态，以及在相应的安全状态下，远程主机可以安全访问的网络资源。
- 安全状态
安全状态的定义是通过设定一组明确的检查对象，以及对各个检查对象所需进行的检查规则，来标识符合一定安全要求的系统状态。
- 安全级别
为了表明不同安全状态所处安全程度的不同，对每个安全状态需要指定一个安全级别。当一个主机系统同时符合多个安全策略所定义的安全状态时，它的安全程度由最高级别的安全状态所确定。



www.h3c.com

提到动态授权，不得不提到安全策略、安全状态和安全级别等几个概念。

所谓安全状态，是指通过设定一组明确的检查对象以及对各个检查对象所需进行的检查规则，来描述符合一定安全要求的系统状态。如远程主机所使用的操作系统类型和版本，是否打上了足够的补丁等。

为了表明不同安全状态的安全程度，由管理员根据自己的判断对每个安全状态指定一个安全级别。当同一台主机系统同时符合多个安全策略所定义的安全状态时，它的安全程度由最高级别的安全状态所确定。

在 SSL VPN 系统中，安全策略用于定义远程主机所处的安全状态，以及在相应的安全状态下，远程主机可以安全访问的网络资源。

安全策略中定义的访问权限和用户身份的静态权限的交集即为该用户登录后的实际访问权限。

动态授权—主机检查

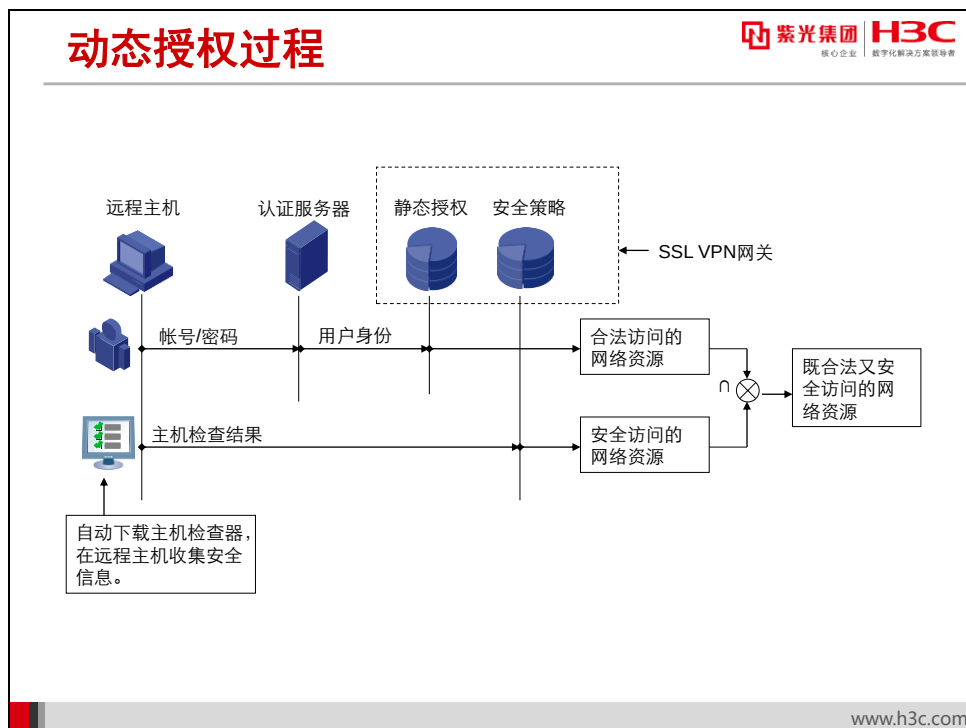
- 通过下载一个客户端程序对远程主机的安全状态进行检查，并将相关信息反馈给SSL VPN网关，网关可以对远程主机的安全状态进行评估，确定它的安全级别。
- 检查的内容包括：
 - 操作系统的类型、版本和补丁
 - 浏览器的类型、版本和补丁
 - 杀毒软件的类型、版本、病毒库版本
 - 防火墙软件的类型、版本和补丁
 - 个人证书
 - 指定的文件是否存在
 - 指定的进程是否存在



www.h3c.com

SSL VPN 网关是通过主机检查来确定登录主机的安全状态的。

在远程客户主机尝试登录 SSL VPN 过程中，会自动下载一个客户端程序至本地，该客户端程序会自动收集远程主机的安全状态，包括操作系统的类型、版本和补丁，浏览器的类型、版本和补丁，杀毒软件的类型、版本、病毒库版本，防火墙软件的类型、版本和补丁，用户使用的个人证书，指定的文件是否存在，指定的进程是否存在等等，并将这些信息反馈到 SSL VPN 网关，网关根据自身定义该远程主机的安全级别。



在配置动态授权的 SSL VPN 系统中，远程主机下载检查程序，检查程序将远程主机的安全状态发送给 SSL VPN 网关；SSL VPN 网关根据配置的安全策略决定给予该远程主机登陆上来的用户相应访问资源的权限。

同时，SSL VPN 网关会根据配置远程认证还是本地认证将用户输入的账号信息送到相应位置进行身份验证，并根据确定的用户身份赋予相应的静态权限。

这两部分权限的交集就是该用户本次访问 SSL VPN 系统最终的权限。

14.4.5 缓存清除

缓存清除

为避免私密信息遗留在远程主机上，SSL VPN提供了缓存清除功能。在用户退出SSL VPN系统时，SSL VPN客户端程序可以自动清除下列对象：

- 缓存的网页
- Cookie
- VPN客户端程序
- VPN客户端配置



www.h3c.com

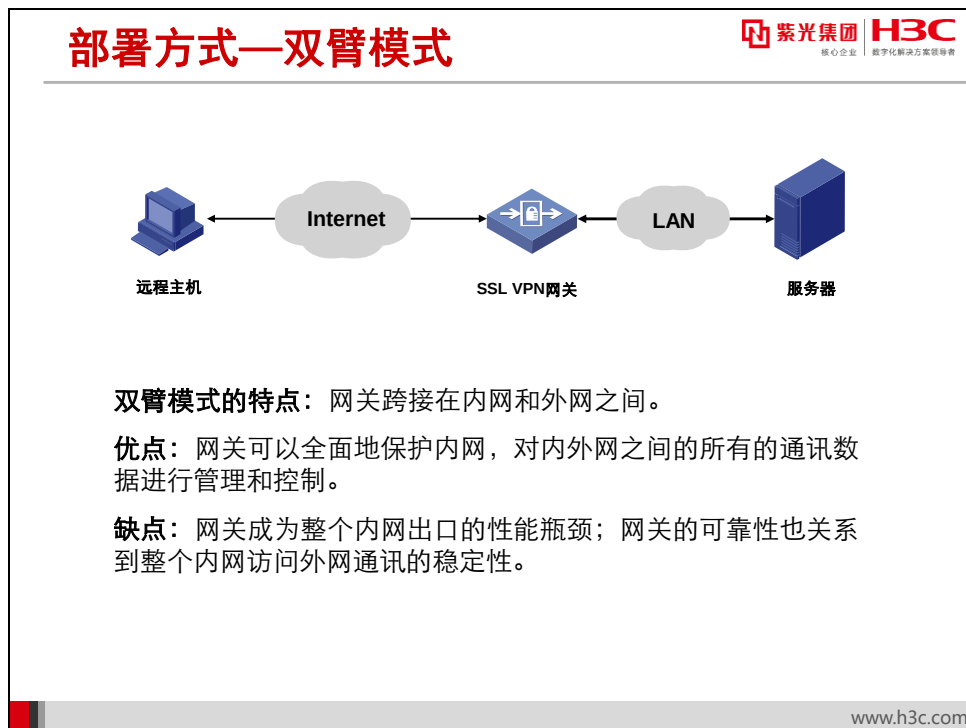
在使用 SSL VPN 的过程中，用户需要使用 Web 浏览器执行登录 SSL VPN 系统，访问 Web 资源等操作。Web 浏览器一般会对访问过的页面进行缓存，以提高访问效率。但这样做也导致一些来自内网站点的页面被保留在了远程主机上，有可能造成内网私密信息的外泄。

另外，Web 服务器普遍使用 Cookie 技术，来保存一些关于用户状态的信息，其中往往包含标识用户身份的 ID。Cookie 一般会在远程主机上保存一段时间。如果在此期间 Cookie 被黑客复制挪用，则此 Cookie 可以被用来伪造用户的身份，使得内部网络存在被黑客入侵的风险。

因此缓存清除非常重要，在用户登录 SSL VPN 后，会下载一个被称为“缓存清除器”的小程序。在用户退出 SSL VPN 系统时，缓存清除器会自动清除包含私密信息的页面缓存和 Cookie，当然也包括前面下载的各种客户端程序及客户端配置等。

14.5 部署SSL VPN

14.5.1 部署方式

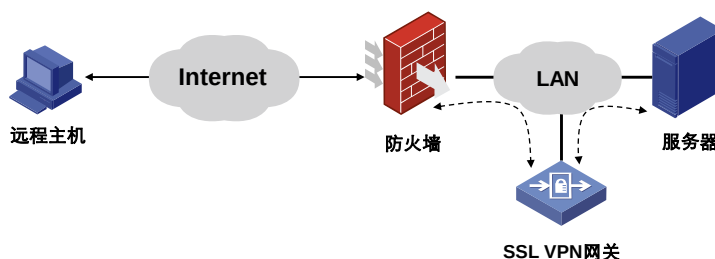


SSL VPN 在实际应用中有单臂和双臂两种组网模式。

采用双臂模式组网时，SSL VPN 网关跨接在内网和外网之间。这种组网的优势在于：外网对内网所有的访问流量都经过网关，网关可以对这些流量进行全面的控制。不足之处是：网关处于内网与外网通讯的关键路径上，一旦网关出现故障将导致整个内网与外网之间通讯的中断；网关的处理性能也对整个内网访问外网的速度有影响。

一般在 SSL VPN 网关与防火墙集成时，多采用双臂模式的组网。由于有防火墙对网络攻击的防护，所以 SSL VPN 可以比较安全地运行。

部署方式—单臂模式

紫光集团 H3C
核心企业 数字化转型方案领导者

单臂模式的特点：网关设备部署于内网，代理远程主机对内网服务器的访问。

优点：网关的处理能力不会成为整个内网访问外网的性能瓶颈，网关的临时故障也不会影响到整个内网对外网的访问。

缺点：网关设备不能全面地保护内部网络，只能对部分网络流量进行管理和控制。

www.h3c.com

采用单臂模式组网时，SSL VPN 网关并不跨接在内网和外网之间，而像一台服务器一样与内网相连。SSL VPN 网关作为代理服务器响应外网远程主机的接入请求，在远程主机与内网服务器之间转发数据报文。

单臂模式的好处是：设备不处在网络流量的关键路径上，设备的故障不会导致整个网络的通讯中断；另外，网关的处理性能不会影响到整个内网与外网通讯的性能。不足之处是：设备不能充分保护内部网络，有些流量可以不经过此设备而访问内部网络中的其它服务器。

单纯的 SSL VPN 设备一般多采用单臂模式，不但可以免受外部的网络攻击，还可以避免成为网络的性能瓶颈和单点故障源。

14.6 本章总结

本章总结

- SSL VPN是利用SSL协议建立远程连接的安全VPN。
- 具有免客户端安装、安全性高、移动性强等特点。
- SSL协议包括握手层和记录层，前者用于建立连接，后者用于发送和接收报文。
- SSL VPN一般采用单臂和双臂两种部署方式。

14.7 习题和解答

14.7.1 习题

1. SSL 协议的通讯实体一般分为两层，包括_____和_____。
2. SSL 协议的记录层用于封装传输报文，加密传输数据，为上层通讯提供包括下列哪些服务？（ ）
 - A. 保护传输数据的私密性，对数据进行加密和解密。
 - B. 验证传输数据的完整性，计算报文的摘要。
 - C. 提高数据的传输效率，对数据进行压缩。
 - D. 保证数据传输的有序性和可靠性。
3. 握手层的主要作用有？（ ）
 - A. 协商加密能力
 - B. 协商密钥参数
 - C. 验证对方身份
 - D. 建立并维护 SSL 会话
4. SSL VPN 接入方式非常丰富，包括下列接入方式。（ ）
 - A. Web 接入
 - B. TCP 接入
 - C. UDP 接入
 - D. IP 接入
5. SSL VPN 的权限控制非常灵活，提供了静态授权和动态授权两种方式，下列哪些关于授权的描述是正确的？（ ）
 - A. SSL VPN 可以提供高细粒度的访问控制，控制的粒度可以达到 URL、文件目录、服务器端口和 IP 网段。
 - B. 身份认证是静态授权的核心内容，用户权限的大小只是和账号有关。
 - C. 在配置动态授权的 SSL VPN 系统中，远程主机下载检查程序，检查程序将远程主机的安全状态。
 - D. 安全状态匹配的安全策略中定义的访问权限和用户身份的静态权限的交集即为该用户登录后的实际访问权限。

14.7.2 习题答案

1. 记录层、握手层
2. ABCD
3. ABCD
4. ABD
5. ABCD